

The Shadow Files

Том 3

Твёрдые Цели

YEHOR SELIN

Содержание

Прежде чем начать	4
Когда след закопан	6
Как устроен Том Третий	9
Мост из Томов Один и Два	12
Призрак в кэше	16
Восстановление удалённого аккаунта	35
Читаем фотографию для места	54
Читаем фотографию для времени	73
Домены и история регистрации	89
Прозрачность сертификатов	108
От инфраструктуры обратно к человеку	126
Пассивный DNS и отпечатки	146
Полноценная жёсткая цель	168
Что ты можешь сделать сейчас	195
Приложение А — Рабочий инструментарий (2026)	198
Приложение В — Шаблоны	204

Приложение С — Красные линии	215
Приложение D — Забери своё обратно	219
Глоссарий	225

Прежде чем начать

Это третий том The Shadow Files — практического курса по разведке из открытых источников, OSINT. Он идёт прямо после Томов 1 и 2. Если ты не прочитал основы — цикл, лестницу уверенности, дисциплину останавливаться на черте — и кросс-платформенную работу — как проводить человека по интернету, не теряя его — прочитай их сначала. Эта книга рассчитывает на оба.

Здесь всё выдуманно

Каждое имя, каждый ник, email, номер телефона, фотография, домен, IP-адрес, запись WHOIS, сертификат, координата и кейс в этой книге полностью вымышлены. Каждый из них построен, чтобы преподать метод — никогда чтобы описать реального человека, реальный сайт или реальное место. Любое сходство с реальным человеком, аккаунтом, доменом или событием — чистое совпадение.

Поскольку каждая деталь выдумана, примеры показаны целиком — записи выглядят полными, вместо замазанных символов — чтобы ты увидел, как реальный след ведёт себя в жизни, не задевая ни одной настоящей цели.

Правила, в одну строку

Только открытые источники. Ничего, что требует логина, пароля или обхода пейвола. Уважай приватность людей и закон. Это вся рамка, и она не ослабевает от того, что книга становится сложнее.

Два момента, которые стоит держать в голове. Том 3 учит тебя читать то, что люди считали стёртым, и помещать их в мир по вещам, которые они никогда не подписывали. И то, и другое кажется вторжением новичку — и является им, если использовать плохо. Знай закон там, где ты работаешь: читать публичный архив — не то же самое, что обманом вытянуть у сервиса приватные данные, а геолоцировать снимок, который человек публично выложил — не то же самое, что следить за его перемещениями. Второе: большая часть вреда в этом ремесле наносится людям, которые никогда не были целью — соседу, попавшему в тень, родственнику за отредактированным WHOIS, ребёнку на заднем плане фотографии. Бери только то, что отвечает на твой вопрос, и на этом остановись.

Профессионал — это не тот, кто находит больше всех. Это тот, кто знает, где остановиться.

Когда след закопан

Что меняется в Томе Третьем

В Томе 1 ты учился тянуть одну нить. В Томе 2 ты учился сплести нити с разных платформ в одну уверенную личность. Обе книги исходили из одного и того же: человек, или аккаунт, или фото *там*. Тебе оставалось только найти его и прочитать как следует.

Том 3 — про случаи, когда его там нет — по крайней мере, не там, где посмотрел бы обычный поиск.

Аккаунт удалён три года назад, и платформа говорит, что профиль «не существует». У фотографии нет подписи, нет метаданных, нет очевидного ориентира, а человек, который её выложил, не отвечает на вопросы. Домен за прокси приватности, а регистрант — строка из иксов. Операция вообще не в Instagram — она на сервере в стойке где-то, и единственное, что на неё указывает — сертификат, который машина выпустила в 3 часа ночи прошлого апреля.

Здесь новички сдаются, а профессионалы начинают. Потому что ничто из этого на самом деле не исчезло. Оно *смещено* — сдвинуто с очевидной поверхности на другую: в архив, в тень на земле, в лог сертификатов, в хеш фавикона. Ты должен знать, что другая поверхность существует, и уметь её читать.

Для кого эта книга

Для тебя, если первые два тома у тебя в крови и ты хочешь работать со случаями, где заканчиваются лёгкие пивоты. Тебе не нужно быть сетевым инженером или фотографом. Тебе нужны терпение, вкус к медленной работе и склад ума, который дали первые две книги. Если какое-то техническое слово тебя собьёт, в конце есть глоссарий — заглядывая в любой момент.

Что ты будешь уметь к концу

Восстановить аккаунт после его удаления. Поместить фотографию на карту по теням в кадре. Датировать её по погоде и солнцу. Провести домен от первой записи WHOIS до того, кто в 2016 забыл себя отредактировать. Читать лог прозрачности сертификатов так, как ты читаешь тред комментариев. Превращать инфраструктуру обратно в людей. И — умение, которое связывает всё это воедино — по-прежнему точно знать, когда остановиться.

Чем этот том не является

Это не пособие по взлому систем. Ничему здесь не нужен логин, пароль или способ обойти замок. Каждая техника читает записи, которые мир уже сделал публичными — по административным причинам, по соображениям безопасности или случайно — и читает их правильно. Профессиональный мир due diligence, отчётов по цепи хранения доказательств, контр-расследования и автоматизации ждёт Том 4. Здесь мы осваиваем одно и хорошо: сложные цели.

Если ты не видишь цель напрямую, посмотри на то, что зафиксировал мир вокруг неё.

Как устроен Том Третий

Серия, эта книга, и как построена каждая глава.

The Shadow Files — серия из четырёх томов. Каждый поднимает тебя на уровень выше, и каждый рассчитывает только на то, чему научил предыдущий.

- Том 1 — Основы. Склад ума, правила и твои первые настоящие навыки.
- Том 2 — Кросс-платформенная атрибуция. Как провести одного человека по соцсетям, мессенджерам, фото и утечкам — в единую, уверенную личность.
- Том 3 — Сложные цели. Удалённые аккаунты, геолокация, хронолокация и инфраструктура за операциями. *(Эта книга.)*
- Том 4 — Профессионал. Корпоративная работа, отчёты, контр-расследование и превращение навыка в ремесло.

Замечание о рамках: этот том наконец уходит дальше профиля. Половина его всё ещё про людей — тех, кто считал, что стёр себя, тех, кого ты помещаешь через окно, которое они никогда не подписывали. Вторая половина — про то, что люди строят и забывают спрятать: домены, хосты, сертификаты, трекеры. Но даже главы про инфраструктуру заканчиваются там, где заканчивается

каждая глава этой серии — на человеке.

Внутри этого тома

1. Призрак в кэше 2. Восстановление удалённого аккаунта 3. Читаем фотографию для места 4. Читаем фотографию для времени 5. Домены и история регистрации 6. Прозрачность сертификатов 7. От инфраструктуры обратно к человеку 8. Пассивный DNS и отпечатки 9. Полная сложная цель

Как построена каждая глава

Тот же ритм, что и в Томах 1 и 2, чтобы ты всегда знал, где ты:

- Идея — простыми словами, без жаргона.
- Метод — как профессионал реально думает и работает, шаг за шагом.
- Разобранный кейс — короткое, выдуманное расследование, за которым можно проследить, с оставленными тупиками.
- Упражнение — что-то безопасное и законное, что ты делаешь сам.
- Резюме — те несколько вещей, которые нужно запомнить.

Одно обещание про инструменты

Как раньше: сначала метод, потом инструменты. Часть инструментов, названных здесь, к моменту чтения может уже исчезнуть, а новые займут их место. Это нормально.

Мышление не меняется. Освой метод — и любой инструмент станет просто более быстрым способом сделать то, что ты уже понимаешь. Том 3 по своей природе тяжелее по инструментам, чем Том 2 — ты будешь читать логи сертификатов и базы обратного DNS, а это буквально сервисы — но *вопросы*, с которыми ты приходишь к этим сервисам, — те же три вопроса, что ты задавал с Тома 1: что открыто, от чего можно пивотить, кому я атрибутирую.

Мост из Томов Один и Два

Основы, на одну страницу, прежде чем идти глубже.

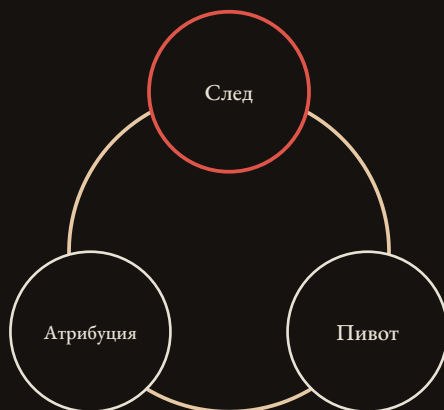
Прежде чем идти куда-то новое, дай мне вернуть тебе в руку основы — быстро. Если что-то из этого кажется незнакомым, это твой сигнал вернуться к предыдущим книгам, прежде чем идти дальше здесь. Всё в этом томе опирается на эти четыре вещи.

Цикл

Любое расследование, каким бы странным ни был фасад, — это одни и те же три хода, идущие по кругу.

След → пивот → атрибуция.

ЦИКЛ



одна зацепка, ходи по кругу, пока не укажет на человека

Три хода идут циклом — атрибуция кормит следующий след.

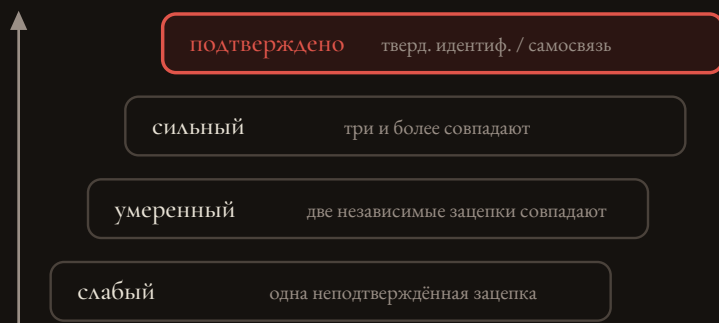
След — это отпечаток, который кто-то или что-то оставил на виду. Пивот — превращение этого следа в следующий. Атрибуция — момент, когда достаточно следов выстраиваются в линию и указывают на одну реальную личность — человека, группу, оператора. В Томе 3 след часто исторический (снимок, запись в логе, старая запись), а не живой. Циклу всё равно. Ты крутишь его так же.

Лестница уверенности

Совпадение — не факт. Мы всегда говорим, *насколько* уверены, в четырёх фиксированных словах:

- **слабый** — одна неподтверждённая зацепка. Лид, никогда не вывод.
- **умеренный** — две независимые зацепки согласуются.
- **сильный** — несколько независимых сигналов, которые вместе трудно объяснить любой конкурирующей гипотезой. Обычно три и больше. Два тяжёлых, диагностических могут сами по себе дотянуть до сильного. Три слабых, общих — могут и не дотянуть.
- **подтверждено** — жёсткий уникальный идентификатор или настоящая самоссылка, независимо закреплённая так, что кто угодно сможет перепроверить.

ЛЕСТНИЦА УВЕРЕННОСТИ



Четыре ступени, на которые ты поднимаешься только по независимым сигналам: слабый, умеренный, сильный, подтверждено.

Лестница важнее в Томе 3, чем где-либо ещё. Ты читаешь следы, которые никогда не задумывались как способ кого-то опознать — тень, серийник в записи WHOIS, хеш фавикона, — и очень легко принять наводящую форму за доказательство.

Независимость, и почему это здесь трудно

Два факта из одного и того же источника считаются за один голос. В Томе 2 это в основном было про то, чтобы не считать дважды самоссылку с ником. В Томе 3 ловушка больше: запись WHOIS, обратный DNS на том же хосте и сертификат, который этот хост отдаёт, — часто *три взгляда на один файл*, на настройку одного оператора, — а не три независимых сигнала. Учись каждый раз спрашивать: *остались бы оба эти факта верными, если бы моя теория была неверна?* Если ответ «нет» — у тебя один сигнал, а не два.

Черта, и где остановиться

Только открытые источники. Никаких логинов, никаких обходов, никакого скрейпинга за пейвол или robots-файл, никаких разговоров с целью под чужим именем. Методы Тома 3 позволяют очень легко продолжать — домен ведёт к хосту, хост к клиенту, клиент к дому — так что назови законный вопрос, на который ты отвечаешь, одним простым предложением, до первого пивота. Если не можешь — у тебя любопытство, а не дело.

Основы в руке? Хорошо. Пошли в закопанные места.



ГЛАВА ПЕРВАЯ

Призрак в кэше

Когда цель жмёт «удалить», она удаляет только ту копию, которой владеет.

Городской советник вычищает предвыборную страницу в пятницу вечером. К воскресенью после обеда страница исчезла из каждого места, куда он додумался посмотреть, и он спит чуть спокойнее. Он вбивает своё имя в поисковую строку и видит только чистые результаты. Он говорит своему главе аппарата, что вопрос решён.

Он ошибается, и не потому, что упустил какую-то настройку. Он ошибается потому, что всегда контролировал только одну копию.

Новичок в понедельник открывает тот же URL, видит 404, пишет в заметках «удалено» и закрывает вкладку. Именно здесь большинство дел умирают — не потому, что работа сложна, а потому, что слово *удалено* звучит окончательно, и интернет приучил нас ему верить.

Профессионал открывает тот же URL, видит тот же 404 и особо ничего не чувствует. Страница под его контролем — не та страница, которая интересна. Интересные страницы — те, которыми он никогда не владел: снапшот в архиве от 2020, блог сторонника, который процитировал три абзаца дословно, новостной агрегатор, закешировавший превью-карточку, сосед, сделавший скриншот поста, чтобы поспорить с ним, RSS-лента, вытянувшая заголовок в базу, которую никто не чистил шесть лет. У каждой копии свой владелец, свой график, своя кривая распада. Никто из них не узнал про удаление в пятницу вечером.

Этот разрыв между тем, во что верит цель, и тем, что помнит экосистема, — вся тема этой главы.

Идея: твоё удаление касается только твоей копии

Публикация в современном вебе ближе к чиханию в переполненной комнате, чем к записи в личном дневнике. В момент, когда ты публикуешь, другие системы тянутся и делают копии по причинам, не имеющим к тебе никакого отношения: чтобы индексировать, показать превью, заархивировать, встроить, процитировать, поспорить. Каждая копия живёт по чужому расписанию. Когда ты жмёшь «удалить», ты говоришь только с одним сервером, доверяющим твоему логину. Остальные не получают уведомления, и большинство из них не отреагировали бы, даже если бы получили.

Это принцип. Всё остальное в этой главе из него следует.

Удаление под контролем пользователя — не удаление в экосистеме.

Полезная ментальная модель — распад кэша. У каждой копии страницы свой период полураспада — одни короткие, другие абсурдно длинные. Текст превью у поисковика может обновиться за дни. Крупный веб-архив может держать снимок десятилетие и дольше. У скриншота у друга срока годности нет вовсе; он живёт, пока друг не почистит телефон, что фактически означает — вечно. Если понимаешь кривые распада — понимаешь, где смотреть и сколько у тебя времени.

THE CACHE TREE



delete removes the trunk — the branches keep their own lives

Одна удалённая страница расходится веером по слоям с диким разбросом периодов полураспада — от часов до десятилетий — а твоя кнопка «удалить» дотягивается только до ствола.

Из этого следует два вывода. Ни один слой не полон — если ты ничего не нашёл в Wayback, ты не искал, ты посмотрел в одном месте. И слои стареют с разной скоростью, так что дело, холодное в 2026, может ещё быть тёплым внутри агрегатора, который никто не подрезал с 2019.

Где копии реально живут в 2026

Есть семь слоёв, которые стоит проверить, прежде чем говорить, что чего-то нет. Выучи их как чеклист. Не пропускай слой потому, что прошлому делу он не понадобился — разные цели протекают в разные слои.

- **Общие веб-архивы.** Wayback Machine и archive.today — рабочие лошадки. Wayback идёт масштабом и автоматизацией; archive.today идёт людьми, сохраняющими страницы вручную, и захватывает то, что Wayback часто пропускает (пейволльные новости, отдельные твиты, страницы, которые владелец сайта попросил Wayback скрыть). Разные инструменты, разное покрытие — проверяй оба.

- **Целевой архив исследователей и активистов.** Небольшие кольца снапшотов, которые ведут академики, журналисты и энтузиасты — мониторы политической рекламы, трекеры экстремизма, зеркала имиджборд, зеркала судебных документов. Они узкие, но глубокие, и часто хранят то, до чего большие архивы никогда не дотянулись.

- **Кэш поисковиков.** Оператор cache: у Google был тихо снят в 2024, и ссылка на закешированную страницу больше не появляется в выдаче. Bing держал версию этой фичи дольше, но истончил её. Считай кэш поисковиков бонусным слоем, а не надёжным — большую часть дней он пуст.

- **Front-end зеркала и read-only фронтенды.** Несколько лет существовали лёгкие read-only фронтенды для больших платформ — паттерн Nitter для Twitter, Bibliogram для Instagram, Invidious для YouTube. Большинство публичных инстансов к 2026 мертвы,

потому что платформы затаили свои API. *Паттерн* повторяется всё равно: как только платформа враждебна к чтению без логина, кто-то делает scraper-зеркало.

Некоторые из этих зеркал тихо хранят контент, который источник с тех пор удалил.

- Синдикация и RSS-агрегаторы. Новостные скрейперы, feed-ридеры и email-дайджест-сервисы вытянули страницу, когда она вышла, и сохранили заголовок, текст превью и часто первые абзацы в своей базе. Многие из них построены в 2011 и никогда не убирались. Их поисковые строки старые и медленные, и это золотые жилы.

- Третьи стороны, которые процитировали или скриншотнули. Блог сторонника копирует три абзаца. Критик вставляет весь текст в форумный тред, чтобы поспорить. Журналист скриншотит заявление для статьи. Ничего из этого не удаляется, когда удаляется источник — у них свои владельцы и свои причины держать копию.

- Упоминания, до которых удаление не дошло. Комментарии, которые цель оставила под чужими постами. Фотографии, на которых цель отметили. Треды ответов. Quote-посты на других платформах. Кэши встраиваний на новостных сайтах, вытянувших виджет. Share-URL, отправленные в групповой чат два года назад. Цель удалила страницу; она не удалила свои следы по чужим страницам, и нажатие «удалить» на стволе никак не касается листьев.

Что ещё работает в 2026, а что тихо умерло

Более старые руководства — включая первое издание этой книги — опирались на пару ходов, которые больше ведут себя не так, как раньше. Ничто не старит следователя быстрее плохой стрижки, чем уверенное исполнение хода, который платформы закрыли годы назад. Так что учи идею под каждым мёртвым трюком и иди искать её сегодняшний эквивалент.

- **Google cache:** умер. Двадцать лет ты мог набрать `cache:example.com/page` и прочитать копию страницы, размещённую на Google. Ссылка исчезла из выдачи в начале 2024, а сам оператор больше не работает.

Принцип остаётся: поисковики по-прежнему заглывают страницы и держат внутренние копии для ранжирования. Что ты всё ещё видишь — это *сниппет*, две строки под синей ссылкой, которые часто являются превью текста, уже убранного с сайта. Читай сниппеты внимательно; это кэш в миниатюре.

- **Именованные front-end зеркала** в основном мертвы. Публичные инстансы Nitter, которыми делились в Slack-каналах до 2022–2023, в основном исчезли; последние инстансы Bibliogram сгинули примерно тогда же. **Принцип остаётся:** как только платформа перекрывает чтение без логина, кто-то делает облегчённый фронтенд, который скрейпит публичные части. Не запоминай имя сервиса, запоминай *форму* — «read-only

зеркало платформы X» — и иди искать то, что выжило в этом году.

- Wayback не полон и не вечен. Два предположения, от которых нужно избавиться. У Wayback есть не каждая страница — многие сайты исключены, а его покрытие соцплатформ тонкое и истончается. Покрытие также распадается по причинам, не связанным с robots.txt — Internet Archive перестал уважать его ретроактивно ещё в 2017. Снапшоты исчезают потому, что владельцы сайтов заполняют форму исключения, потому, что ДМСА и подобные тейкдауны снимают конкретные захваты, и потому, что большие платформы борются с краулерами достаточно жёстко, что даже существующие снапшоты часто оказываются JavaScript-оболочкой, стеной логина или ошибкой рендера, наряженной в страницу. Принцип остаётся: архивы помнят то, что цель забыла. Но не всё, и не навсегда — проверяй родственные архивы и фиксируй, что нашёл, пока ещё видишь.

Прежде чем смотреть

Два знака «стоп», оба стоят уважения.

Архивы не пассивны. Wayback логирует запросы. archive.today логирует запросы. Rate-limits существуют и укусят, если ты по ним колотишь, а сгоревший IP может стоить дела. Двигайся с человеческой скоростью. Если у страницы три снапшота, открой три снапшота — не скрейпи

весь календарь. И никогда не заказывай свежий захват страницы живой цели, если ты хорошо не подумал, что делаешь. Три причины. Во-первых, это *маркер* — часть архивных сервисов тянет URL с IP, который сайт цели логирует, часть триггерит краулеры превью ссылок, которые появляются в аналитике цели, и внимательный субъект, следящий за *referrer*-логами, видит незнакомца, спрашивающего про него по имени. Во-вторых, ты навсегда фиксируешь материал, на распад которого цель, возможно, рассчитывала; в контексте охранного ордера, защиты источника или борьбы со сталкингом это не нейтрально, это действие, оставленное на записи. В-третьих, в некоторых юрисдикциях сознательное сохранение материала живого лица в деле о преследовании или охранным ордере может быть представлено как вмешательство в его права на собственные данные. Не юридическая консультация; рабочее правило одинаковое. Читай то, что уже существует; не создавай новых доказательств без реальной причины.

Второй знак «стоп» — OPSEC на твоей стороне. Используй чистый исследовательский браузер без залогиненного Google — соседние с *cache* продукты Google логируют каждый URL, который ты запрашиваешь, под твоей личностью, а история исследований, смешанная с личным поиском, — утечка в ожидании дня. Отключи синхронизацию. Используй профиль, который не носит твоих реальных *cookies*. Скучная гигиена, и важнее всего в

тот день, когда о ней забываешь.

Метод, шаг за шагом

Шаг 1 — Зафиксируй формы URL. У страницы больше адресов, чем цель когда-либо думает. Канонический (example.com/post/1234), «vanity» (example.com/@dale/purnell-for-district-4), share-форма (example.com/s/aB3xQ), embed (example.com/embed/1234), мобильный поддомен (m.example.com/...), вариант AMP или reader-mode, глубокая ссылка на конкретный комментарий. Разные кэши индексировали разные формы. Запрос в Wayback по каноническому URL может вернуть ноль; тот же запрос по share-URL — пять снапшотов. Выпиши все правдоподобные формы, прежде чем что-либо запрашивать.

Шаг 2 — Пройди таймлайн Wayback. Открой web.archive.org/web/*/<url> и прочитай весь календарь, а не только последний захват. Самый свежий снапшот часто наименее полезен — он мог быть сделан *после* удаления и показывает 404. Более старые обычно богаче — сделаны, когда цель ещё публиковала открыто. Записывай *время снимка* на каждый снапшот, который сохраняешь; важна эта метка, а не сегодняшняя дата.

Попробуй (2026). Возьми любой публичный аккаунт, на который ты подписан — свой подойдёт. Открой

web.archive.org/web/*/ <URL их профиля> и прочитай таймлайн сверху донизу. Заметь, как покрытие кучкуется вокруг событий (виральный пост, упоминание в новостях) и истончается в тихие месяцы. Отметь последний захват до того, как аккаунт как-то заметно изменился — переименование, переписанное био, уход в private. Этот последний-до-изменения снимок — тот, который тебе нужен был бы в реальном деле, и находить его должно быть рутиной, а не подвигом.

Шаг 3 — Проверь родственные архивы. archive.today первым — он захватывает то, что Wayback отвергает или пропускает, особенно отдельные соцпосты и пейвольные новости. Затем, в зависимости от страны и темы цели, проверь специализированные архивы: Perma.cc для того, что мог сохранить юрист или академик, UK Web Archive для .uk доменов и британских госорганов, Arquivo.pt для португальского и лузофонного контента, национальные библиотеки веб-архивов в других местах. Упоминаю их здесь как *форму*, не рекомендацию — суть в том, что «веб-архив» — это не один сервис, это семейство, и разные его члены поймали разные вещи.

Шаг 4 — Читай то, что оставили поисковики. Ссылка cache: мертва. Снимет — нет. Прогони site:example.com "<редкая фраза из удалённой страницы>" и прочитай двухстрочное превью под каждым результатом. Текст

превью генерируется из внутреннего снимка, который движок не обязательно обновлял. Если у цели был характерный оборот речи — слоган, необычное имя, странно специфичное число — прогони его в кавычках по всему открытому вебу и посмотри, где ещё он приземлился. Редкая фраза — отпечаток; распространённая — шум.

Шаг 5 — Иди за третьими сторонами, которые процитировали. Если публичное лицо сказала что-то цитируемое, кто-то его процитировал. Прогони обратный поиск по пропавшей аватарке, чтобы найти блоги и форумные посты, которые её встраивали. Прогони поиск в кавычках по характерному предложению из того, что помнишь со страницы — со скриншота в новостной статье, из своих заметок, из опровержения критика.

Сайты-агрегаторы, блоги мнений и однотемные форумы негламурны и богаты.

Шаг 6 — Пройдись по копиям в экосистеме. Удаление не тронуло комментарии, которые цель оставила под чужими постами, отмеченные фото, quote-ответы, share-URL, вставленные в публичные групповые чаты. На соцплатформах ищи *ник* цели, а не её профиль — получишь каждое упоминание, а каждое упоминание — фрагмент страницы, которую она сняла.

Шаг 7 — Дисциплина свежести. Для каждого утверждения в заметках записывай URL *конкретного снимка*, из

которого ты его взял, и его *время снимка*. Не «найденно в Wayback». URL снапшота с меткой времени — цитата; «Wayback» — слух. Когда ранжируешь утверждение на лестнице — *слабый / умеренный / сильный /* подтверждено — убедись, что каждый поддерживающий сигнал указывает на снапшот, а не на память.

Разобранный кейс, с тупиками и всем

Dale Purnell — вымышленный, со Среднего Запада, четвёртый округ городского совета — провёл неудачную перевыборную кампанию в 2019 на странице Facebook под названием «Purnell for District 4». После скандала в начале 2026 вокруг контрактного решения из его прошлого срока страница была тихо удалена вместе с его личным аккаунтом. Репортёр местного еженедельника, разбирая, что Purnell реально обещал избирателям в 2019 по тому контракту, спрашивает, есть ли шанс восстановить хоть что-то со страницы кампании. URL у неё — facebook.com/purnellfordistrict4.

Тупик с Google cache. Первый инстинкт — старая мышечная память — `cache:facebook.com/purnellfordistrict4`. Google вернул «нет результатов». Оператор мёртв; мышечная память — плохая привычка. Идём дальше.

Тупик с Wayback. У Wayback было три снапшота. Два — JavaScript-оболочка: Facebook рендерится на клиенте, и

снапшот захватил спиннер загрузки и больше ничего.

Третий, посвежее, упёрся в другую стену: к моменту, когда краулер Wayback дошёл до страницы, антикраулерная защита Facebook вернула логин-запрос и оболочку рендера, вот это и сохранилось. Более ранние захваты на этом домене истончились и по обычным причинам — исключения владельцев сайтов и тейкдауны работают ретроактивно, даже когда robots.txt — нет.

```
wayback listing for purnellfordistrict4
-----
* facebook.com/purnellfordistrict4
snapshots found: 3
  2019-10-14  captured (JS shell)
  2019-11-02  captured (JS shell)
  2023-04-18  unusable (auth wall)
-----
0/3 usable
```

Три снапшота, три стены.

Тупик с archive.today. У archive.today был один снапшот, октябрь 2019. Этот реально отрендерился — настоящая страница, настоящие посты, настоящий закреплённый контент сверху. Только снапшот был со страницы профиля, а не отдельного поста, и закреплённые комментарии под каждым постом — где в 2019 Purnell отвечал на вопросы избирателей про контракт, иногда развёрнуто — были свёрнуты и не захвачены. Снапшот сохранил стену и потерял разговоры.

Пивот. У репортёра было одно, с чем работать: она помнила фразу из речей Purnell — «prudent stewardship of the district's dollars» — которая появлялась на странице дословно не раз. Поиск этой фразы в кавычках, ограниченный блогами и новостями, стал трещиной.

```
dork: "prudent stewardship of the district's dollars"
-----
1. citizenswatch-oakhaven.blog  2019-09
   "quoting Purnell's page in full below..."
2. district4-neighbors forum    2019-11
   thread: "what did he actually promise"
3. oakhaven-weekly.com/rss.xml  2019-10
   preview: "...prudent stewardship..."
-----
3 hits, all 2019, all outside FB
```

Фраза донесла то, что не донёс URL.

Первый хит был блоготом граждан-«наблюдателей», который в сентябре 2019 вставил три абзаца поста Purnell про контрактную политику целиком — блогер хотел спорить с ними по строчкам и в процессе сохранил их по строчкам.

Второй — тред на соседском форуме под названием «что он на самом деле обещал», в котором один участник скриншотнул пост, а другой транскрибировал текст под ним. Третий — RSS-лента собственного агрегатора местного еженедельника, который в 2019 подтягивал посты Purnell из Facebook в сайдбар-виджет и никогда не чистил базу — текст превью шести постов всё ещё лежал там, адресуемый по URL, если знаешь паттерн.

Ранжирование. Цитата в блоге — сильный сама по себе для тех абзацев, которые она приводит: дословно, датировано сентябрём 2019 в архиве самого блога, у блогера не было мотива фабриковать цель, которую он уже критиковал своими словами. Форумный скриншот плюс транскрипция — умеренный: скриншот можно отредактировать, а транскрипция вводит второе место сбоя, — но там, где она перекрывается с блогерской цитатой, это подтверждено, а там, где выходит в закреплённые комментарии, которых блог не касался, остаётся умеренным. Агрегатор RSS — умеренный для текста превью и не больше: превью — фрагмент, а фрагменты могут вводить в заблуждение без окружающего абзаца.

Репортёр получила частичное восстановление удалённой страницы, процитированное по трём независимым источникам с временами снимков, и чёткую линию, какие абзацы она может цитировать как *что Purnell написал* (сильный) против *что он, судя по всему, написал* (умеренный). Удаление Purnell дошло до ствола. Оно не дошло до блога, форума и агрегатора и никогда не дойдёт.

Второй кейс: тот, что не закрывается

Другой запрос в тот же месяц. Приватный аккаунт в Instagram, удалён в середине 2022, якобы принадлежащий свидетелю по гражданскому делу. Покрытия архивов нет — у Wayback ноль снапшотов по vanity-URL и ни одного по числовому ID; у archive.today нет; специализированные кольца, зеркалящие контент Instagram, никогда не видели ник. Аватарка была закеширована в публичном превью одного стороннего аналитического инструмента, но изображение — обычный закат, и обратный поиск вернул только сток. Никто не цитировал аккаунт. В открытом вебе не всплыли скриншоты. Район, из которого аккаунт постил, был маленьким настолько, что форумный поиск должен был поднять *хоть что-то*, а не поднял.

Отчёт клиенту: не смог атрибутировать. Ни один слой не заплатил. Я отдал им список проверенных слоёв, запросы, которые прогонял, и времена снимков негативных результатов, чтобы если дело позже откроется, они знали, что уже пробовали. Беспорядок — это работа, а не ошибка.

Безопасное упражнение

Возьми публичную новостную статью трёх- или четырёхлетней давности по истории, которую помнишь — национальное событие, местные выборы, что угодно с реальным репортажем. Открой Wayback и пройди таймлайн захватов статьи. Прочитай самый ранний захват, средний и самый свежий. Заметь исправления, изменённые заголовки, отредактированные абзацы, заменённые или убранные фотографии. Отметь время снимка на каждом. Ты никого не расследуешь; ты тренируешь глаз видеть, что один URL — на самом деле семья версий, и версия, которую ты находишь сегодня, может быть не той, которую кто-то читал в день, когда это имело значение. Этот рефлекс — *какую версию я смотрю и когда она была снята* — вся дисциплина в миниатюре.

Резюме

- Удаление под контролем пользователя — не удаление в экосистеме; копии, которыми ты никогда не владел, продолжают быть копиями.
- У каждой копии своя кривая распада; одни слои обновляются за дни, другие держат десятилетиями.
- Проверь все семь слоёв, прежде чем считать страницу исчезнувшей; не пропускай слой потому, что прошлому делу он не понадобился.

- Google cache: мёртв; front-end зеркала в основном тоже; Wayback не полон и не вечен. Учи принцип, а не инструмент.
- Двигайся с человеческой скоростью по архивам; никогда не заказывай свежий снимок страницы живой цели, если не понимаешь, чем платишь.
- Зафиксируй все формы URL, прежде чем запрашивать; разные кэши индексировали разные формы.
- Записывай *время снимка* каждого снимка в заметках и цитируй URL конкретного снимка, а не главную страницу архива.
- Некоторые дела не закрываются, и отчёт «не смог атрибутировать» с проверенными слоями — реальный результат.

Что дальше

Следующая глава переходит от удалённых *страниц* к удалённым *профилям* — аккаунтам, которые закрыл, переименовал или вычистил стоящий за ними человек, — и к тому, сколько от человека всё ещё стоит, когда аккаунта, которым он пользовался, больше нет.



ГЛАВА ВТОРАЯ

Восстановление удалённого аккаунта

Аккаунт уходит с платформы. Человек не уходит из экосистемы.

Ты вбиваешь ник в адресную строку, и страница грузится полсекунды, прежде чем платформа принимает решение. *Sorry, this page isn't available.* Ни аватарки. Ни баннера. Ни 404 с дружелюбным мультиком. Просто стандартная стена, которую сайт показывает, когда аккаунт удалён, деактивирован или вычищен командой доверия.

Большинство закрывают вкладку. Кто-то пробует другую капитализацию ника. Пара человек догадывается проверить кэш, получает один хит и на этом останавливается.

Ты сделаешь больше, потому что стена, в которую ты только что упёрся, — стена *одной* витрины. За ней человек, который держал эту витрину, был отмечен на свадебных фото, процитирован в местной газете, добавлен в группу старым коллегой и назван в посте про ужин торговой палаты. Ничего из этого не жило на его профиле. Оно жило на чужих профилях, на чужих серверах, в кэшах, которые не подчиняются никому из его знакомых. Аккаунта нет. Человек — есть.

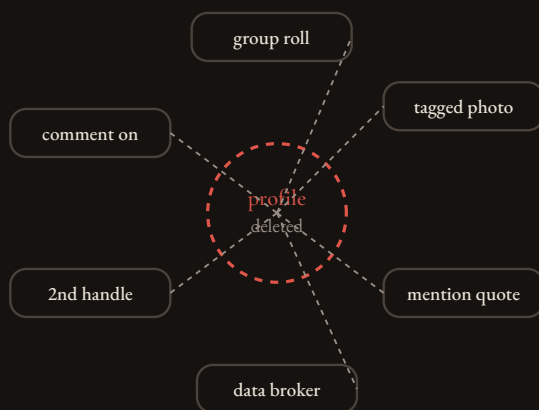
Эта глава — про перестройку человека из того, что оставила экосистема. Это другая работа, чем в Главе Первой. Там ты спасал конкретный *пост*, который кто-то снял. Здесь ты спасаешь *личность*, которую кто-то пытался закрыть. Техники рифмуются. Трение тяжелее, и этика тоже.

Идея: человек — не профиль

Представь удалённый аккаунт как арендованную витрину на людной улице. Пока арендатор был там, он высовывался из окна, махал соседям, вписался в уличную рассылку, попадал на задний план в фотографиях других торговцев, спорил с покупателем, который написал об этом в местной газете. Когда он возвращает ключи, домовладелец закрашивает вывеску. Вот что значит «аккаунт удалён»: витрина пуста, и вывески нет.

Всё остальное остаётся. У соседей всё ещё их фото. В рассылке всё ещё старый адрес. У газеты всё ещё статья. Покупатели всё ещё помнят. Домовладелец — платформа — может решить только, что делать с самим магазином. Он не может ходить по улице, стирая память всех остальных.

THE DELETED RING



the storefront is gone — the street around it kept a copy

В центре — заколоченная витрина: профиль, который больше не разрешается. Вокруг, всё ещё под светом, — стены соседей, которые тегали магазин, списки групп, куда он входил, архивы, снявшие его снимок, брокеры данных, продавшие копию его вывески годы назад, и второй аккаунт по соседству, который никто не подумал закрыть.

Удаление витрины не удаляет улицу. Твоя работа — пройти по ней.

Что переживает смерть профиля

Точный каталог сдвигается по платформе и по году, но форма держится. Когда сам профиль исчез, у тебя обычно остаётся какое-то подмножество нижеследующего.

- Отмеченные фото на чужих стенах. Фото, на котором цель была отмечена, живёт на странице *того, кто выложил*. После удаления тег превращается в лейбл «пользователь недоступен», но подпись автора часто по-прежнему называет человека простым текстом, а лицо остаётся в кадре.
- Комментарии, которые цель оставила под публичным контентом. Треды на страницах публичных новостей, брендовых постах, страницах сообществ и постах авторов часто сохраняют старые комментарии нетронутыми после смерти аккаунта комментатора. Ник схлопывается в плейсхолдер; текст, а часто и закешированная миниатюра

аватарки, остаётся.

- **Списки участников групп и страниц.** Списки членства, RSVP на события, списки модераторов страниц и админ-логи живут на стороне группы. Уборка после удаления пользователя — неравномерная; ты по-прежнему увидишь имя в «прошлых участниках», в старых admin-кредитах и на фото с событий.
- **Кросс-пост цитаты и embed'ы.** Твит, встроенный в пост в блоге в 2019, — копия этого твита, отдаваемая блогом, а не платформой. Шейр коммьюнити-таба YouTube, который канал перепостил в рассылку, — копия в рассылке. Удаление оригинала не дотягивается до embed.
- **Утечки данных платформы, предшествующие удалению.** Скрейп Facebook 2019, скрейп LinkedIn 2021, разные форумные дампы, гуляющие по leak-рынкам: если человек был на платформе на ту дату, его запись в этом дампе и останется там. Обращайся аккуратно и только для законных целей.
- **Снапшоты брокеров данных.** People-search сайты, зеркала бизнес-регистраций и directory-скрейперы рутинно захватывали публичные профили годы назад и никогда не перепроверяли. Профиль, удалённый в 2024, может быть воспроизведён из снапшота брокера 2019, часто со старым био, старым работодателем и старым фото.

- Остатки френд-графа на чужих аккаунтах. Список друзей самой цели ушёл вместе с ней, но на платформах, где списки друзей можно оставлять публичными, они по-прежнему появляются внутри *чужих* списков — как неназванный плейсхолдер или как старое отображаемое имя, сохранённое в кэшированных копиях. Кластер открытых профилей, которые молча перечисляют одного и того же пропавшего друга, — отпечаток.
- Второй и «дремлющие» аккаунты на кросс-платформах, о которых забыли. Люди удаляют громкий аккаунт и оставляют тихие: старый DeviantArt со времён художки, Goodreads под псевдонимом, Strava, Letterboxd, старый блог на давно закрывшемся хосте. Их редко захватывает волна «удалите моё присутствие».

Что тихо перестало работать

Три хода, которым старые руководства учили уверенно, больше не делают ту работу, что раньше. Пойми, что умерло, а что нет.

- Facebook Graph Search. Годами ты мог перечислять друзей названного человека, фотографии, сделанные в месте, посты, лайкнутые пользователем, — всё через структурированные поисковые запросы. Facebook убрал Graph Search в 2019. Принцип остаётся: френд-граф всё ещё самая короткая карта от удалённого аккаунта к реальной жизни человека. Ты просто больше не можешь

запросить его централизованно. Ты доходишь до него, обходя открытых друзей вручную.

- **LinkedIn'овские публичные страницы «people you may know».** Раньше их можно было краулить без логина, и они давали тебе карту 2-го круга цели напрямую. Сейчас они за стеной аккаунта, а щупать их из залогиненного аккаунта сливает *тебя* в сеть рекомендаций цели (двусторонняя ловушка РҮМК, разобранный в Томе 2). Принцип остаётся: 2-й круг всё ещё выдаёт скрытый 1-й. Ты просто должен строить его из других публичных сигналов, а не из скрепленной страницы.

- **Массовые скрейперы френд-листов.** На некоторых платформах технически возможно, категорически — нарушение ToS, и бесполезно в суде. Мы так не делаем. Принцип остаётся: цель снова появляется в открытых списках людей, которые её знали. Ты доходишь до этого ручным чтением того, что эти люди решили оставить публичным, а не скриптовым сбором. Любой инструмент или сервис, обещающий обратное, продаёт тебе иск.

Если техника в этой главе называет конкретный сайт или endpoint, считай, что к моменту чтения он может быть мёртв. Форма хода переживает дверь.

Прежде чем смотреть

Перестройка удалённой личности оставляет больше следов на большем числе людей, чем почти любая другая работа в этой книге. Друг, чей свадебный альбом ты грузишь десять раз, увидит всплеск в счётчике просмотров поста. Старый блог, который ты тянешь три раза из трёх разных снапшотов, оставит небольшой паттерн в логах. Если твоя работа чувствительна, относись к каждому запросу как к видимому событию на чужой собственности и веди себя как гость, знающий, что его замечают.

Используй нормальный исследовательский браузер — отдельный профиль, никаких личных логинов, никакой синхронизации контактов, никакого доступа к адресной книге, никакой телеметрии на твою реальную личность. Двусторонняя проблема «people you may know» из Тома 2 применима здесь в полной силе: шупать старый круг цели из залогиненного исследовательского аккаунта может вывести *твой* исследовательский аккаунт на тех самых родственников и коллег, которых ты тихо читаешь. Так умирают исследовательские аккаунты и сгорают дела.

И этика. Человек, который удалил аккаунт, выбрал, на записи с платформой, чтобы она его забыла. Отменять этот выбор — не нейтрально. Имей реальную причину, которую можешь произнести вслух — законное расследование, история общественного интереса, задокументированное

мошенничество, человек, которого ты пытаешься воссоединить с родственником, — и бери только то, что отвечает на этот вопрос. Удалённый профиль — более сильный сигнал приватности, чем закрытый, и заслуживает более сильного обоснования, прежде чем ты его обойдёшь.

Метод, шаг за шагом

Шаг 1 — Закрепи то, что уже знаешь. Запиши: настоящее имя цели в тех формах, в которых видел его написанным, последний ник, под которым ты её знал, лицо, если оно у тебя есть, город, работодатель, известный близкий, приблизительная дата, когда аккаунт погас. Это твой поисковый набор. Всё, что ниже, крутится вокруг него, и каждое совпадение, которое ты находишь, проверяется на нём. Сначала якорь, всегда.

Шаг 2 — Cache pass. Прежде чем что-то тяжёлое, прогони URL удалённого профиля через архивы — Wayback Machine, кэши поисковиков, малые зеркала, разобранные в Главе Первой. Это дешёвая проверка, которая иногда закрывает весь вопрос за десять секунд. Сделай и иди дальше; не проводи здесь весь день.

Шаг 3 — Обратный поиск по последней известной аватарке. Если можешь достать *любую* копию старой аватарки — тег у друга, закешированную карточку участника группы, снимок брокера с 2020, последнюю архивную

версию профиля — прогони обратный поиск по двум-трём движкам. Свежий аккаунт под другим именем с тем же лицом — один из самых частых паттернов «я удалил своё присутствие» в жизни: люди редко делают новое фото просто потому, что взяли новый ник.

Шаг 4 — Пройди по кольцу упоминаний. Поищи настоящее имя цели по открытому вебу, вычтя её платформу: "Ilse Vroeg" -site:facebook.com -site:instagram.com. Прочитай, что о ней писали другие — цитаты в прессе, посты в блогах, форумные треды, местные новости, протоколы сообществ. Если знаешь редкую фразу, которую она использовала в старом био, — поищи её в кавычках. Если у неё было редкое отчество или редкое место работы — включи их.

Попробуй (2026). Возьми человека, которого знаешь лично, который удалил соцаккаунт годы назад — и который спокойно относится к тому, что ты сделаешь это как упражнение. Проведи по нему только Шаг 4. В чистом браузере прогони его настоящее имя плюс город в кавычках с фильтрами -site: для тех платформ, откуда он ушёл. Прочитай первые две страницы результатов и выпиши каждое упоминание его на чьей-то *чужой* собственности: пост в блоге друга, школьная рассылка, результат забега, объявление о свадьбе, справочник палаты. Остановись там. Покажи ему список. Спроси, что он считал исчезнувшим и что удивило. Эта реакция — обычно тихое «ох» — весь

урок.

Шаг 5 — Списки на стороне групп. Цель, возможно, вышла из группы; *фото, которое она выложила* в общий альбом группы, и *комментарий, который она оставила* под чужим постом внутри группы, очень часто остаются.

Проверь каждую группу и страницу, которую можешь с ней связать: списки прошлых участников на страницах событий, «основатели» на страницах сообществ, треды комментариев к анонсам групп за годы её активности. Метаданные членства ведутся на стороне группы и чистятся неравномерно.

Шаг 6 — Карта 2-го круга. Возьми двух-трёх известных близких, чьи собственные связи по-прежнему публичны. Прочитай *их* списки связей вручную и отметь, кто повторяется. Кластер из пяти человек, все из которых, кажется, знают человека, у которого больше нет аккаунта, — и чьи комментарии под старыми постами обращаются к нему по имени, — сильная подпись реального кластера. Только ручное чтение. Никаких скриптов, никаких пересечений, никаких скрейперов. То, что один внимательный читатель может держать в голове, — ровно объём работы, который разрешают правила.

Шаг 7 — Чтение старых брокеров данных. People-search сайты и directory-зеркала часто хранят снапшот профиля задолго до удаления. Читай их, чтобы понять, что цель

раньше публично говорила о себе: био, работодатель, город, ассоциированные адреса, ассоциированные телефоны. Считай каждое поле лидом, а не фактом. Брокеры знамениты ошибками — не то отчество, не тот город, «известный близкий», который на самом деле незнакомец с той же фамилией, — и всё дело часто сшито из трёх людей со схожими именами. Совпадение у брокера даёт тебе гипотезу для проверки в другом месте. Оно не даёт вывода.

Шаг 8 — Ранжируй каждый фрагмент на лестнице. Разложи, что нашёл, взвесь и будь честен. Тег на свадебной фотографии — умеренный. Тег плюс запись брокера, называющая того же работодателя, плюс процитированное био на сайте палаты — сильный. Три брокера, эхом повторяющие друг друга, — один брокер: все они купили у одного оптовика. Взвешивай прежде, чем писать.

Разобранный кейс, с тупиками и всем

Региональная газета в маленьком европейском городе попросила помощи в истории про правление благотворительности, которое проголосовало за отставку своего казначея в публичной ссоре в середине 2022. Имена вымышленные, метод настоящий. Казначей, Ilse Vroeg, удалила свои Facebook и Instagram на той же неделе, когда голосование попало в местную газету. Вопрос репортёра был узким и разрешимым: до ссоры что Vroeg публично заявляла о своих профессиональных квалификациях? Конкретно — старое био описывало её как дипломированного бухгалтера или как финансового консультанта? Разница важна, потому что первое — регулируемый титул в её стране, а второе — нет.

Якорь. Полное имя, город, благотворительность, месяц удаления и один известный близкий — коллега по правлению, названная в газете. Известного фото пока нет. Записать.

Cache pass. У Wayback Machine был один снимок её страницы в Facebook, снятый в начале 2022. Открылся. Это была HTML-оболочка приватного вида — стена «вы должны войти, чтобы увидеть этот контент», захваченная в момент снимка. Нет био. Нет текста. Ничего.


```
Wayback lookup: facebook.com/ilse.vroeg
```

```
-----  
snapshots 1  
  2022-03-14  captured  
opening 2022-03-14 ...  
  HTML = platform login shell  
  bio   = not present in capture  
  posts = not present in capture  
-----  
snapshot exists, content does not
```

Снапшот стены — всё ещё стена.

Второй тупик. Она числилась членом публичной локальной бизнес-группы. Реестр членов группы всё ещё существовал на её собственной странице. Её строка была цела — но поле имени читалось как `user deleted`, а ссылка на профиль была мертва. Доказательство членства, без био.

Третий тупик. URL LinkedIn под её именем, закешированный в старом поисковом результате, редиректил 302 на «`profile not found`». Не снапшот, просто заглушка страницы, которая когда-то существовала.

Что реально сработало. Проход по кольцу упоминаний по её настоящему имени плюс городу, с вычтенными двумя платформами, выдал три полезные вещи.

Во-первых, региональный скрейпер бизнес-справочника — брокер, который пасётся на сайтах палат и перепубликуывает био — по-прежнему держал страницу с её именем и благотворительностью в заголовке, последнее

обновление 2021. Страница воспроизводила то, что казалось копией её старого «About» из Facebook, слово в слово, включая самоописание из двух предложений. Брокерские данные, так что я обошёл с ними как с лидом. Но я поискал точную фразу в кавычках по открытому вебу, чтобы посмотреть, появлялась ли формулировка где-то, где она писала сама.

```
Mention ring, quoted phrase
-----
QUERY  "financial consultant to
        several non-profits in"
        "Vroeg"
results  3
  1) business-directory scraper
      (broker copy, 2021)
  2) charity's own 2020 newsletter
      (PDF on their website)
  3) local blog "chamber notes"
      (2020 post, quoted her bio)
-----
same wording in three places, two
of them non-broker sources
```

Две независимые не-брокерские копии одной и той же формулировки.

Собственная рассылка благотворительности за 2020 — PDF, всё ещё лежащий на сайте благотворительности, — цитировала её био дословно в разделе «meet the board». Локальный блог, покрывающий события торговой палаты, цитировал тот же абзац в отчёте о событии 2020, приписывая его её представлению у трибуны. Оба

использовали фразу «financial consultant». Ни один не использовал фразу «chartered accountant». Копия брокера совпадала.

Во-вторых, фотоальбом на сайте палаты с ужина 2019, выложенный другим участником, отмечал её полным именем в подписи. Она была в напечатанном именном бейдже в переднем ряду. Лицо снято, имя снято, событие снято — всё на чужой собственности, всё ещё в сети.

В-третьих, старый блог, который вела коллега по правлению, содержал «прощальный» пост 2018, поздравлявший её со вступлением в должность казначея, описавший её прежнюю роль одной строкой: «*a consultant who has helped several of our sister charities*». Согласованно.

Куда это оставляет лестницу. Вопрос репортёра был узким: дипломированный бухгалтер или финансовый консультант? Два независимых не-брокерских источника — собственная рассылка благотворительности и локальный блог — цитировали одну и ту же формулировку, и копия брокера совпадала. Фото палаты подтвердило, что она та самая Ilse Vroeg, что и в благотворительности, на случай если кто-то попробует защиту «то же имя — другой человек». Сильный на конкретном заявлении. Я не пошёл искать, ради чего было удаление, потому что репортёр этого не спрашивал, а свадебные фото кухни её кухни не научили бы меня тому, что нужно в деле. Останавливайся, когда ответ приземлился.

Второй кейс: тот, что не закрывается

Другой запрос, недель позже. Лицо, вытащенное со скриншота, ник, заявление, что человек держал маленький вендорский аккаунт на маркетплейсе, закрывшемся в 2023. Аккаунт был удалён до анонса закрытия. Архивов нет. Отмеченных фото ни в одной сторонней ленте, до которой я мог дотянуться. Обратный поиск по лицу вернул не выше тонкого шума. Два правдоподобных кандидата на имя всплыли из зеркал брокеров — оба реальные люди, оба примерно нужного возраста, оба примерно в нужном регионе, — и ничто их не разделяло.

Я написал честно. *Не смог атрибутировать; вероятных кандидатов на имя: два, отличить нельзя; независимой нити, достаточно сильной, чтобы поднять любого, нет.* Клиент хотел имя. Доказательства не несли ни одного. Не закрыть дело — работа, а не провал; а неправильное имя, названное уверенно, — вред, который ты не заберёшь назад.

Безопасное упражнение

Сделай это на себе. Возьми свой собственный аккаунт, который ты удалил годы назад — старый MySpace, мёртвый ник ICQ, ушедший в небытие форумный профиль, ранний Twitter, который ты снёс в свои двадцать, блог на хосте, который прекратил существование. В чистом браузере прогони метод на себе: `cache pass`, кольцо упоминаний по своему имени плюс эпохе, поиск у брокеров, крошки 2-го круга от друзей, у кого списки ещё открыты. Посмотри, что выжило. Запиши, что удивило.

Ты найдёшь. Большинство находят. Затем реши, по пункту за раз, хочешь ли попробовать что-то снести — и оцени, что человек на другом конце твоих расследований чувствует то же самое, только наоборот.

Резюме

- Аккаунта нет. Человек — есть. То, что выжило, живёт на чужой собственности.
- Закрепи то, что знаешь, прежде чем смотреть — имя, лицо, город, близкий, дата удаления.
- Сначала `cache pass`, дёшево и иногда сразу выигрыш.
- Прогони обратный поиск по любой выжившей аватарке; свежий аккаунт под новым именем — самая частая самомиграция.

- Пройди по кольцу упоминаний в открытом вебе с вычтенными собственными платформами цели.
- Списки групп, страницы событий и треды комментариев ведутся на стороне группы и чистятся неравномерно.
- Снапшоты брокеров — лиды, не факты, а три брокера, эхом повторяющие друг друга, — один брокер.
- 2-й круг вручную, никогда скриптом; скрепленные списки друзей нарушают ToS и портят дело.
- Взвешивай всё на лестнице; две умеренные нити — не одна сильная.
- Имей называемую причину, прежде чем перестраивать удалённую личность, и бери только то, что нужно причине.

Глава Третья идёт от одного всплывшего фрагмента обратно к целой жизни — превращая одно удачное попадание в задокументированный, взвешенный профиль без чрезмерного прочтения того, что ты нашёл.



ГЛАВА ТРЕТЬЯ

Читаем фотографию для места

Каждый снимок, куда попадает мир снаружи, — координата, ждущая, чтобы её прочли.

Фотография падает тебе в почтовый ящик в 11:14 во вторник. Без подписи. Без метаданных в файле — отправитель сделал скриншот, дважды, из приложения, которое зачищает всё по пути. Что у тебя есть — угол балкона, пластиковый стул, полосатая чашка, полоска неба цвета слабого чая и диагональный край другого здания, наклоняющегося в кадр. Женщину где-то держат против её

воли. Её сестра прислала тебе снимок с бёрнера. Кто-то на другом конце телефона спрашивает, где она.

Ты не будешь угадывать. Угадывают те, у кого снимок кажется слишком маленьким, чтобы говорить. Этот снимок не маленький. Этот снимок громкий. Он громкий на языке, который большинство не читает, и вся дисциплина этой главы — научиться его читать: пройти кадр элемент за элементом и позволить каждому элементу выбросить места, где он быть не может. Правильное настроение для работы — *сужение*. Не поиск. Сужение. Ты начинаешь со всей земли и вычитаешь.

Идея: сужай, не угадывай

Геолокация по фотографии — не удачная догадка и не фокус. Это контролируемое сужение. Каждый элемент, который ты можешь прочесть в кадре, либо *исключает* многие места на земле, либо *концентрирует* внимание на нескольких. Дорожная разметка исключает половину континентов. Номер на припаркованном скутере исключает половину того, что осталось. Цветущее дерево исключает половину того. Сделай так десять раз, терпеливо, и земля схлопывается до района. Сделай ещё два раза — до квартала.

Единственная формулировка, которую ты должен уметь произнести обратно одним предложением: каждый видимый элемент либо исключает места, либо

концентрируется на них; работа — снимать исключения, пока не останется маленький набор. Всё, что ниже, — техника на службе этого предложения.

Что фотография на самом деле тебе говорит

Прежде чем брать любой инструмент, надо знать, на что тымотришь. Тренированный глаз читает фото так, как механик слушает двигатель — как стопку независимых сигналов, каждый из которых сужает поле.

- Тени и солнце. Тень указывает от солнца. Её длина относительно объекта, отбрасывающего её, ограничивает высоту солнца, что ограничивает время суток для данной даты и широты. В Северном полушарии выше тропика Рака солнце в полдень стоит на юге; в Южном полушарии ниже тропика Козерога — на севере; между тропиками полуденное солнце может стоять и там, и там в зависимости от сезона, и эта неоднозначность сама по себе — сигнал. Одна чёткая тень даёт полушарие и, с правильной астрономией, полосу широты.
- Профиль рельефа. Дальние пики, плоский горизонт, линия побережья, то, как холм поднимается за крышами — рельеф упрямо локален. Зубчатая снеговая линия, видимая над многоэтажками, исключает большую часть планеты. Мёртво-плоский горизонт исключает остальное.
- Дорожная разметка и ширина полос. Цвет краски, паттерн штрихов, отношение штриха к пропуску, ширина

полосы, цвет бордюра — всё варьируется по стране, а часто и по десятилетию перекладки. Жёлтые центральные полосы значат один набор мест; белые — другой.

Ярко-белые пунктирные краевые линии с шевронной обочиной говорят тебе про конкретный набор ПДД.

- **Указатели.** Знак «стоп» — восьмигранник почти везде, но слово на нём, вес рамки, светоотражающая подложка и крепёж отличаются. Регулирующие знаки конкретным шрифтом с конкретным ограниченным алфавитом сузят до региона внутри страны за секунды.

- **Автомобильные номера.** Цвет фона, соотношение сторон, набор символов, есть ли синяя боковая полоска в стиле ЕС, номер в одну строку или в две, есть ли префикс штата или области. Номера — самый плотный на пиксель сигнал геолокации в большинстве уличных фото.

- **Автомобили и ориентация.** Модель машины говорит, на какие рынки она продавалась. Но громче всего — с какой стороны сидит руль. Правый руль схлопывает мир до конкретного набора стран. Леворульная машина в праворульной стране почти всегда значит, что она была ввезена по очень конкретной причине — и это тоже сигнал.

- **Линии электропередач, столбы, фонари.** Удивительно региональны. Деревянные против бетонных столбов. Цвет и форма изоляторов. Несёт ли столб три фазы или одну. Уличные фонари — от небольшого числа

производителей, чьи региональные контракты стабильны десятилетиями.

- **Флора и сезон.** Жакаранда в фиолетовом цветении задаёт климатическую зону и месяц. Оливковая роща исключает большую часть Северного полушария. Клёны в осеннем цвете сужают календарь до недель. Даже виды газонной травы читаются регионально для тренированного глаза.

- **Архитектура.** Уклон крыши отслеживает снеговую нагрузку (крутая — для тяжёлого снега, пологая — если снега нет). Балконы читаются локально — иберийская плитка, французский кованый металл, советские бетонные консоли, экраны затенения Персидского залива. Смотри именно на то, где установлены блоки кондиционеров — решётка на стене под окном, компрессор на крыше, коробка сплит-системы на специально сделанной полочке: каждая — региональная привычка.

- **Фрагменты письма и языка.** Двухбуквенное сокращение на почтовом ящике, кусочек грифельной доски, вывеска магазина у края кадра, стикер на фонарном столбе. Даже одно слово в характерном алфавите сужает сильнее, чем сотня общих улик.

- **Остатки EXIF.** Если файл выжил с метаданными, читай их *последними*. Марка камеры, метка времени и GPS могут присутствовать, отсутствовать, быть вычищенными

или подделанными. Считай любое число заявлением, которое надо проверить против всего остального в кадре — никогда как факт, перебивающий то, что видят твои глаза.

Читай снимок в три прохода

Дисциплина — три прохода, и если пропустишь первый, ты сместишь себя так, что никакие инструменты не восстановят дело.

Первый проход — голым глазом, без инструментов. Открой снимок на весь экран. Не открывая браузерную вкладку. Никуда его не загружай. Запиши, простым списком, каждый элемент, который видишь. «Синяя плитка, шестиугольный паттерн. Пластиковый стул, белый. Фрагмент грифельной доски, левый край. Тент через улицу, красно-белые вертикальные полосы. Воздушный кабель, один провод, деревянный столб с изолятором сверху.» Список скучен. Скучный — и есть суть. Ты собираешь инвентарь до того, как формируешь теорию.

Второй проход — сортируй по исключению. Для каждого элемента спроси, что он *исключает*. Воздушный однопроводной кабель на деревянных столбах исключает большую часть новых городских районов Западной Европы. Фрагмент грифельной доски в чём-то похожем на латиницу исключает большую часть Азии. Пластиковый стул не

исключает ничего — напиши «нет сигнала» рядом и перестань на него смотреть. Ты ещё ничего не пытаешься опознать. Ты сжимаешь карту.

Третий проход — выбирай рычаги. Теперь вытащи два-три элемента с самым сильным сигналом — те, что схлопнули бы огромную площадь, если бы ты их искал. Ищи *их*, а не всю фотографию. Вся фотография — плохой запрос. Тесно кадрированный кусок конкретного почерка на доске, конкретной полоски тента, конкретного номера на скутере — каждый из них хороший запрос. Здесь ты наконец тянешься к браузеру.

Метод, шаг за шагом

Шаг 1 — Залогируй снимок. Отметь источник, человека, который прислал, и любое заявление о времени снимка, которое он сделал («она прислала это во вторник утром»). Заявление — заявление; тень в кадре — свидетель. Позже, возможно, придётся их согласовывать.

Шаг 2 — Прочитай кадр голым глазом. Напиши инвентарь. Сопrotивляйся обратному поиску по картинке — запуск сейчас заменит твоё свежее чтение тем, что случайно лежит в индексе движка, и следующий час ты будешь гоняться за хитами, которые тебе не нужны.

Шаг 3 — Проход по континенту и полушарию. Только по тени, растительности и фрагментам письма помести снимок

на половину планеты. Солнце на северной стене в полдень ставит тебя южнее экватора. Кроп фрагмента доски даёт семейство письменности. Листопадная листва в листе в декабре ставит тебя южнее экватора или в узкую тропическую полосу. Сделай это до того, как трогать страну.

Шаг 4 — Проход по стране. Теперь формат номера, дорожная разметка, сторона движения в кадре, шрифт указателей и фрагменты языка. Перекрёстно проверь как минимум по трём независимым осям, прежде чем называть страну. Если номер говорит одну страну, а дорожная краска — другую, у тебя приграничный городок, импортированное авто или ошибка — ничего из этого не решается выбором любимого ответа.

Попробуй (2026). Возьми публичное новостное фото из страны, которую плохо знаешь — уличный снимок агентства с закрытой подписью. Работай только по стране из кадра: номера, разметка, указатели, один фрагмент письма. Запиши ответ, потом открой подпись. Сделай так десять раз — почувствуешь, как растёт мышца исключения. Делай раз в неделю — не усохнет.

Шаг 5 — Проход по региону. Со страной в руке сужай до региона. Рельеф (горы, море, равнина, дельта). Архитектура (северная крутая крыша против южной плоской).

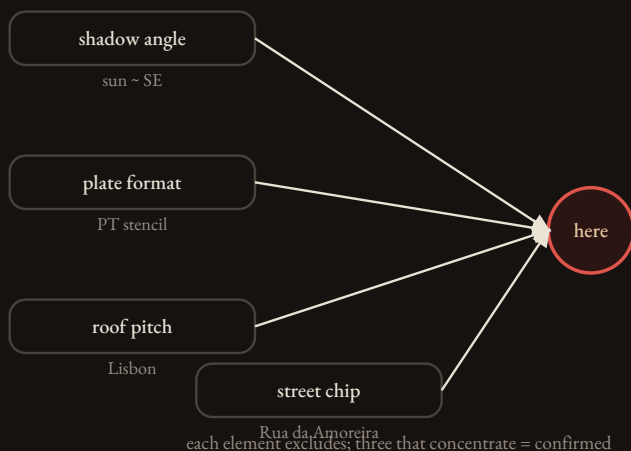
Растительность (средиземноморская против альпийской против степной). Второй язык на вывесках, если в стране есть региональные языки. Региональные сети — логотип супермаркета, который читаешь, аптечный крест конкретного цвета, топливный бренд, торгующий только в одной части страны.

Шаг 6 — Обратный поиск теперь, с целевым кропом.

Обратный поиск по всему кадру — приём новичка, и почти всегда возвращает бесполезное. Обрежь до одного самого характерного элемента — конкретной вывески, уникального куска архитектурной отделки, мурала, номерного люка — и прогони обратный поиск *этого*. Пробуй больше одного движка; их индексы резко расходятся. Обратный поиск — lookup, а не открытие: ты спрашиваешь «этот именно объект уже сфотографирован и проиндексирован где-то?», а не «что это».

Шаг 7 — Прогулка по street view. Как только у тебя есть кандидат-улица или район, пройди по нему в спутнике и в уличных снимках. Ты сопоставляешь углы, а не вайб. Конкретный угол, под которым здание соседа врезается в твой кадр. Краска на перилах балкона. Паттерн плитки пола. Конкретное дерево — вид, высота, положение относительно угла.

GEO-TRIANGULATION



Три независимые оси пересекаются на одном балконе: точный угол линии крыши соседа, положение единственной цветущей жакаранды во дворе и характерная коробка кондиционера, установленная над конкретным окном. Любая одна ось совпадает со многими местами. Все три, совпадающие одновременно, совпадают с одним.

Шаг 8 — Подтверждай на независимых осях.

Кандидат-локация *подтверждена* только когда сходятся как минимум две — лучше три — независимые оси. Силуэт здания плюс дерево во дворе плюс кондиционер соседа. Не «балкон выглядит правильно, и у меня чувство». Ранжируй результат на лестнице честно: правдоподобный район — слабый, совпадающая улица — умеренный, три независимые оси на одном здании — сильный, а *подтверждено* — ступень выше того — оставлено случаю,

когда независимый источник (подпись на другом фото того же балкона, объявление о недвижимости, сам субъект) замыкает петлю.

Разобранный кейс, с тупиками и всем

Журналист пересылает тебе снимок. Балкон маленького кафе. Синие-белые шестиконечные плитки на полу. Один белый пластиковый стул. Полосатая чашка — красно-белая. Половина грифельной доски видна у левого края, верхнее слово обрезано, потом во фрагменте мелового курсива: *...e
ita cerveja*. Через улицу, у правого края, угол тента — красно-белые вертикальные полосы. Один скутер припаркован внизу, его задний номер наполовину виден. Вопрос: где.

Проход голым глазом. Ты записываешь. Синяя плитка, геометрическая. Белый пластиковый стул, обычный. Грифельная доска, латиница, курсивный почерк. Фрагмент читается «и пиво» на португальском или чём-то близком. Тент, красно-белые полосы, глянцевый. Скутер, номер вырубленный трафаретом — белые символы на светлом фоне. Сверху: проводов не видно, городская застройка. Небо: дымчатое, тёплое, позднее утро по углу тени. Тень на полу балкона: короткая, лежит в сторону южной стены, значит солнце где-то на севере — ты дважды перепроверяешь, потому что южно-обращённое солнце поставило бы тебя в Южное полушарие, а ты не хочешь

опираться на неправильное полушарие следующий час.

Первый тупик. По привычке ты бросаешь весь кадр в движок обратного поиска.

```
Query: cafe_balcony_full.jpg
-----
Top matches (3 engines pooled):
- "Blue tile terrace, Lisbon"          weak
- "Riad rooftop, Marrakesh"          weak
- "Salvador da Bahia colonial house"  weak
- "Andalusia, azulejo balcony"       weak
- 40+ stock images, blue tile floors  noise
-----
No exact match. All near-matches
scatter across four countries.
```

reverse-image search — full frame

Бесполезно. Синяя плитка — это синяя плитка; у движка тысячи таких, проиндексированных с сайтов риелторов, тревел-блогов и Airbnb-объявлений. Ты закрываешь вкладку.

Второй тупик. Ты обрезаешь красно-белый тент и ищешь его.

```
Query: awning_stripe_crop.jpg
-----
Chain-café brand matched:
- franchise operates in PT, BR,
  ES, MZ, AO — five countries.
- Roughly 1,400 outlets total.
-----
Signal: cafe brand family.
Location: any of five countries.
```

reverse-image search — awning crop

Лучше — сигнал — но всё ещё пять стран. Тент сужает до *сети*, а сеть торгует на каждом португалоязычном рынке плюс в Испании. Ты сохраняешь имя сети и идёшь дальше.

Чтение языка. Фрагмент на доске, *e ita serveja*, — португальский, не испанский. Испания отпадает. Ты дошёл до Португалии, Бразилии, Мозамбика, Анголы — четыре страны.

Третий тупик. Ты преждевременно фиксируешься на Португалии, потому что лучше всех знаешь Лиссабон. Ты ищешь «azulejo balcony blue geometric» и начинаешь ходить по улицам Лиссабона в спутнике. Через полчаса замечаешь, что не так: конкретный шестиугольный паттерн плитки в кадре в Лиссабоне необычен — на большинстве балконов Лиссабона квадратная azulejo. Твои кандидатские крыши в Алфаме не совпадают. Ты откатываешься и перестаёшь опираться на любимый город.

Четвёртый тупик. Ты пивотишь в Бразилию, потому что паттерн плитки ближе к тому, что ты видел в Сальвадоре. Но профиль ЛЭП в кадре — точнее, *отсутствие* конкретной бразильской захламлённости воздушными кабелями — не совпадает с бразильскими городскими улицами, у которых почти всегда каша воздушных кабелей, режущих небо. Твой кадр имеет чистое небо. Бразилия отпадает, или как минимум понижается.

Пивот. Ты возвращаешься к номеру скутера. Трафарет однозначен, когда увеличиваешь: белые символы на светлом фоне, конкретный португальский национальный формат, с маленькой боковой полоской цвета, который использует Португалия, а лузофонные страны Африки — нет. Ангола и Мозамбик понижаются. Ты обратно в Португалии, но не в Лиссабоне.

Ты снова смотришь на архитектуру: уклон крыши, видимый на соседнем здании, пологий, но не плоский. Кондиционер над окном соседа установлен на маленьком настенном кронштейне в стиле, который на твой глаз читается скорее как Порту, чем Лиссабон, но ты не доверяешь этому наитию и идёшь искать три референсных фото обоих городов, чтобы проверить. Стиль кронштейна распространён в агломерации Порту, менее — в Лиссабоне. Слабый сигнал, но согласуется с паттерном плитки.

Целевой обратный поиск, попытка вторая. Ты кропишь тент сети *плюс* полосу здания над ним — на здании есть маленькая, едва видимая плитка-номер дома в стиле *azulejo*, номер частично читается. Этот кроп теперь — конкретный запрос.

Candidate: Porto district, café
chain outlet register lists
four Porto-area outlets on
small residential streets.

Walking each in street imagery:

- Rua A: awning wrong colour
- Rua B: awning right, but
balcony opposite is glass
- Rua C: no awning visible
- Rua D (Rua da Amoreira, 21-23):
awning stripes match,
balcony opposite matches
tile pattern, house-number
tile matches, jacaranda in
courtyard matches the tree
visible at the frame edge.

Four independent axes align on
Rua da Amoreira, 21-23. Confirm.

street-view scan for Rua da Amoreira

Четыре оси: полоса тента, паттерн плитки, плитка с номером дома, дерево во дворе. Это сильный на лестнице. Остаётся на сильном, а не подтверждено — каждая ось выводная, и публичный реестр торговых точек сети кафе, называющий ту же улицу, подкрепляет вывод, но не даёт жёсткой уникальной самоссылки (никто на снимке не заявляет адрес; ни один первичный документ его не называет). Подтверждено — ступень, к которой ты приходишь через уникальный идентификатор или через заявление первого лица, а не через складывание независимых умозаключений, как бы чисто они ни согласовывались. Ты пишешь это с цепочкой рассуждений, включая каждый

тупик выше, чтобы человек, читающий отчёт, видел не только куда ты пришёл, но и почему более ранние кандидаты были отвергнуты — и как должен был бы выглядеть *подтверждённый* сигнал.

Второй кейс: тот, что не закрывается

Другой день, другой снимок: крупный план заснеженного соснового ствола, полоска серого неба и один отпечаток ботинка. Никаких сооружений. Никаких указателей. Никакого письма. Каждая ось сужает одинаково — Северное полушарие, хвойный лес, зима, вероятно бореальная зона. Ты изучаешь текстуру коры, паттерн опавшей хвои, точную ширину отпечатка ботинка, конкретную зернистость снега. Ничто не отделяет два региона-кандидата друг от друга: Карелия на северо-западе России и восточный Квебек оба подходят по каждой оси, что ты можешь прочесть. Ты не можешь ранжировать один выше другого по имеющимся уликам. Так что ты чисто это и сообщаем: два региона-кандидата, сопоставимая вероятность, вот оси, которые я прочёл, и вот оси, которых у меня нет. Беспорядок — это работа. Геолокатор, который никогда не возвращает вердикт «не могу разделить», — геолокатор, который угадывает.

Об этике помещения людей на карты

Геолокация — это координаты, а координаты — сила. В контексте домашнего насилия, в деле о stalkingе, на войне предложение «я знаю, где ты снял это» — оружие, иногда во благо, иногда нет. Имей законный вопрос, прежде чем начинать; публикуй только то, что твоему вопросу реально нужно; и никогда не публикуй точные координаты частного дома, если общественный интерес не бесспорен, а цель — не публичный актер в своей публичной функции. «Фото из Порту» часто — весь ответ, который нужен внешнему миру. Квартал, улица, номер — для тебя и клиента, не для эфира.

Безопасное упражнение

Возьми публичное новостное фото с протеста или митинга, где ты не был и быть не мог. Закрой подпись. Работай геолокацию только из кадра — страна, регион, улица если дойдёшь. Сравни ответ с подписью, когда закончишь. Это законно, никому не вредит, тренирует каждую мышцу этой главы и учит тому, как реально выглядят твои честные погрешности.

Резюме

- Геолокация — это сужение, не угадывание. Каждый видимый элемент либо исключает места, либо концентрируется на них; продолжай снимать исключения.

- Читай кадр в три прохода: инвентарь голым глазом, сортировка по исключению, потом целевой поиск двух-трёх элементов с самым сильным сигналом.
- Учи грамматику кадра: тени, рельеф, дорожная краска, указатели, номера, сторона руля, столбы, флора, архитектура, письмо, EXIF-последним.
- Делай сужение континент-страна-регион, прежде чем что-либо реверснуть по картинке.
- Обратный поиск с кропом, никогда всем кадром; используй несколько движков, потому что их индексы расходятся.
- Проходи уличные снимки за углами, не вайбом — сопоставляй углы, отделку, конкретные деревья, конкретные кондиционеры.
- Подтверждай на независимых осях. Одна ось — предчувствие, две оси — кандидат, три оси — сильный. Всё, что называется «подтверждено», требует источника вне самого снимка.
- Отчитывайся о тупиках, а не только об ответе. Геолокация без своих отбрасываний — не геолокация, а заявление.
- Публикуй только то, что нужно вопросу. Района обычно достаточно для мира; номер двери — для файла.

Глава 4 обращается к той же фотографии и задаёт другой вопрос: *когда*.



ГЛАВА ЧЕТВЁРТАЯ

Читаем фотографию для времени

Солнце и сезоны — два самых честных часа в любом снимке.

Клиент вернулся на следующее утро с более коротким вопросом. Мы поместили кафе в Главе Третьей — балкон на Rua da Amoreira в Порту, плиточный фасад через улицу, трамвайные провода, доводящие кадр. Это ответило на *где*. Но *где* никогда не было настоящим вопросом. Настоящий вопрос — *когда*. Фотография была прислана без подписи, и человек в кадре отрицал, что был на том балконе в месяце, в котором клиент считал, что снимок сделан. Так что — тот

же снимок, то же рассуждение, другая колонка информации. Мы уже прочитали снимок для места. Теперь прочтём его для времени.

Геолокация и хронология — сёстры-дисциплины. Они ездят по одному циклу — наблюдай, гипотезируй, проверяй, держи — и лезут по одной лестнице от *непроверенного* через *правдоподобный, поддержанный, сильный* до *подтверждено*.

Но они читают разные якоря. Где геолокация живёт в паттернах плитки, бордюрных камнях и геометрии горизонта, хронология живёт в солнечном свете, листве, погоде и мелком датированном мусоре, который человеческая жизнь оставляет в кадре. Настенный календарь. Край плаката. Телефон в руке.

Идея: снимок — это часы

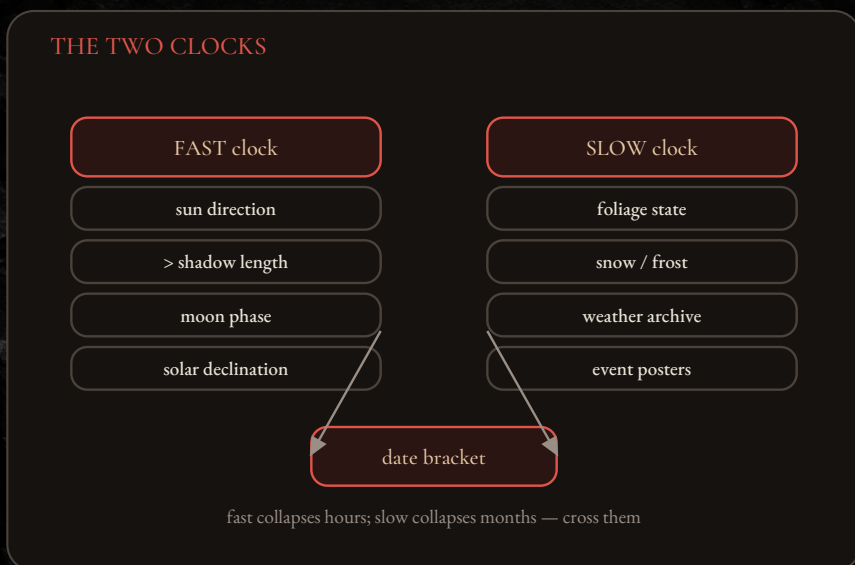
Каждая уличная фотография несёт двое часов, и оба тикают честно, если знаешь, как их читать.

Быстрые часы — астрономические. Положение солнца зависит от широты, долготы и момента. В любой заданный день в любом заданном месте солнце всходит с конкретного азимута, поднимается до конкретной максимальной высоты и отбрасывает тени конкретной длины и направления. Луна крутит свой цикл — фаза, восход, заход — и когда она попадает в кадр, она даёт бесплатно несколько дней в интервале. Видимое частичное затмение, если однажды

повезёт, — одна дата.

Медленные часы — фенологические и сезонные. Деревья голые, в почках, в полной листве, в сенесценции или сброшены. Поля вспаханы, посеяны, растут, убраны или стернь. Снег присутствует, отсутствует, свежий или старый. Эти сигналы движутся медленно, но в одном направлении по году, и в комбинации с широтой сужают снимок до месяца-двух календаря.

Фотография, показывающая оба часа — тень *и* лист, угол *и* снеговую линию — очень быстро схлопывает ответ.



Быстрые часы наверху кадра, медленные внизу, а датированный человеческий мусор — плакаты, телефоны, машины — идёт по середине.

Что снимок реально тебе говорит о времени

- **Направление солнца и длина тени.** Направление тени по компасу говорит азимут солнца. Отношение длины тени к высоте объекта говорит высоту солнца. Вместе, на известной широте и долготе, они схлопываются до маленького набора кандидатов дата-время.
- **Состояние листвы.** Голые ветки, распускание почек, полная крона, осенний цвет, опавшие листья. В умеренной зоне это одно сужает тебя до нескольких недель. Отметим, листопадное ли дерево — вечнозелёные ничего не говорят о сезоне.
- **Снеговой покров.** Присутствие, отсутствие, свежесть (чёткие края против растаявшей корки), глубина относительно известного репера типа бордюра. Свежий снег после тёплой полосы значит снегопад за последний день-два.
- **Сельскохозяйственная стадия.** Вспаханная коричневая, зелёные всходы, высокая стоящая пшеница, скошенная и в валках, стернь с соломенными тюками, снова вспаханная коричневая. Каждая стадия — конкретное окно в местном сельхозкалендаре.
- **Погода в кадре.** Тип облаков — высокие перистые против низких слоистых против растущих кучевых. Земля ещё мокрая от дождя. Иней на крышах в утреннем свете. Конденсат на окнах, который образуется только когда

воздух снаружи очень холодный.

- **Рукотворные календарные сигналы.** Настенный календарь на офисной стене за кем-то. Меловая доска магазина «6 дней до Рождества». Футбольный матч на баровом TV с читаемым счётом и командами. Сезонная промо-акция пивоварни.
- **Датирование по моде и технике.** Форма iPhone в руке — у каждого поколения свой характерный камерный бугор. Модель или фейслифт машины на улице. Конкретная стритвир-коллаборация с задокументированной датой релиза.
- **Сигналы на стороне платформы.** Формулировка приложения «posted 2h ago» — строка, которая уплывает во «вчера», а потом в «3 июня» за дни. Скриншот раньше, чем сменится. Время снимка в Wayback Machine страницы, на которой лежит изображение, — жёсткий верхний предел: изображение существовало к этой дате.
- **Астрономические экстра.** Видимая в кадре фаза Луны даёт интервал в несколько дней в лунном цикле. Редкие события — солнечное затмение, яркая комета на известную дату, пик метеорного потока — привязывают к одной ночи.
- **Инверсионные следы и самолёты.** Видимый самолёт или свежий инверсионный след с характерной формой можно проверить по истории отслеживания полётов для

этого региона на дни-кандидаты. Конкретные трекерные сайты, доступные сегодня, могут не существовать через пять лет; относись к технике как к долговечной, а к инструменту — как к расходнику.

Двое часов, работающих вместе

Двое часов важны потому, что каждые из них по отдельности неоднозначны. Положение солнца 15 июня в 14:00 на 41°N почти идентично его положению 27 июня в 13:50. Хронолокация только по тени почти всегда оставляет тебя с двумя окнами-кандидатами, иногда одно весной и одно осенью, симметрично вокруг солнцестояния.

Медленные часы схлопывают эту неоднозначность. Полная крона на дереве в кадре исключает мартовское зеркало сентябрьской даты. Снег на земле исключает июньское зеркало декабрьской. Мокрый асфальт в день, который погодный архив показывает сухим, исключает сам день.

Ты почти никогда не получишь хронолокацию с одних часов. Ты получишь её, заставив двое часов согласоваться.

Метод, шаг за шагом

Шаг 1 — Заморозь провенанс. Сохрани изображение с именем файла и URL. Сделай скриншот *страницы*, на которой оно лежит, включая лейбл «posted N hours ago». Этот лейбл — текстовая строка, а не data point, и он изменится за ночь. Отметь историю захватов в Wayback Machine страницы-носителя — самый ранний захват, содержащий изображение, — жёсткий верхний предел даты.

Шаг 2 — Прочитай кадр голым глазом на подсказки медленных часов. Прежде чем открыть любой инструмент, смотри. Листва? Снег? Стоящие посевы? Луги? Тени чёткие или размытые? Запиши, что видишь, словами, в свои заметки. Это заставляет тебя замечать вещи, которые ты бы иначе проскочил, когда уже на полпути к гипотезе.

Шаг 3 — Прочитай кадр на подсказки быстрых часов. Куда указывает тень? Насколько она длинная относительно того, что её отбрасывает? Видна ли луна? Есть ли хоть какая-то видимая небесная референция? Отмечай направления в компасных терминах в первую очередь — «тень указывает примерно на северо-северо-восток» — потому что именно это солнечный калькулятор скажет тебе в ответ.

Шаг 4 — Перекрёстная проверка погоды. Если Глава Третья дала тебе локацию, вытяни местный погодный архив

на дни-кандидаты. Дождь в кадре плюс сухой день-кандидат исключает тот день. Ясное небо в кадре плюс день-кандидат, зафиксированный как полностью пасмурный, тоже его исключает.

Попробуй (2026). По любому городу публичный погодный архив даст тебе почасовое облачное покрытие, температуру и осадки за годы. Возьми своё фото с известной даты, посмотри архив на тот час и проверь, совпадает ли запись с тем, что показывает фото. Если нет — ты узнал что-то о размещении твоей местной станции; полезная калибровка.

Шаг 5 — Листва и фенология. Даты распускания почек для вида на заданной широте варьируются от года к году, но публично доступные фенологические записи дают интервал. Листопадное дерево умеренной зоны в свежей светло-зелёной листве, чёткие края, без пыли — двухнедельное окно весной. Полная крона, приглашенная летней пылью, — гораздо более широкое окно, июнь-август.

Шаг 6 — Календарные и содержательные сигналы. Футбольный матч на TV в пабе с читаемым счётом — жёсткий якорь к одному вечеру. Оконный стикер «Merry Christmas», ещё не выветренный, задаёт декабрь. Концертный плакат с читаемой датой — золото. Читай кадр

на датированный мусор обычной жизни.

Шаг 7 — Датирование по технике. Телефон или машина, выпущенные в мае 2023, исключают всё до мая 2023. Это пол, не потолок — тот же телефон существует и сегодня. Комбинируй со всем остальным.

Шаг 8 — Ранжируй на лестнице. Хронолокация с точностью до одного дня редка и почти всегда требует астрономического якоря или датированного события в кадре. Интервал в несколько дней — хороший результат. Интервал в месяц — часто честный. Говори честный ответ. Клиент лучше получит *последнюю неделю мая 2025, сильный*, чем *17 мая 2025, надемся*.

Разобранный кейс, с тупиками и всем

Возвращаемся на балкон на Rua da Amoreira, в Порту. Клиент считал, что фото — с августа. Фотограф говорил — нет. Снимок был очищен от EXIF тем мессенджером, через который он пришёл — сайты обратного поиска не вернули более ранних копий, и файл был чист.

Первый тупик. Нет метаданных. Нет более ранней загрузки. Из самого файла поднять нечего.

Второй тупик. Направление солнца, прочитанное голым глазом с тени фонарного столба, видимой на тротуаре под балконом, указывало примерно на северо-северо-запад.

Перепроверено против формы положения солнца — для широты Лиссабона такое направление тени соответствует утреннему окну весной или летом. То же направление тени появляется в полосе апрель-май и зеркальной полосе июль-август. Так что августовская гипотеза клиента была совместима с солнцем. Как и «не август» фотографа. Быстрые часы ничего не делали.

Третий тупик. Листва в кадре была горшечным лимонным деревом на балконе. Вечнозелёное. Молчит. Одно уличное дерево, видимое у края кадра, было платаном, но обрезано так плотно, что видно было только полоску листа, не хватало сказать, полная ли крона или ранний распуск.

Четвёртый тупик. Погодная перекрёстная проверка на предложенную клиентом дату — конкретный день в августе — показала запись архива Порту с тяжёлыми растущими кучевыми и грозой в 16:00. Фотография показывала плоское, высокое, дымчатое небо и сухой асфальт. Тот день исключён.

day/hour	cover	temp	precip
14 / 15	OVC	28C	0.0
14 / 16	OVC	27C	4.2 mm
14 / 17	BKN	24C	1.1 mm

weather archive readout — Porto

Затем снимок начал сдаваться.

Вдоль стены кафе через улицу, у левого края кадра, маленький бумажный плакат был наклеен поверх более

старого. Верхний слой был в основном нечитаемым, но две строки читались при увеличении: название фестиваля и слова *5–7 Junbo*. Собственный сайт фестиваля подтвердил, что он проходил в тот уикенд в один конкретный год. Тот год плюс окно утренней тени, совместимое с ранним июнем на той широте, было двухдневным интервалом.

Full canopy typically established by late May. On 5–7 June: full leaf, dust not yet accumulated. Frame edge shows this exact state – consistent, not distinctive.

phenology bracket — Porto plane tree

Фенология платана у края была совместима с июньским интервалом — полная листва, всё ещё свежая — но сама по себе не отделила бы июнь от конца мая или начала июля. Это подкрепление, не якорь.

Собственная рука фотографа была видна внизу кадра, держащая телефон. Камерный бугор был характерной раскладкой модели, выпущенной в мае того же года. Это исключало те же даты в любом более раннем году — так что фестиваль плакат, который повторялся ежегодно, теперь указывал на один конкретный уикенд.

Окончательный ответ: *утро либо 5, либо 6, либо 7 июня, того года, сильный*. Не подтверждено — мы не сняли часы в кадре — но сильный: два независимых якоря (плакат, модель телефона) плюс два согласующихся чтения (солнце, листва),

без противоречий. Клиент просил месяц и ожидал, что ему скажут какой. Он получил уикенд.

Хронолокация видео

Видео — это фотография, которая идёт. Оно добавляет непрерывность, а непрерывность даёт больше якорей.

Часовой угол солнца меняется примерно на пятнадцать градусов в час — это чистая астрономическая константа. Видимый азимут (компасное направление) движется совсем с другой скоростью: около местного полудня летом на высоких широтах он может пройти десятки градусов за минуты, а при низких углах солнца зимой азимут почти не движется. Что именно показывает твоё видео, зависит от геометрии комнаты — тень на стене обычно читает азимут; пятно света, ползущее по полу ближе к полудню, читает смесь. Сделай арифметику для конкретной даты, широты и часа, прежде чем зафиксироваться на «один градус в пять минут». Пятно солнечного света измеримо движется в клипе, длительность которого — малая доля часа; точную скорость надо проверить, а не предположить. Тени от облаков движутся в ту же сторону, что ветер на высоте нижней кромки облаков, со скоростями, которые фиксирует местный погодный архив. Клип, в котором тень пересекает сад за восемь секунд на известной дистанции, можно перекрёстно проверить против скорости ветра на той высоте для часов-кандидатов.

Инверсионные следы — друг видео-хронолокатора. Пара пересекающихся свежих инверсионных следов, в известном направлении по компасу, в известный момент клипа, может быть перекрёстно проверена по истории отслеживания полётов для этого региона на дни-кандидаты. Конкретный сервис, который ты используешь для архива, может не существовать через пять лет, так что относиться к технике как к долговечной, а к инструменту — как к расходнику. Рассуждение — то, что переносится вперёд.

Второй кейс: тот, что не закрывается

Студийный портрет, в помещении. Ни окна. Ни настенных часов. Ни телефона в кадре. Субъект в простой чёрной футболке, обычных тёмных брюках, простом серебряном кольце — ничего, что несло бы сезон или год. Стена сзади покрашена средне-серым, без плакатов, календаря, детали модели выключателя. Свет — софтбокс — мог быть выставлен в любой день любого года.

Самый ранний захват страницы-носителя в Wayback Machine — январь 2023, так что фотография существовала к тому времени. Ничто в кадре не сужает дальше. Лучший честный ответ — *между датой самой ранней сетевой копии и сегодня, не проверено сверх этого*. Отчитано: *где-то за последние три года, не проверено*. Не каждый вопрос закрывается, и прикидываться иначе хуже, чем это сказать.

Об этике помещения людей на таймлайн

Хронолокация фотографии человека несёт конкретный смысл: *ты был в этом месте в этот день*. В комбинации с геолокацией это картирует срез жизни. Это законный инструмент для публичной подотчётности публичных акторов, для репортёров, проверяющих заявление, для страховых следователей, смотрящих на мошенничество. Это не инструмент для построения дневного ритма перемещений частного лица.

Та же дисциплина, что применима к геолокации, применима здесь — законный вопрос, минимальное раскрытие, никакой публикации чего-либо, что скомпрометировало бы безопасность того, кто не публичный актор. Уикенд-интервал по отрицаемому появлению публичной фигуры — журналистика. Уикенд-интервал по воскресным прогулкам бывшего партнёра — сталкинг. Прочитай свой кадр, прежде чем читать их.

Безопасное упражнение

Возьми три своих старых фото, где ты знаешь точную дату. Сними метаданные. Спрячь дату от себя — напиши её на карточке и положи карточку в ящик. Потом работай их хронологически с нуля: прочитай медленные часы, прочитай быстрые часы, вытяни погодные архивы и запиши интервал. Открой ящик только после того, как напишешь. Это самый быстрый способ откалибровать, насколько плотный интервал ты можешь честно заявить, и где твоё чтение тебя обманывает.

Резюме

- Каждый уличный снимок несёт двое часов: быстрые астрономические и медленные фенологические.
- Ни одни часы по отдельности обычно не хватает. Заставь их согласоваться.
- Сначала заморозь провенанс — метки времени, URL страницы, строки «N hours ago» — прежде чем они уплывут.
- Погодные архивы — самый дешёвый инструмент исключения, что у тебя есть.
- Датированный мусор в кадре — плакаты, телефоны, настенные календари, счета матчей — то, что толкает интервал с месяца до недели до дня.

- Ответ с точностью до дня редок и требует события или астрономического якоря. Интервал — обычный честный результат.
- Видео добавляет непрерывность: движение солнечного света, дрейф облаков, инверсионные следы против историй полётов.
- Хронолокация жизни частного лица — граница. Спроси зачем, прежде чем спрашивать когда.

В следующей главе мы уходим из мира кадров и заходим в мир стоек. От чтения фотографии на время — к чтению сети на владельца.



ГЛАВА ПЯТАЯ

Домены и история регистрации

У каждого домена есть бумажный след. Редакция — это занавес, а не стена.

Год назад ты читал блог. Не большой — личный сайт, постов тридцать, одна длинная серия, которую ты держал на глазу, комментарии, где осели три постоянных читателя. Сегодня ты вставляешь адрес в свежую вкладку, и браузер уносит тебя куда-то в другое место — на посадочную страницу с курсом, о котором ты никогда не слышал, шрифтом, от которого старый сайт бы поперхнулся. Домен жив. Сайт за ним — от

чужого.

Кто-то владеет этим именем сейчас. Кто-то владел им тогда. Между этими двумя владельцами — бумажный след: регистрация, передача, смена сервера имён, новый почтовый провайдер, может быть, просрочка и перехват оппортунистом. А под всем этим, зарытая в снимке 2011 года, до которого зачистка 2018-го так и не добралась, всё ещё может лежать email — настоящий, в чистом виде, принадлежащий человеку, который впервые зарегистрировал домен, когда никто не смотрел.

Ты только что вышел из работы по людям в работу по инфраструктуре. Инструменты меняются. Инстинкт — нет. Ты по-прежнему обходишь по кругу точку в центре, и кольцо по-прежнему подсвечено.

Идея: домен — это бумажный след

Домен — это не сайт. Первое, что нужно поправить в голове, потому что пока не поправишь — половина того, что дальше, будет казаться магией.

Сайт — это то, что видно в браузере: пиксели, текст, картинки, корзина. Домен — это *запись* об этом сайте, запись, которую ведёт реестр, повторяет регистратор и переповторяют полдюжины публичных lookup-сервисов и сервисов пассивного сбора по всему миру. Каждый раз, когда кто-то меняет эту запись — новый регистрант, новый

сервер имён, новый почтовый провайдер, новая дата истечения, — изменение фиксируется, и часто *старое* значение фиксируется тоже, где-то, кем-то.

Тебе не нужно ничего взламывать. Ты читаешь след.

След в 2026-м тоньше, чем в 2015-м, потому что в 2018-м пришла эпоха редакции и спрятала многое из того, что раньше было в открытом виде. Но *тоньше* — не *исчез*. Две вещи в домене почти невозможно спрятать полностью: прошлое, потому что снимки переживают ту зачистку, которая за ними пришла; и соседей, потому что домен живёт на инфраструктуре, которую делит с другими доменами, а соседи часто рассказывают больше, чем цель собиралась.

Термины, которые ты услышишь часто

Разбираем сначала. Каждая техника ниже использует минимум два.

- **WHOIS** — публичная запись о том, кто и когда зарегистрировал домен. Читается «ху из». Запрашиваешь — получаешь текстовый блок.
- **Реестр vs регистратор**. Реестр — авторитет, ведущий домен верхнего уровня (.com, .io, .de). Регистратор — продавец, у которого ты домен на самом деле покупаешь: GoDaddy, Namecheap, маленький бутик. Тот же домен, две разные компании за ним.

- DNS — Domain Name System, телефонная книга, которая превращает имя (example.com) в адрес, до которого компьютер может дотянуться (IP).
- Типы записей. A — IPv4-адрес, на который указывает имя. AAAA — IPv6. MX — куда доставляется почта для этого домена. NS — какие серверы имён держат DNS-записи домена. TXT — свободные текстовые записи для политик и верификаций, самый громкий канал утечек из всей пачки.
- Сервер имён. Сервер, который фактически держит DNS-записи домена. Каждый домен указывает на один или несколько серверов имён, и они группируются полезным образом.
- Исторический WHOIS. Снимки записи WHOIS, сделанные до эпохи редакции 2018, когда имена и email регистрантов обычно были в открытом виде. Держатся коммерческими архивными сервисами.
- Reverse IP. Каждый другой домен, обслуживаемый с того же IP-адреса, что и твоя цель. Иногда шум, иногда золото.

Что WHOIS всё ещё показывает в 2026-м, а что перестал

Примерно до 2018-го живой запрос WHOIS по большинству доменов верхнего уровня выдавал имя, email, почтовый адрес и телефон регистранта в открытом тексте. Эта эпоха закончилась. В Европе появился GDPR, политика ICANN в ответ сдвинулась, и большинство регистраторов теперь возвращают отредактированную запись для персональных полей: «REDACTED FOR PRIVACY», «Data Protected», «See registrar's privacy policy».

Что *всё ещё* возвращается в 2026-м почти для любого запрошенного домена:

- Регистратор — продавец.
- Дата создания — возраст операции. «Консалтинговая фирма», чей домен зарегистрирован одиннадцать недель назад, что-то о себе рассказывает.
- Дата обновления — последнее изменение записи.
- Дата истечения — когда она сдохнет без продления.
- Флаги статуса — `clientTransferProhibited`, `serverHold` и их кузены. Это анти-угонные замки, которые ставит регистратор или реестр — они блокируют несанкционированную передачу, они *не* про приватность, и отредактированный регистрант со статусом «prohibited» — это нормально, не подозрительно.

Скучно почти всегда, полезно, когда внезапно меняются.

- Серверы имён. Одно самое полезное поле, оставшееся в живом WHOIS.

Серверы имён важны, потому что кластеризуются. Два несвязанных хобби-блога на одном большом DNS-провайдере (ns1.cloudflare.com и его соседи) не говорят ничего. Два малоизвестных домена, делящих приватное имя сервера имён, которое встречается ещё только на девяти доменах в мире, — говорят очень много.

Принцип держится. То, что выглядит отредактированным, спрятано не полностью. Персональные поля на лицевой стороне записи ушли за занавес, но боковые каналы — предпочтения по регистратору, возраст по дате создания, кластеризация серверов имён и, главное, исторический архив — не ушли.

Исторический WHOIS: email 2011 года, который так и не отредактировали

До эпохи редакции email и имена регистрантов были публичными по умолчанию для большинства TLD. Вокруг этого выросла коммерческая индустрия — сервисы, которые тихо записывали снимок WHOIS всего мира каждый день и держали архив. Когда в 2018-м пришёл GDPR и текущий WHOIS ушёл в темноту, архив не стёр себя задним числом. Что было в открытом виде до — до сих пор в открытом виде, лежит в этих исторических базах.

Это самый большой рычаг, которому учит эта глава. Если домен был впервые зарегистрирован в 2011-м на `operator@personalemail.com` и отредактирован только после 2018-го, запись 2011-го всё ещё там — и email тоже.

Регистрант, который ни разу не переносил этот домен, не додумается вычищать то, что записал пятнадцать лет назад, потому что в 2011-м никто ничего не вычищал. Это «тот один email, который упустила зачистка» — и это часто весь кейс.

Честная оговорка: большинство сервисов исторического WHOIS коммерческие и платные, и конкретный вендор, названный в любом гайде, который ты читаешь, — включая этот, если бы я назвал одного, — может не существовать к моменту, когда ты попробуешь. Считай *форму* долговечной (снимки до 2018-го существуют и запрашиваемы), а

конкретную дверь — заменимой.

Чтение DNS как разведка

Набор DNS-записей домена — короткий список, публично запрашиваемый и — в отличие от WHOIS — никогда не редактировался. Читай каждый тип записи. Каждая выдаёт что-то своё.

- **A / AAAA.** IP, обслуживающий сайт. Это пивот в reverse-IP: какие ещё домены сидят на этом же хосте? На гигантском шаред-хосте или CDN — тысячи несвязанных арендаторов, почти бесполезно. На маленьком VPS с тремя арендаторами — все три могут принадлежать одному оператору.
- **MX.** Куда доставляется почта домена. MX-записи, указывающие на google.com или outlook.com, значат, что оператор пользуется Google Workspace или Microsoft 365 — распространённо, слабый сигнал сам по себе. MX, указывающий на самохостовый почтовик на собственном IP оператора, говорит, что оператор любит держать почту сам, — и даёт тебе IP для реверса.
- **NS.** Серверы имён. На блоке дженерик-провайдера — бесполезно для кластеризации. На необычном имени частного сервера имён — ns1.mycoolprojects.net — можно сделать reverse-NS: каждый другой домен в мире, указывающий на тот же сервер имён, часто оказывается другой собственностью того же оператора.

- **ТХТ.** Самый громкий канал утечек. SPF-записи перечисляют каждого отправителя почты, которого домен авторизует. DKIM и DMARC подробно раскрывают почтовый стек. Токены верификации — google-site-verification, facebook-domain-verification, Zoom, Atlassian, Stripe — говорят, какие платформы оператор прицепил к этому домену, и сами строки токенов иногда сшивают два домена в одном организационном тенанте.
- **CNAME.** Алиасы. CNAME, указывающий blog.target.com на личный поддомен оператора в Netlify или его личный GitHub Pages, — распространённая случайность и чистый пивот.

Метод, шаг за шагом

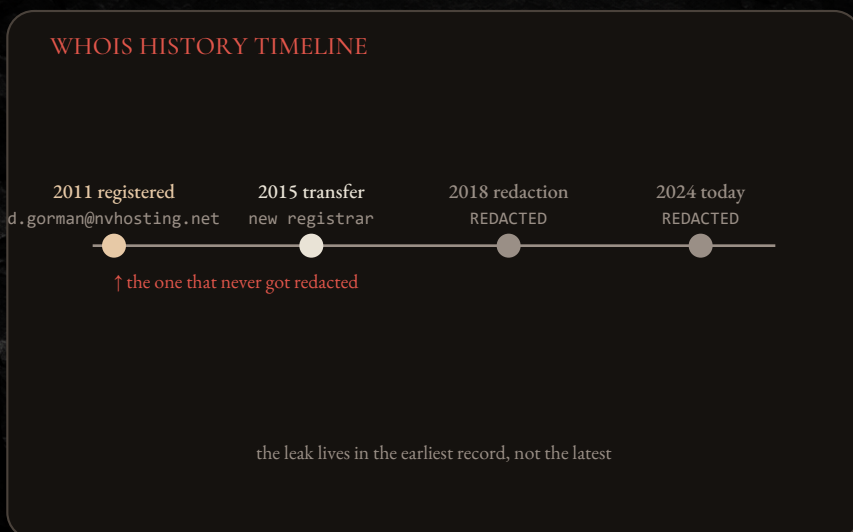
Шаг 1 — прочитай живой WHOIS. Запроси домен. Запиши: регистратор, дату создания, дату обновления, истечение, флаги статуса, серверы имён. Ни через одно не пробегай глазами.

Шаг 2 — заberi исторический WHOIS. Посмотри *самую раннюю* запись в архиве. Потом иди по хронологии и отмечай каждый переход — смена email регистранта, смена имени регистранта, смена сервера имён, смена регистратора. Каждый переход — момент, когда оператору пришлось коснуться записи, и каждое касание — момент возможного следа. Email 2011-го обычно в *самой ранней* записи;

переходы рассказывают историю дальше.

Шаг 3 — прочитай DNS. Забери A, AAAA, MX, NS и каждую TXT-запись. Особенно читай TXT — большинство людей оставляют там больше себя, чем понимают.

Шаг 4 — reverse-IP по текущему хосту. Посмотри каждый другой домен, обслуживаемый с того же IP. Взвешивай честно: на шаред CDN или большом хостинг-провайдере reverse-IP — это тысячи несвязанных арендаторов, ничего не говорит; на маленьком VPS с горсткой арендаторов близкие соседи часто оказываются тем же оператором.



Бумажный след домена во времени: создание, переходы, зачистка редакцией и снимки до 2018-го, пережившие её в коммерческих архивах.

Шаг 5 — reverse-NS. Посмотри каждый другой домен в мире, указывающий на те же серверы имён.

Дженерик-провайдерские серверы имён (ns1.cloudflare.com и друзья) для этого бесполезны — уровень шума слишком высок. Странные, приватные имена серверов имён — золото; сервер имён, который обслуживает девять других доменов и только их, только что вручил тебе весь кластер оператора.

Попробуй (2026). Возьми домен, которым владеешь сам. Запроси его живой WHOIS и запиши каждое поле. Запроси каждый тип DNS-записи. Прочитай собственные TXT глазами постороннего. Что они говорят чужому о том, какими платформами ты пользуешься, куда уходит твоя почта и какие другие домены — твои? Большинство удивлены ответом. Конкретный инструмент запроса, названный в любом руководстве, к моменту чтения мог умереть, — форма (запросить WHOIS и каждый тип записи со свежего терминала или через приличный веб-lookip) — нет.

Шаг 6 — паттерны регистратора. Кросс-проверь регистратора против других известных доменов кандидатского оператора. Большинство людей регистрируют всё у одного продавца по привычке. Если семь доменов, которые ты уже привязал к одному человеку, все у

одного нечастого регистратора, и целевой домен — там же, это подпись — слабо само по себе, значимо в комбинации.

Шаг 7 — ищи момент «упустили зачистку». Прочитай каждый контактный email в каждой исторической записи WHOIS этого домена и его соседей. Прочитай каждую TXT-запись на токены верификации, которые маются на конкретный tenant-идентификатор — токен верификации Google Workspace связывает каждый домен в этом тенанте. Один утёкший email или один общий tenant-токен часто — весь пивот к человеку.

Шаг 8 — ранжируй. Та же лестница, что всегда. Только совпадение регистратора — слабый. Совпадение регистратора плюс reverse-NS кластер — умеренный. Историческая запись WHOIS с полным именем регистранта и email, который совпадает с реальной контактной информацией человека в другом месте, — сильный. Не складывай два умеренных и не называй результат сильным; лестница работает не так, и не так ты сохраняешь репутацию.

Разобранный кейс, с тупиками

Клиент попросил меня атрибутировать мелкого оператора, крутившего скам-сайт «инвестиционного образования» на winspiral-partners.io. Сайт продавал «менторскую программу» за пятизнак, отзывы — в основном стоковые фото под выдуманными именами. Клиент хотел живого человека за операцией. Кейс вымышленный, метод настоящий.

Живой WHOIS. Всё, что мне интересно, — за занавесом.

```
WHOIS  winspiral-partners.io
-----
Registrar    BigDiscountRegistrar
Created       2023-04-11
Updated       2024-11-02
Expires       2027-04-11
Status        clientTransferProhibited
Registrant    REDACTED FOR PRIVACY
Email         REDACTED FOR PRIVACY
NS1           ns1.cloudflare.com
NS2           ns2.cloudflare.com
-----
personal fields = redacted
```

Всё, что можно прочитать в 2026-м на свежий домен.

Из персональных полей брать нечего. Крупный дисконт-регистратор, дата создания в апреле 2023, дженерик-серверы имён Cloudflare. Всё равно записываю.

Reverse-IP тупик. Сайт стоит за Cloudflare, поэтому А-запись указывает на edge-адрес Cloudflare. Reverse-IP на

адрес Cloudflare возвращает тысячи несвязанных арендаторов — украинский фуд-блог, португальскую юрфирму, битый WordPress 2019 года. Слабо, отклонено. Список арендаторов шаред-CDN — не кластер, это телефонная книга интернета.

Исторический WHOIS тупик. Запрашиваю исторический архив на winspiral-partners.io. Самая ранняя запись — 11 апреля 2023. Раньше ничего. TLD .io никогда не был так дружелюбен к архивным сервисам, как .com, и этого домена просто не существовало до даты создания. Снимка до 2018 нет, потому что домена до 2018 не было. Работать не с чем.

ТХТ-записи тупик. Забираю каждую ТХТ. Дженерик SPF (v=spf1 include:_spf.google.com ~all), дженерик DMARC на quarantine, никаких отличительных токенов верификации. Google Workspace, стандартная конфигурация, никакого tenant-идентификатора, который куда-то ведёт. Ничего отличительного.

Четыре тупика подряд. В этой точке многие бы отчитались *insufficient signal* и остановились. Я — нет, потому что кольцо шире одного домена: домен — одна точка, а у точек есть соседи.

Пивот. Проход по пассивному DNS (техника получит свою главу в главе 8; здесь возьми на веру) вывел на родственный домен — winspiral-support.com, — появившийся в том же

DNS-окружении годом раньше. Сайт по тому адресу был почти идентичным клоном .io-сайта, судя по всему выведенный из строя и оставленный как редирект. .com был *зарегистрирован в 2016-м*, задолго до того, как эпоха редакции стала универсальной для .com.

Я прогнал исторический WHOIS по .com.

```
Historical WHOIS  winspiral-support.com
```

```
-----  
2016-08-19  first record  
Registrant  Daniel Gorman  
Email       d.gorman@nvhosting.net  
Registrar   NicheRegistrarLLC  
2018-05-24  redacted (GDPR sweep)  
Registrant  REDACTED FOR PRIVACY  
2021-03-02  registrar transfer  
Registrar   BigDiscountRegistrar  
2024-11-02  updated  
-----  
2016 record = missed the sweep
```

Снимок до 2018, к которому оператор так и не вернулся и не вычистил.

Вот оно. В записи регистранта 2016-го есть имя и личный email. Домен email, nvhosting.net, — маленький хостинг-бренд, резолвится в лендинг одиночного шопа. Поиск по точному адресу выводит на публичный LinkedIn некоего «Daniel Gorman», мелкого крипто-аффилиата, у которого баннер-картинка — то же самое стоковое «менторское» фото, что и на winspiral-partners.io.

Быстро приходят два подтверждающих. Первое: перенос регистратора .com в 2021-м переместил его к тому же дисконт-регистратору, которого сегодня использует .io, — паттерн регистратора по кластеру оператора. Второе: токены верификации Google Workspace обоих доменов (видимые в TXT) ссылаются на один и тот же tenant-идентификатор — оба домена сидят внутри одного почтового тенанта, и этот тенант — nvhosting.net.

Ранжирую честно. Историческая запись WHOIS 2016 — единственный чистый, самоссылочный сигнал, first-party утверждение о владении на определённый момент времени. Паттерн регистратора-кластера и общий почтовый тенант *ощущаются* как два дополнительных голоса, но по сути это один и тот же лежащий факт, увиденный дважды: административные привычки оператора. Тот, кто покупает через один дисконт-регистратор и держит оба домена внутри одного тенанта Google Workspace, выражает одно закупочное решение, а не два независимых. Считаемо правильно, это одна самоссылка плюс один сигнал-привычка — умеренный-к-сильному, а не чистый сильный.

Клиент получил человека, email и подтверждающий LinkedIn — и честную оговорку из двух частей. Первая: человек, названный в записи 2016-го, — это *регистрант*, что не обязательно то же самое, что *оператор сегодня*. Домен

может сменить руки. Вторая: два «независимых» подтверждающих не вполне независимы друг от друга; отчёт помечает их как сигналы-привычки оператора, а не три отдельных голоса. Чтобы чисто дойти до сильного, нужен был бы сигнал из принципиально другого метода сбора — совпадение содержания с текстами самого Daniel Gorman, фото, которое он выложил и которое переиспользовано на сайте, публичное признание в его LinkedIn. Отчёт называет то, что могло бы туда довести.

Второй кейс: тот, который не закрывается

Другой домен, та же неделя. Одностраничный сайт, обвиняющий именованного человека в мошенничестве, ни автора, ни контактов. Клиент хотел знать, кто его поставил.

Домен зарегистрирован свежим в июне 2024, приватная регистрация с первого дня. Живой WHOIS: полностью отредактирован. Исторический WHOIS: ничего старше июня 2024 не существует, потому что домена не было. Серверы имён: дженерик Cloudflare, значит reverse-NS бесполезен. Reverse-IP: одиночный арендатор Cloudflare, та же бесполезность. TXT-записи: дженерик SPF, нет токенов верификации, почта не настроена (нет MX).

На доменном уровне пивота нет. Каждый боковой канал, которому эта глава учит, возвращает шум или ничего.

Честный отчёт клиенту: *недостаточный сигнал на одном*

доменном уровне. След продолжается в других слоях — в СТ-логах главы 6, в соседях пассивного DNS главы 8, в HTML-отпечатках сайта и аналитик-ID, которые тоже территория главы 8. Домен сам по себе не сказал ничего. Это настоящий ответ, и я его так и пишу.

Безопасное упражнение

Сделай это на себе, на домене, которым реально владеешь. Прочитай живой WHOIS. Прочитай каждый тип DNS-записи. Прочитай свои TXT глазами постороннего, ища токены верификации и детали почтового стека. Потом напиши короткий абзац: только из этих записей — что чужой человек может узнать о том, какими платформами ты пользуешься, чью почту маршрутизируешь и какие ещё твои домены сидят по соседству. Большинство удивлены, насколько много себя оказывается публикуемым по умолчанию в DNS.

Итог

- Домен — не сайт; это *запись* о сайте, и каждое её изменение фиксируется.
- Живой WHOIS после 2018-го обычно скрывает регистранта, но всё ещё возвращает регистратора, даты, флаги статуса и — самое полезное — серверы имён.
- Исторический WHOIS держит мир до 2018-го в открытом виде. Email 2011-го, который так и не

вычистили, часто и есть весь кейс.

- Читай каждый тип DNS-записи — A, AAAA, MX, NS, TXT. Больше всего утекает TXT.
- Reverse-IP и reverse-NS — пивоты, а не ответы; взвешивай по шумности окрестности.
- Предпочтения по регистратору и тенанты по токенам верификации — кластерные сигналы, слабые в одиночку, значимые в комбинации.
- Ранжируй по лестнице как всегда: два умеренных — не сильный; один чистый самоссылочный сигнал — сильный.
- Когда доменный слой возвращает ничего — так и говори. Есть другие слои.

Глава 6 идёт в следующий — в логи прозрачности сертификатов, где каждый TLS-сертификат, когда-либо выпущенный на имя, записан публично, навсегда.



ГЛАВА ШЕСТАЯ

Прозрачность сертификатов

Каждый сертификат, которому доверяют браузеры, теперь публикуется, навсегда, открыто.

Отдел зарплат средней компании тратит пятничный вечер, чтобы собрать новое стейджинг-окружение. Оно должно быть только внутренним. В публичных зонах их DNS про него не упоминает; их фаервол блокирует случайные сканы снаружи; никому в компании об этом не сказали. Потом их админ, за десять минут до ухода на выходные, запускает certbot — стандартный инструмент выпуска

TLS-сертификатов от Let's Encrypt — против имени хоста staging-payroll.corp-example.com, потому что HTTPS проще, чем ворнинг браузера в понедельник утром.

За секунды это имя хоста становится публичным. Не утечкой, не мисконфигурацией, не тем, что их кто-то сканирует. По устройству современного веба. Сертификат, который админ только что запросил, был опубликован в append-only лог в момент выпуска и будет лежать там, читаемый кем угодно, фактически вечно. Стена осталась. Фаервол остался. Внутренний DNS остался приватным. Но *имя* — staging-payroll.corp-example.com — снаружи.

Ты их не сканировал. Ты их не пробивал. Ты прочитал compliance-запись, которую браузерная индустрия намеренно сделала обязательной. Эта глава — про эту запись.

Идея: браузеры сделали приватность TLS-именованных хостов невозможной

В середине 2010-х браузерной индустрии надоели неправильно выпущенные сертификаты. Несколько громких инцидентов — сертификационный центр, тихо выпустивший сертификат на домен, который не имел права подписывать; скомпрометированный СА, чеканящий Google-сертификаты; государства, дающие на национальные СА, — показали, что модель приватного доверия не аудируется. Ответ — Certificate Transparency, оформленный в RFC 6962: сеть append-only публичных логов. Каждый публично-доверяемый сертификат должен быть опубликован хотя бы в один лог в момент выпуска. Если сертификата нет в логах, современные браузеры отказываются ему доверять. На практике «современные браузеры» — это политика Chrome с 2018-го и Apple с того же года; Firefox СТ никогда не форсил. С учётом суммарной доли рынка Chrome и Safari, СТ фактически обязателен для любого сертификата, смотрящего в публичный веб.

У этой политики есть второй порядок последствий, о котором составители знали и с которым согласились. Любое имя хоста, защищённое публично-доверяемым TLS-сертификатом, — это имя хоста, перечисленное в публичном логе. Не «обнаружимое в теории» — перечисленное, в поисковой базе, с меткой времени,

навсегда, индексируется десятками агрегаторов.

Ты не эксплуатируешь баг. Ты читаешь compliance-запись.

Это оформление важно, потому что оно же проводит линию: всё в этой главе — работа с публичной записью; ничто в этой главе не даёт тебе права *трогать* обнаруженный хост. К этому мы вернёмся.

Термины в одну строчку каждый

- CA (сертификационный центр) — организация, которая подписывает сертификат; Let's Encrypt, DigiCert, Sectigo, GoDaddy и ещё около дюжины обрабатывают почти всё.
- CT-лог — append-only публичная запись каждого выпущенного сертификата; можно искать, подписываться, никогда нельзя удалять.
- SAN (Subject Alternative Name) — список имён хостов, которые покрывает один сертификат; часто десятки, иногда сотни.
- Wildcard — SAN вида *.example.com, покрывающий каждый поддомен, ни один не называя.
- CN (Common Name) — легаси-поле, куда раньше клали основное имя хоста; всё ещё часто заполнено, но теперь важен SAN.
- Precertificate (прексертификат) — копия сертификата, который CA собирается выпустить, с

«poison»-расширением, чтобы браузеры её не приняли, отправляется в логи первой, чтобы лог вернул Signed Certificate Timestamps, которые встраиваются в финальный сертификат. Прекертификат — то, что ты видишь при поиске в СТ-логе; отдельной поздней записи для настоящего сертификата нет.

- **Issuer** — СА, подписавший конкретный сертификат; один оператор часто использует несколько в течение года.

Что СТ реально даёт

- Почти полный перечень *внешне-видимых* имён хостов целевой организации — включая staging, admin, api, dev, payroll, jenkins, git-поддомены, которые админ не собирався рекламировать, но хотел на них HTTPS.
- Историческую запись — имена хостов из истёкших, отозванных или удалённых сертификатов остаются видны; поддомен, переставший резолвиться в 2022-м, до сих пор виден как свидетельство того, что он когда-то был.
- Кросс-issuer вид — одна компания рутинно использует три-четыре СА между стейджингом, продакшеном и разными SaaS-обёртками; поиск по домену объединяет их в единый список.
- Утечки SaaS-тенантов — SaaS-провайдер выпускает per-customer сертификаты (acme-corp.zendesk.com, acme-corp.atlassian.net), и поиск в СТ по домену самого SaaS раскрывает каждого клиента, чей tenant-имя было

когда-либо сертифицировано.

- Тайминг — прекертификат нового окружения часто виден за часы до публичного анонса, потому что админы выпускают TLS до того, как перерезать ленточку.
- Кросс-организационный вид общей инфраструктуры — два бренда, делящих сертификат по одному SAN-листу, — недвусмысленно делят хостинг.

Чем СТ не является

СТ видит только *публично-доверяемые* сертификаты — те, которым доверяет браузер. Организация, крутящая полностью внутреннюю РКІ (самоподписанные или подписанные приватным СА, который она сама распространяет по своим машинам), в СТ не появляется вообще. СТ также не раскрывает, что *работает* на хосте — только имя. Имя хоста — это след, а не атрибуция: оно говорит, что вещь существует по адресу, но не кто за ней и что она делает. Всё в этой главе превращает имена хостов в зацепки, которые последующие главы превращают в людей и в подтверждённое использование.

Метод, шаг за шагом

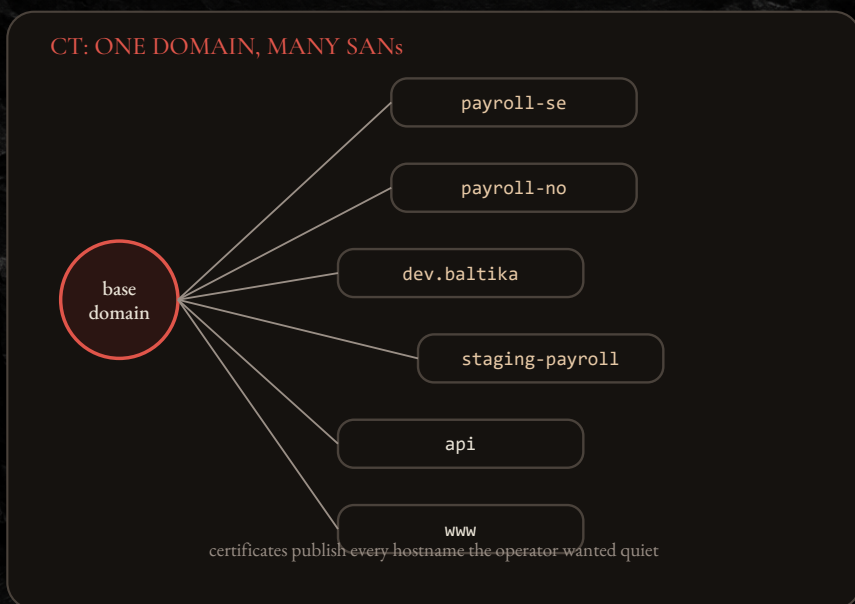
Шаг 1 — зафиксируй домен. Из работы главы 5 по WHOIS и DNS у тебя уже есть базовый домен, которым цель реально управляет, плюс её алиасы (поглощения, маркетинговые сайты, ccTLD-варианты). Запиши. СТ-запросы возвращают ровно то, что запрашиваешь; пропущенный алиас — упущенная ветвь дерева.

Шаг 2 — запроси СТ по базовому домену и каждому известному алиасу. Форма запроса одинакова во всех СТ-интерфейсах — crt.sh и его собратья принимают выражение по домену и возвращают сертификаты, чей SAN-лист ему соответствует. Забери каждое имя хоста из каждого SAN во всех возвращённых сертификатах, дедуплицируй и отсортируй по времени первого появления. То, что у тебя теперь есть, — история внешне-сертифицированных имён хостов цели. (Названия интерфейсов устаревают быстро; форма — «запросить по домену, прочитать SAN» — нет.)

Шаг 3 — прочитай паттерн именования. Админы не креативны. admin, api, staging, stage, stg, dev, qa, uat, test, preprod, payroll, internal, intranet, vpn, git, gitlab, jenkins, jira, wiki, mail, smtp, sso, auth, id, admin-`<region>`, `<product>`-`<env>` — это классический словарь утечек. Кластер таких говорит тебе о *форме* внутреннего окружения ещё до того, как ты согласишься на содержимое. Шесть

поддоменов, названных jenkins, sonarqube, nexus, git, jira, wiki, набрасывают целый DevOps-стек без единой пробы.

Шаг 4 — кросс-референс с DNS. Имя хоста, видимое в СТ и при этом резолвящееся — с живой A или AAAA, — сейчас достижимо. Имя хоста, видимое в СТ и уже не резолвящееся, вышло из эксплуатации, но когда-то было реальным. Оба важны. Живые — это текущая поверхность атаки для защитника или текущая исследовательская поверхность для ресёрчера; мёртвые набрасывают то, как окружение выглядело раньше, что часто более раскрывающе, чем сегодняшнее, потому что админы убирают продакшн и оставляют стейджинг в логе навсегда.



Базовый домен в корне, верс SAN'ов от каждого сертификата и разделение на ветви живых-в-DNS и только-исторических.

Исторические ветви — самое красноречивое.

Шаг 5 — ищи утечки тенантов. Каждый SaaS-продукт, дающий клиентам собственное имя хоста, кладёт эти имена в СТ. Возьми SaaS, который цель, вероятно, использует — helpdesk, wiki, issue tracker, зарплатный процессор, — и ищи в СТ домен этого SaaS. Гrepни возвращённые SAN-листы на имя цели. Сертификат, покрывающий `acme-corp.zendesk.com`, доказывает, что у Acme Corp есть платный тенант Zendesk. Никто в Acme это не публиковал. Никто в Zendesk это не публиковал. Опубликовал СТ-лог, потому что Zendesk обязан был сертифицировать.

Попробуй (2026). Поищи в СТ-интерфейсе собственный домен. Прочитай таймлайн сертификатов, которые ты сам себе выпускал за годы. Отметь забытый стейджинг, купленный бренд, которым до сих пор владеешь, wildcard от CA, которого думал, что перестал использовать. Это упражнение натаскивает глаз на паттерн утечек; заодно закрывает пару собственных.

Шаг 6 — смотри поток. Некоторые сервисы (упоминаю как форму, не как рекомендацию — конкретные названия меняются) позволяют подписаться на домен: каждый новый выпуск сертификата триггерит алерт в течение минут. Так исследователи ловят запуски продуктов, поглощения и

новые региональные расширения раньше пресс-релиза. Новый SAN, появляющийся под доменом конкурента с именем payroll-de в 03:17 вторника, — датапоинт, которого у тебя иначе никогда не было бы.

Шаг 7 — ранжируй. Имя хоста — это *след*, не *атрибуция*. Живой поддомен admin говорит, что организация существует и держит админ-интерфейс; он не называет человека, не доказывает использование и не даёт права на следующий шаг. Только в сочетании с содержимым (глава 7) или отпечатками инфраструктуры (глава 8) след становится зацепкой, указывающей на человека. Взвесь фрагмент на лестнице честно и решай.

Разобранный кейс, с тупиками

Финансово-прессовый клиент попросил проверить одно конкурентное утверждение перед публикацией. Стартап-соперник рассказывал инвесторам, что маленькая SaaS-компания Halkstone Labs — публично описанная только как «магазин fintech-тулинга» на одностороннем сайте — тихо строит зарплатный продукт для Северного рынка. Сайт Halkstone ничего не говорил ни про зарплаты, ни про Скандинавию. Клиент не хотел контактировать с целью и предупреждать её. Он хотел знать, из открытых источников, держится ли утверждение соперника. Компания вымышленная, метод настоящий.

Anchor. Из маркетингового сайта и работы главы 5 по WHOIS базовый домен — halkstonelabs.com. Очевидных алиасов нет, купленных брендов не всплыло. Значит, один СТ-запрос.

Первый проход был в основном скучным.

```
crt.sh style listing, halkstonelabs.com
-----
47 certificates, 3 issuers
oldest 2021-04, newest 2026-06

SAN samples (dedup):
  www.halkstonelabs.com
  mail.halkstonelabs.com
  api.halkstonelabs.com
  stage.halkstonelabs.com
  status.halkstonelabs.com
  *.halkstonelabs.com   (wildcard, 2024-11)
-----
nothing said "payroll" yet
```

Сорок семь сертификатов, и SAN-лист выглядел как любой другой маленький SaaS в интернете.

Тупик один — скучный кластер. [www](https://www.halkstonelabs.com), [mail](https://mail.halkstonelabs.com), [api](https://api.halkstonelabs.com), [stage](https://stage.halkstonelabs.com), [status](https://status.halkstonelabs.com). Ничего там не намекало на новую продуктовую линию, тем более на зарплатный продукт для Скандинавии. Обычный паттерн: маленький магазин с маленьким футпринтом держит маленький SAN-лист на главном сертификате и ротирует одни и те же.

Тупик два — wildcard. В ноябре 2024-го они выпустили wildcard, *.halkstonelabs.com. Wildcard покрывает каждый

поддомен, но не *называет* ни одного. Значит, сам сертификат wildcard доказывает, что оператор ожидал много поддоменов — маленький, но реальный сигнал, — при этом ничего не говорит о том, *каких*. Это компромисс, на котором построены wildcard'ы, и он же делает их привлекательными для организаций, понимающих СТ.

Тупик три — призрачный поддомен. Один более старый сертификат, из 2022-го, имел SAN на `dev.halkstonelabs.com`. Многообещающе. Отметил, потом кросс-чекнул в DNS: `dev.halkstonelabs.com` больше не резолвится. Сертификат истёк, продлён не был. Исторически реален, сейчас мёртв — свидетельство, что dev-окружение когда-то было, но живой двери, куда идти, нет.

Тупик четыре — false-positive поиск арендаторов. По интуиции, что они пользуются распространёнными SaaS, я прогнал поиск арендаторов по `atlassian.net` и `zendesk.com`. Ничего под `halkstonelabs` ни там, ни там. Либо пользуются этими продуктами под другим tenant-именем, либо не пользуются вовсе. Отсутствие в СТ — не доказательство отсутствия в реальности; арендатор может существовать под именем, которое я не угадал — распространённый трюк: регистрировать арендатор под кодовым именем проекта, не имеющим общего с родительским брендом. Отметил null, дальше.

Тупик пять — коллизия одноимённых. Сортируя возвращённые сертификаты по issuer, один выпадал: сертификат, выпущенный малоизвестным региональным СА на halkstone.labs — без s, другой TLD, с SAN'ами на бутиковый винный магазин на юге Франции. Коллизии одноимённых в СТ-результатах — правило, а не исключение, потому что лог индексирует каждую строку, которую когда-либо подписал любой СА. Отбросил винный магазин и дальше. Урок: перед тем как считать что-то найденное, убедись, что базовый домен, который ты запрашивал, и базовый домен, который получил, совпадают точно.

Потом лог выплатил. Сортируя SAN-лист по времени первого появления, три записи последнего месяца кластеризовались вместе.

```
Sorted-by-first-seen SAN readout
-----
2026-06-24 payroll-no.halkstonelabs.com
           precertificate, Let's Encrypt
2026-07-02 payroll-se.halkstonelabs.com
           precertificate, Let's Encrypt
2026-07-11 payroll-uat.halkstonelabs.com
           full cert, Let's Encrypt
-----
"no" = Norway, "se" = Sweden, uat = user
acceptance test – a real staging track
```

Три сертификата, три недели, одна история.

Читаем паттерн честно. payroll-no и payroll-se — сильные намёки: no и se — ISO-коды Норвегии и Швеции, и никакая другая продуктовая линия в SAN-истории Halkstone такой суффикс-паттерн не использует. payroll-uat — расколка: user acceptance testing — стадия, которая существует, только когда реальный продукт достаточно близок к реальным клиентам, чтобы обосновать клиент-подобное тестовое окружение. Никто не поднимает UAT под паром.

Кросс-чек в DNS: все три резолвятся, на IP в том же хостинг-блоке, что и остальная инфраструктура halkstonelabs.com. То есть окружения не только сертифицированы — они живые. Я их не открывал. Я не послал ни одного запроса ни на один из этих трёх хостов сверх резолва имени. Это была линия.

Что я отчитал. Утверждение соперника подтверждается публичным СТ-следом: Halkstone Labs крутит зарплатную продуктовую линию с норвежским и шведским вариантами плюс рабочим UAT-окружением, впервые сертифицированным за последние четыре недели. Свидетельство — публично-запись и воспроизводимо; клиент может проверить сам, не контактируя с целью. Я честно пометил wildcard и прозрачный dev-сертификат как фоновые сигналы, а не как payload, и отметил, что СТ говорит форму и тайминг, но не *содержание*: неделю или шесть месяцев продукт от клиентского запуска — вопрос, на

который СТ не отвечает.

Клиент опубликовал материал. Материал устоял.

Второй кейс: тот, который не закрывается

Другой микрокейс, оборонный подрядчик. Клиент попросил ту же процедуру: перечислить внешне-видимое окружение через СТ и набросать форму. СТ-поиск вернул ровно один сертификат: wilddcard на маркетинговом домене, выпущенный мейнстримным СА, покрывающий маркетинговый сайт и алиас www. И всё. Ни стейджинга, ни admin, ни jenkins, ни утечек тенантов ни в одном SaaS, что я пробовал.

Причина легко угадывается и обойти её невозможно: этот подрядчик крутит полностью внутреннюю РКІ. Каждый внутренний хост подписан приватным СА, распространённым по собственным машинам. Ни один из этих сертификатов никогда не идёт в публичный лог, потому что они не публично-доверяемые и никогда не должны были быть. СТ был спроектирован, чтобы аудировать *публичное* доверие; про приватное он по устройству ничего не говорит.

Честный отчёт клиенту: *СТ здесь тебе не даёт ничего. Эта цель не течёт через СТ. Двигайся к главе 7 за content-based углами или прими предел.* Не каждый метод выплачивает на каждой цели, и зрелость РКІ цели — сигнал сам по себе, стоящий, чтобы его записать.

Замечание про этику

Обнаружение внутренне-выглядящего имени хоста не даёт тебе права его пробивать. Чтение сертификатного лога — работа с публичной записью; открытие ТСП-соединения к `admin.corp-example.com`, отправка HTTP-запроса, запуск port-скана или проба учёток — другой класс действий и в большинстве юрисдикций регулируется законами о несанкционированном доступе, которым плевать, что имя хоста было легко найти. Остановись на имени. Имя хоста заходит в твои заметки как факт о следе цели; оно не становится дверью, в которую тыходишь. Исключения узкие и формальные: опубликованный `scope bug-bounty`, где хост перечислен; авторизованный `penetration-test`; исследовательское соглашение в `scope` — всегда письменно, всегда конкретно. Без этого этическая линия проведена ровно на границе между чтением лога и касанием хоста, и юридическая линия часто проведена там же.

Безопасное упражнение

Возьми известный SaaS-продукт — helpdesk, issue tracker, платёжный процессор, — у которого клиенты получают свои имена хостов. Поищи в СТ домен продукта и прочитай SAN-паттерны. Заметь конвенцию именования (<customer>.product.com, или <region>-<customer>.product.com, или наоборот), wildcard'ы, которые вендор выпускает себе, и говорящие внутренне-звучащие имена хостов, которые вендор забыл, что они наружу. Уйдёшь с работающим глазом на паттерн утечек и с сильным подозрением, что большая часть SaaS-рынка тихо опубликовала свой клиентский лист, никогда этого не собираясь.

Итог

- Certificate Transparency превращает каждый публично-доверяемый TLS-сертификат в постоянную поисковую публичную запись — по политике браузера, не по утечке.
- Любое имя хоста, защищённое публично-доверяемым сертификатом, — это имя хоста в публичном логге; ты читаешь compliance-запись, ты не атакуешь цель.
- SAN-лист в одном сертификате часто называет десятки имён хостов; классические утечки — admin, staging, dev, payroll, jenkins, git и остаток DevOps-словаря.

- Wildcard'ы прячут поддомены за *; они сигнализируют широту, не называя имён.
- Прекертификаты и метки первого появления позволяют засечь новые окружения за часы до публичного анонса.
- Утечки SaaS-тенантов — поиск в СТ по домену самого SaaS раскрывает per-customer имена хостов тенантов, которые клиент никогда не анонсировал.
- СТ молчит по внутренней РКІ; цель, которая подписывает всё приватным СА, СТ ничего не даёт.
- Имена хостов — это *след*, не *атрибуция*. Остановись на имени; не трогай хост без письменного разрешения.

Глава 7 разворачивается от инфраструктуры обратно к людям: как *содержимое*, подаваемое на этих именах хостов, — фавикон, копирайт в футере, аналитик-ID, имя автора в HTML-комментарии — несёт человеческий отпечаток, который одно имя хоста удерживает.



ГЛАВА СЕДЬМАЯ

От инфраструктуры обратно к человеку

*У серверов нет имён. Их операторы не могут удержаться,
чтобы не оставить.*

Есть сайт, продающий фальшивые пресс-релизы. Он выглядит как новостной ленточник — шапка, дэйтлайн, подпись автора, где стоит только «staff». Нет страницы «О нас». Нет импринта. Домен — свежая регистрация, WHOIS полностью отредактирован, хостится за большой CDN. Фронтальный поиск умирает у входной двери.

Но во вкладке браузера есть фавикон — маленький оранжевый квадрат со стилизованной буквой М. И тот же фавикон, байт в байт идентичный, сидит во вкладке, когда открываешь три других сайта, не похожих на этот: магазин добавок, блог «крипто-обзоров» и фальшивую местную газету города в другой стране. И два из четырёх несут один и тот же publisher ID Google AdSense в исходнике страницы — строка, начинающаяся pub-, привязывающая ad-аккаунт к одной Google-идентичности. И этот AdSense ID снова появляется на пятом сайте — маленьком фуд-блоге с подписью автора и реальным именем.

Эта глава — петля. Всё до неё было про инфраструктуру — домены, DNS, сертификаты, хосты. Всё после, стоит перейти петлю, снова становится про человека, и там подхватывает Том 2. Сам пивот — то, чему учит эта глава.

Идея: операторы оставляют отпечатки на своих инструментах

Сервер анонимен. Человек, который его настраивает, — нет.

У каждого оператора есть привычки. Есть аналитический аккаунт, который он всегда вставляет, потому что помнит от него логин. Есть файл фавикона, который он таскает от проекта к проекту, потому что один раз сделал и другой лень. Есть тема WordPress, к которой он всегда тянется, потому что купил лицензию в 2021-м и теперь каждый сайт

начинается с той же папки. Есть паттерн времени коммитов, выдающий часы, которые он реально сидит за клавиатурой, и язык, на котором пишет комментарии, — язык, который никакой конфиг не спрячет.

Любая одна из этих привычек сама по себе — слабый сигнал. Фавикон может быть переиспользован, потому что оба оператора скачали одну и ту же бесплатную иконку. AdSense ID может совпасть, потому что кто-то по ошибке вставил старый снипет. WordPress-тему покупают тысячи людей. Каждая привычка сама по себе не доказывает ничего.

Две-три привычки, выстраивающиеся вместе поверх независимых источников, — совпадение фавикона, совпадение аналитик-ID, совпадение таймзоны коммитов, ни одно из которых не объяснимо той же случайностью, — это уже другая находка. Именно это строит эта глава.

Классы отпечатков оператора

- **Аналитик-ID.** GA4 measurement ID (G-XXXXXXXXXX), легаси-теги Universal Analytics (UA-XXXXXX-Y), publisher ID AdSense (pub-XXXXXXXXXXXXXXXXXX), Facebook Pixel ID, счётчики Yandex.Metrika. Тот же ID на двух сайтах значит тот же *аккаунт* на стороне вендора, а аккаунт принадлежит одному логину. Это один из сильнейших сигналов связи оператора, которые ты найдёшь на инфраструктурном уровне. Он же — один из чаще всего перечисываемых: общий GA-снипет может именовать *разработчика*, а не владельца — младшего подрядчика, переиспользующего один тег у несвязанных клиентов, или аффилиатное кольцо, где дюжина маркетологов вставляет один AdSense ID. Оценивай находку сначала как «тот же аккаунт», и только когда второй, независимый сигнал согласится, повышай до «тот же оператор».
- **Отпечатки фавиконов и изображений.** Фавикон — это файл. Файлы хешируются. Если два якобы несвязанных сайта отдадут одни и те же *байты* по /favicon.ico, это почти никогда не совпадение — это один человек, разворачивающий одну папку. Та же логика распространяется на любой маленький ассет, поставляемый с шаблоном сайта: логотип шапки, placeholder-картинку, JavaScript-файл с характерным комментарием.

- **Комбинации tech-стека.** WordPress сам по себе — распространён. WordPress плюс конкретная платная тема плюс конкретный набор плагинов — с плагинами, загружающимися в том же порядке, — часто индивидуален для оператора. Инструмент, классифицирующий tech-стеки, полезен по отдельным фичам, но идентифицирует комбинация.
- **Исторические email из WHOIS.** Глава 5 подробно об этом говорила. Современный WHOIS отредактирован, но у домена, существовавшего до середины 2018-го, обычно есть публичный email регистранта, захваченный одной из исторических баз, и часто это реальный адрес оператора.
- **Публичный git и метаданные коммитов.** Если хоть часть кода сайта или сопутствующего проекта, которым оператор гордился, лежит в публичном репозитории, git-история течёт email коммиттера, языком сообщений и таймзоной каждого коммита. Репозиторий, где коммиты кучкуются между 21:00 и 02:00 UTC+3, говорит и о том, в какой части мира живёт оператор, и о том, какую часть суток он считает работой.
- **Утечки страниц ошибок.** Неправильно настроенный nginx возвращает дефолтную страницу, называющую внутреннее имя хоста. Забытый эндпоинт `mod_status` на Apache перечисляет каждый обслуживаемый virtual host — иногда включая сайты, которые оператор не хотел на

одной коробке. .env-файл, оставленный в webroot, — не такая уж редкость.

- Адреса отчётов DMARC. Ящик в TXT-записи DMARC домена — `rua=mailto:...` — куда собираются отчёты аутентификации почты, и человек, который его ставил, обычно указывал свой собственный админский адрес.
- Заголовки контактных форм и почты. Сырой вывод контактной формы или заголовков Reply-To на письме, которое она генерирует, иногда несёт настоящий ящик оператора, а не публичный алиас сайта.

Независимость, снова

Том 2 дал тебе правило лестницы — слабый, умеренный, сильный, подтверждено — и предупредил, что штабелирование неезависимых сигналов — самый быстрый способ уверенно ошибиться. Правило применяется здесь без изменений.

Совпадение фавикона и совпадение tech-стека на *одном сайте* — два вида одного набора. Одна папка одного оператора породила оба. Это один сигнал в двух пальто, не два независимых голоса.

Совпадение фавикона на сайте А и совпадение аналитик-ID на сайте В — два независимых голоса. Разные файлы, разные вендоры, разные режимы отказа. Когда они соглашаются,

они соглашаются честно.

Та же ловушка, которую ты научился видеть в главе про identity-graph, есть и здесь. Спрашивай про каждую пару: могли ли они разойтись и не разошлись? Если да — считай. Если нет — считай раз.

Есть более тонкая версия ловушки. Общий аналитик-ID между маркетинговым сайтом компании и её сайтом поддержки — один оператор, скучно и правильно. Общий аналитик-ID между сайтами из абсолютно несвязанных отраслей — магазин добавок, блог маленького городка, обзорник кухонной техники — скорее общий *разработчик*, чем общий *владелец*. Прежде чем записать находку, задай вопрос опровержения: *какая альтернативная история дала бы тот же отпечаток?* Если «один фрилансер, собравший все три» подходит так же хорошо, как «один оператор, крутящий все три», — оператора у тебя ещё нет.

Метод, шаг за шагом

Шаг 1 — anchor. Проговори точку пивота вслух. У тебя есть домен, имя хоста, URL. Запиши. Всё дальше — спицы от этой втулки, и если ты втулку потерял, то смешаешь находки с разных целей.

Шаг 2 — заberi исходник страницы. Открой сайт в браузере и посмотри сырой исходник главной и двух-трёх подстраниц. Извлеки каждый идентификатор, похожий на

тег: аналитик-ID, container ID tag-менеджера, pixel ID, токены верификации сайта, src-хосты скриптов, имена CSS-файлов, характерные имена классов. Читай страницу не за то, что она говорит. Читай её за то, что её код случайно признаёт.

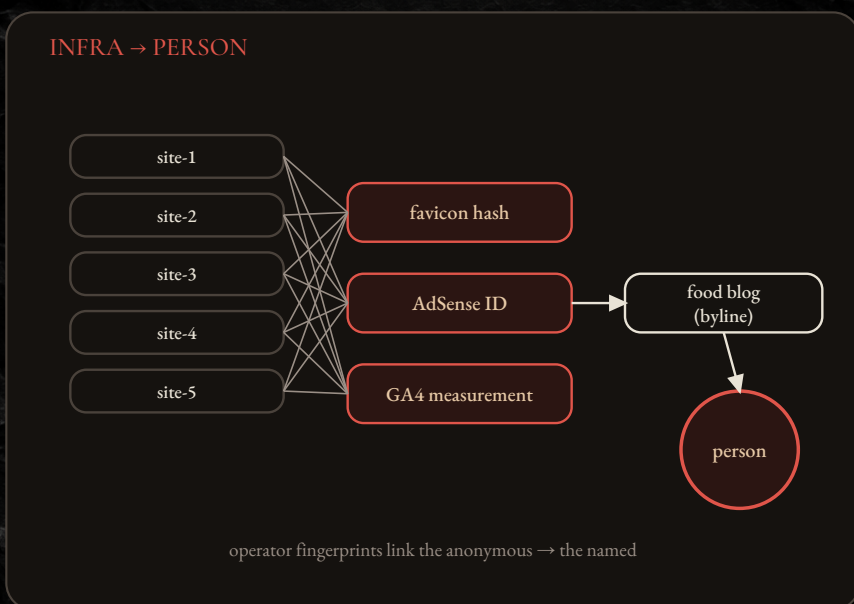
Шаг 3 — хешируй фавикон. Скачай /favicon.ico и посчитай его хеш. Конвенция инфраструктурных поисковиков — MurmurHash3 от base64-закодированных байт; MD5 или SHA-256 сырого файла подходят для кросс-чека. Потом ищи другие хосты, отдающие файл с тем же хешем. Shodan и Censys, на момент написания в 2026-м, оба индексируют хеши фавиконов и дают их запрашивать — проверь текущий синтаксис перед тем, как полагаться.

Шаг 4 — ищи аналитик-ID в другом месте. Возьми каждый ID из шага 2 и ищи точную строку по всему вебу. Google найдёт часть. Специализированные сервисы, индексирующие исходники страниц на tracking-ID, найдут больше. Один AdSense или GA ID, появляющийся на втором, якобы несвязанном домене, — один из сильнейших сигналов связи оператора на инфраструктурном уровне, потому что ID по определению принадлежит одному вендорскому аккаунту.

Шаг 5 — прочитай WHOIS-след снова, в новом контексте. В главе 5 ты это сделал ради самого следа. Сделай снова с целью: email, который ты найдёшь в записи до 2018-го, —

кандидат для проверки против каждой другой находки.

Шаг 6 — ищи собственные обрывки оператора. Забери `humans.txt`, `security.txt`, `robots.txt`, `sitemap.xml`. Попробуй `contact.html`, `about.html`, `team.html`, `imprint.html`. Что угодно с именем. Потом посмотри в архиве версии этих страниц до того, как оператор их вычистил — материал главы 1 применяется напрямую.



Один якорный домен в центре, спицы бегут к каждому классу отпечатков: аналитик-ID, хеш фавикона, tech-стек, исторический WHOIS, утечки страниц ошибок, DMARC-адрес, заголовки контактной формы, публичный git. Каждая спица заканчивается маленьким кластером других хостов или идентификаторов, где повторяется тот же отпечаток. Кластеры пересекаются там, где два

независимых отпечатка приземляются на один и тот же второй хост, — эти пересечения и есть самые сильные точки атрибуции, а до человека доходят, идя по пересечениям наружу.

Шаг 7 — пивот в кросс-платформенную работу. В тот момент, когда какой-то из этих шагов выдаст имя, email или личный соцмедиа-хэндл, ты перешёл петлю. Всё, чему научил Том 2, — работа с identity-graph, работа «заставь сигналы согласиться» — теперь применяется к человеку на другом конце. Передай пивот тому инструментарию; не пробуй переучить его здесь.

Попробуй (2026). Возьми личный сайт или блог, который сам крутишь. Открой исходник и перечисли каждый аналитик-ID, pixel, токен верификации и сторонний скрипт, который он грузит. Скачай его фавикон и посчитай MurturHash3 от base64-закодированного файла. Теперь поищи в favicon-hash индексе другие хосты с тем же хешем и поищи в вебе каждый аналитик-ID. Посмотри, что чужой узнает о тебе только из пивота. Потом холодно реши, какие из этих отпечатков ты хочешь оставить на месте, а какие поменять завтра.

Шаг 8 — кросс-референс публичного кода. Возьми характерную строку из исходника сайта — необычное имя CSS-класса, рукописный JavaScript-комментарий, кусок PHP, не похожий на скопированный из tutorials, — и ищи точную строку на больших код-хостингах. Попадание в личный репозитории — вся игра: git-история течёт email коммиттера, таймзону каждого коммита и язык сообщений. Даже попадание внутри форка может привести к человеку, которому не всё равно и который форкнул.

Шаг 9 — ранжируй на лестнице. Запиши в один абзац, что *выложено* и что *атрибутировано*. Выложено — инфраструктура, которую ты видишь. Атрибутировано — человек, о котором ты теперь утверждаешь, что он это крутит, и на какой ступени уверенности — слабый, умеренный, сильный, подтверждено. Если твои свидетельства останавливаются на «одно совпадение фавикона и один общий арендатор вендора», у тебя зацепка, а не находка. Так и напиши, теми же словами. Читатель, не различающий эти две вещи, воспримет твою зацепку как твой вывод, и это твоя проза, а не его невнимательность, дала ему это.

Разобранный кейс, с тупиками

Задача была маленькой и негламурной. Городской совет накануне местных выборов заметил пять сайтов новостного вида, публикующих скоординированные материалы про одного кандидата. Все пять появились внутри шестинедельного окна. Все пять писали одним голосом. Совет хотел знать, кто их крутит.

Я начал там, где начинается любой пивот: WHOIS по всем пяти. Каждая запись — приватность-отредактирована регистратором. Все зарегистрированы через один и тот же commodity-регистратор, да, но у него миллионы клиентов — в лучшем случае слабый сигнал. Тупик.

DNS дальше. Все пять доменов указывали серверы имён на Cloudflare. Reverse-IP бесполезен — адреса, которые я видел, принадлежали шаред edge, за которым стоят миллионы несвязанных сайтов. Тупик.

Прозрачность сертификатов, по паттерну главы 6. У каждого домена — сертификат Let's Encrypt. Каждый сертификат нёс только имя хоста самого сайта и www. — никакого просачивания admin-поддоменов, никаких стейджинг-окружений, никаких утечек имени оператора в случайном SAN. Тупик.

Контактная форма на каждом сайте на HTML-уровне уходила на адрес contact@ в одном и том же дженерик

Google Workspace арендаторе. Снаружи я видел, что арендатор существует; не видел, кому он принадлежит. Тупик.

Четыре независимых направления, четыре пустоты. Так снаружи выглядит грамотно анонимизированная операция: не то, что ты упускаешь что-то умное, — а то, что фронтальный путь честно закрыт.

Прорыв пришёл из вкладки браузера.

Я заметил, переключаясь между пятью сайтами в одном окне, что маленькие иконки во вкладках выглядят идентично. Не похоже — идентично. Я сохранил /favicon.ico каждого сайта, посчитал MurmurHash3 от base64-закодированных байт и получил один и тот же номер пять раз подряд.

```
favicon-hash.txt
site1.example.tld -1893478234
site2.example.tld -1893478234
site3.example.tld -1893478234
site4.example.tld -1893478234
site5.example.tld -1893478234
default apache icon 1094239847 (not our hash)
default nginx icon -0038284712 (not our hash)
```

Пять сайтов, один файл фавикона, байт в байт. Это не шаблонный дефолт и не два человека, скачавших одну бесплатную иконку. Это одна папка, развёрнутая пять раз.

Я перешёл к исходнику страниц. Три из пяти сайтов встраивали один и тот же publisher ID AdSense.


```
adsense-matches.txt
site1 pub-6602934871052210
site2 pub-6602934871052210
site3 pub-6602934871052210
site4 (no ads)
site5 (no ads)
```

Publisher ID AdSense — не общая библиотека. Это платёжный идентификатор, привязанный к одному Google Account. Три сайта, несущих его, значат одного оператора, направляющего три ресурса на собственную ad-выручку.

Тут пауза, потому что именно здесь поле уже жгло себя. Общий аналитик или AdSense ID — известный сигнал и известный false positive. В 2020-м Bellingcat и The Grayzone публично спорили ровно про такую находку — доказывает ли общий Google-аккаунт у нескольких изданий скоординированное владение или только общий сантехник. Ни одна сторона тогда до конца не победила; урок пережил. Считай совпадение ID сильной зацепкой, не вердиктом. Прежде чем написать «один оператор», ищи второй независимый сигнал — совпадение фавикона, совпадение содержания, необычный общий хостинг-отпечаток. Два голоса, каждый из которых мог не согласиться и не не согласился, — находка. Один голос — зацепка.

Я прогнал тот же publisher ID текстовым поиском по всему вебу. Он попал в шестой сайт — маленький, сонный фуд-блог, зарегистрированный в 2019-м, по теме несвязанный с пятёркой, — который нёс этот ID в футере

каждой рецептной страницы. У блога была подпись автора: «Iryna Petrenko». Распространённое имя в регионе — зацепка, не находка, пока.

Текущая страница «О нас» была из двух предложений и ничего не давала. Я вытащил ту же страницу из архива с трёхмесячным шагом от первого захвата. Версия 2019-го была разговорчивее — абзац об авторе, ссылка на Twitter-хэндл, город.

Теперь я перешёл петлю. С Twitter-хэндла дальше применяется всё из Тома 2: работа с identity-graph, кросс-платформенное подтверждение, family-side пивоты, когда прямой аккаунт затих. Эта работа — не тема этой главы, и я не буду её здесь заново прогонять. Сам пивот — смысл.

Ранжирую честно. На уровне *оператора* — «один человек или очень маленькая команда крутит все пять этих дезинформационных сайтов» — находка сильная: три независимых голоса (совпадение хеша фавикона по всем пяти, совпадение AdSense ID по трём, повторение AdSense ID на шестом атрибутированном сайте), каждый из которых мог пойти иначе и не пошёл. На уровне *индивида* — «и этот человек — Iryna Petrenko из города X» — находка умеренная на одних инфраструктурных доказательствах. Передача в Том 2 донесла дальше. Совет получил отчёт, который назвал ступень, а не только имя.

Второй кейс: тот, который не закрывается

Следующая цель выглядела как та же работа, а не была ею.

Один сайт, один домен, скоординированное поведение в соцсетях вокруг него. WHOIS: полностью отредактирован, свежая регистрация 2024-го. DNS: Cloudflare, дженерик. СТ: один сертификат Let's Encrypt, один SAN. Исходник страницы: никаких аналитик-ID вообще, ни pixel, ни tag manager, ни токенов верификации. Фавикон: дефолтный браузерный глобус — файла не отдаётся, значит и хеша нет. Нет humans.txt. Нет security.txt. Нет публичного git-репозитория, который я мог бы к нему привязать. Каждая admin-поверхность достижима только через внутренний сертификационный центр, которого публичные СТ-логи никогда не видели. Запись DMARC есть, `gua=mailto:` указывает на `dmarc@` на приватно-форвардинговом сервисе.

Каждый класс отпечатков этой главы либо отсутствовал, либо был дженерик. Эту цель построил кто-то, кто читал такую же книгу. На одном инфраструктурном уровне пивота у меня не было — и честный отчёт так и говорит, теми же словами. Есть искушение, когда цель закрывается чисто, придумать ещё один маленький сигнал, чтобы оправдать потраченные часы. Сопrotивляйся. Чистое ничто — реальная находка; выдуманное что-то — карьерозакрывающая. Контр-работа для такой хорошо

укреплённой цели — там, где начинается Том 4.

Когда это не человек — когда это команда

Не каждая инфраструктурная операция принадлежит одному индивиду. Общий фавикон и общий tech-стек по десяти сайтам могут значить одного оператора, крутящего десять проектов, — а могут значить одно маленькое веб-агентство, строящее десять сайтов для десяти разных клиентов из одного in-house шаблона.

Расколка обычно в аналитике, но только если читать внимательно. Агентство обычно вставляет собственный GA или AdSense ID клиента в сайт этого клиента, поэтому эти ID не будут повторяться в десятке. Но некоторые агентства используют один свой Google-аккаунт для *части* клиентов — более новых или на поддержке, — а для остальных ставят теги вручную. Паттерн у агентства неровный: GA4 ID, совпадающие в одних парах и не совпадающие в других, и совпадения не выстраиваются по теме или географии. Один оператор, крутящий десять фронтов, даёт плоское, скучное согласие — те же идентификаторы везде.

Другие сигналы разводят эти два случая. Разные дизайн-системы в «одном» кластере — один сайт на современной библиотеке компонентов, другой ещё на теме 2018-го — гораздо типичнее для агентства, обслуживающего разных клиентов годами, чем для одного оператора,

собирающего десять фронтов в спринте. Метаданные времени коммитов, сдвигающие таймзону между якобы связанными репозиториями, указывают туда же; одиночные операторы не переезжают спонтанно между проектами. Кредиты в футере, ссылающиеся обратно на «*site by studio-name*», даже мелким серым текстом, — расколка, которую агентства оставляют на сайтах клиентов, не заплативших за снятие. Email регистранта в WHOIS на собственном домене агентства, а не на каждом клиенте, — ещё одна. Любые две из этих вместе — и правильная атрибуция *агентство*, не индивид.

Когда инфраструктурные отпечатки согласны, но идентификаторы уровня аккаунта расходятся, твоя атрибуция — *агентство*, не какой-то один клиент. Скажи это на лестнице теми же словами. Атрибутирование общей агентской настройки конкретному клиенту — ложное разрешение, и плохой отчёт юрист разберёт за десять минут. Стоит сказать прямо: атрибуция уровня агентства — *всё ещё* реальная атрибуция. Она называет актёра — реальный бизнес с реальным штатом, счётом в банке и причиной построить сайт. Просто называет другого актёра, чем читатель надеялся. Отдай находку как находку; не растягивай её под предпочтительный ответ читателя.

Безопасное упражнение

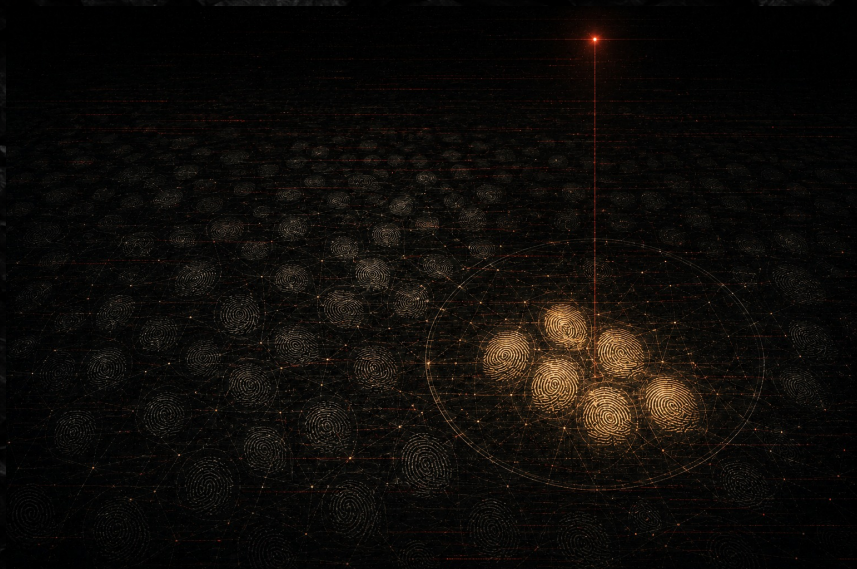
Возьми три собственных сайта или блога — что угодно, что сам крутишь. По каждому проинвентаризируй каждый отпечаток оператора из списка этой главы: аналитик-ID, хеш фавикона, комбинацию WordPress/CMS-темы и плагинов, исторический email из WHOIS если домен достаточно старый, любой публичный git-репозиторий, где лежит код сайта, страницы ошибок, текущие внутренние имена хостов, DMARC-адрес отчётов, заголовки контактной формы. Теперь решай, по одному отпечатку за раз, какие готов оставить и какие хочешь поменять до завтра. Узнаешь за этот час больше, чем за любое количество чтения.

Итог

- Сервер не идентифицирует себя. Человек, который его настраивал, обычно — через инструменты, которые он переиспользует.
- Классы отпечатков к проверке: аналитик-ID, хеши фавиконов, комбинации tech-стека, исторические email из WHOIS, публичные метаданные git, утечки страниц ошибок, DMARC-адреса отчётов, заголовки контактных форм.
- Независимость по-прежнему правит. Совпадение фавикона и совпадение стека на одном сайте — один сигнал. Совпадение фавикона на одном сайте и совпадение аналитик-ID на втором — два.

- Сильнейший сигнал связи оператора на этом уровне — один и тот же аккаунт-скопированный идентификатор (AdSense, GA, Pixel), появляющийся на якобы несвязанных сайтах.
- Wayback — спасение, когда текущую страницу вычистили. Старые About-страницы — там, где операторы раньше были небрежны.
- Эта глава — петля. Как только у тебя есть имя, email или личный хэндл, работа становится работой Тома 2.
- Когда отпечатки принадлежат агентству — атрибутируй агентство. Не отмывай общий шаблон в личную идентичность.
- Некоторые цели построены, чтобы победить каждую технику здесь. Скажи так прямо; не выдумывай уверенность, которую не заработал.

Глава 8 движется от этих активных отпечатков к пассивным следам, которые домен оставляет в DNS во времени, — истории резолуций, пережившей аккуратную зачистку оператора.



ГЛАВА ВОСЬМАЯ

Пассивный DNS и отпечатки

У интернета есть память. Он просто её не подписывает.

Хостинг-провайдер рекламирует себя определённому типу клиентов. Никаких логов. Никаких проверок личности. Никакой истории. Плати чем-то неотслеживаемым, поднимай машину, сноси её, уходи — никто, обещает подача, не узнает, что ты был. Изнутри панели управления провайдера обещание правдиво.

Правдиво оно только изнутри провайдера. В день, когда клиент впервые указал имя хоста на машину, публичный

резолвер где-то в мире залогировал DNS-запрос и позже опубликовал его в агрегаторе, который держит запись бессрочно. Через три месяца, когда клиент тихо переехал ко второму провайдеру, другой резолвер увидел переход. А через полгода после этого, когда он поднял зеркало у третьего провайдера и выпустил свежий TLS-сертификат, сканирующий индекс опубликовал *отпечаток* TLS-стека этого сертификата — 62-символьную форму, которая по случайности совпала точно с отпечатком первого сервера у первого провайдера.

Провайдер клиента сдержал слово. У интернета — своя память.

Идея: у интернета есть память

Два вида памяти, не одно и то же.

Первый — пассивный DNS, сокращённо pDNS: *история* DNS-резолвций по миру. Крупные операторы публичных резолверов и исследовательские коллекторы логируют ответы, которые их резолверы отдают, агрегируют по сенсорам и публикуют — бесплатно с рейт-лимитами или платно за объём. То, что ты получаешь, — таймсерия: это имя хоста резолвилось на этот IP между датой X и Y, на другой IP раньше, ни на что до этого, пока его впервые не увидели. Ты цель не запрашивал. Запрашивали чужие пользователи, а ответ записали.

Второй — сканирующий индекс. Каждый день горстка проектов сканирует видимый интернет — каждый IPv4-адрес, каждый распространённый порт — и записывает, как каждый хост выглядит на сетевом уровне: открытые порты, TLS-сертификаты, HTTP-заголовки, посадочные страницы, фавиконки. Публикуется как поисковой индекс с ключом по каждому захваченному отпечатку. Некоторые держат исторические сканы, давая каждому хосту грубую таймсерию за месяцы и годы.

Вместе pDNS и сканирующие индексы дают тебе time-history и корпус отпечатков всего видимого интернета, без того чтобы ты отправил цели хоть один пакет.

Что даёт пассивный DNS

- Историческая резолюция. Это имя хоста указывало на этот IP в такие-то даты. Смена хостинг-провайдера — датированный переход, видимый через месяцы или годы.
- Обратная история. Этот IP был целью *этих* имён хостов во времени. На маленьком, тихом IP-блоке обратная история — кластер собственности оператора; на огромном шаред-хосте — тысячи несвязанных арендаторов.
- Трассировка миграций. Можно смотреть, как оператор переезжает — старый IP гаснет, пока кэши истекают, новый разгорается — и приколоть миграцию к

календарному окну. Это окно становится собственным отпечатком.

- **Обнаружение кластеров.** Имена хостов, указывавшие на один и тот же необычный IP в течение одной недели, особенно на маленьком VPS с тремя арендаторами на коробке, почти всегда — тот же оператор. Чем реже IP, тем плотнее кластер.
- **Призрачные имена хостов.** Имена, которые разрезолвились один раз, больше никогда, но в записи рDNS сидят навсегда. Идеально для перечисления забытых тестовых окружений цели — имя, которое было живым выходные в 2019-м, разрезолвилось тридцать раз и с тех пор мертво.

Чем рDNS не является

Пассивный DNS видит только то, что залогировали публичные резолверы. Цель, гоняющая собственный рекурсивный резолвер или маршрутизирующая lookup через DNS-over-HTTPS или DNS-over-TLS в стек, не участвующий в рDNS-проекте, в большой мере невидима — запросы никогда не касались логирующего резолвера.

Покрытие неровное по регионам и годам; более старые данные скуднее, некоторые ccTLD представлены едва.

Коммерческий рDNS несёт самый глубокий архив и платный. Бесплатные тирсы существуют, но жёстко

рейт-лимитят с короткой ретенцией. Оба приходят и уходят. Считаю *форму* долговечной (кто-то, где-то логирует ответы резолверов), а *конкретную дверь* — заменимой.

Что дают сканирующие индексы

- **Обзоры открытых портов.** Каждый хост видимого интернета, каталогизированный по открытым портам и *баннеру*, который он вернул, — короткая строка, которую сервис выдаёт при первом соединении, вроде строки версии SSH или приветствия почтового сервера.
- **Отпечатки TLS-сертификатов.** Отпечаток JARM TLS-стека сервера кластеризует идентичные установки. Два сервера с одинаковым JARM крутят один и тот же TLS-софт, настроенный одинаково, на том же порту.
- **Отпечатки HTTP-заголовков.** Строка Server, набор кастомных X-заголовков, фреймворковые подписи, запечённые в страницах ошибок. Редкая комбинация — кластерный сигнал.
- **Хеши фавиконов по всему корпусу сканирования.** Глава 7 использовала фавикон на масштабе одного сайта; здесь ты просишь индекс каждый хост в интернете, отдающий точно этот фавикон, и получаешь список собственности оператора за секунды.
- **Исторические сканы.** Некоторые индексы сохраняют прошлые сканы, поэтому запрос по IP возвращает грубую таймсерию — какие баннеры отдавал полгода назад,

каким сертификатом пользовался год назад, когда сменился заголовок Server.

Типы отпечатков, которыми ты реально пользуешься

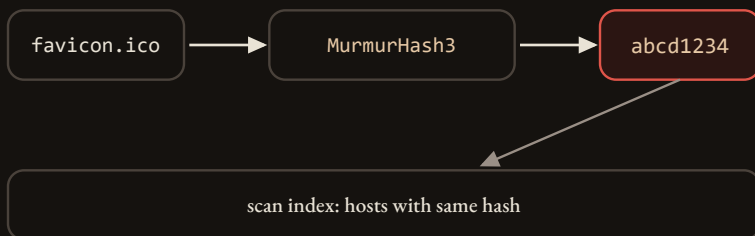
Названия меняются; формы ниже переживают свои инструменты. Учись, чем каждый отпечаток *является*, до того, как учишься, где его смотреть.

- **Хеш фавикона.** Файл иконки сайта, прогоняемый через MurmurHash3 и кодируемый в короткое знаковое целое. Каждый сервер, отдающий байт-идентичный фавикон, считается в тот же хеш — почти идеальный сигнал связи оператора.
- **JARM.** 62-символьный отпечаток поведения TLS-хендшейка сервера — как сервер отвечает, когда клиент предлагает разные опции хендшейка. Идентичные JARM значат идентичную конфигурацию TLS-стека. Распространённые JARM (дефолтный nginx, дефолтный Apache) не значат ничего; редкий JARM близок к подписи.
- **JA3 / JA4 / JA4S.** JA3 — более старый клиентский отпечаток TLS (хендшейк, отправляемый клиентом). JA4 — его преемник эпохи 2023 с более чистыми свойствами и лучшей устойчивостью к тривиальной рандомизации. JA4S — серверный вариант, и в отличие от JA3 JA4S напрямую полезен для OSINT, потому что твоя цель

обычно сервер. Там, где сканирующий индекс поддерживает, предпочитай JA4S старому JARM для свежесобранных стеков; JARM всё ещё рабочая лошадка для огромного бэк-каталога хостов, уже отпечатанных им. Названия меняются; *форма* — «поведение TLS этого сервера, сжатое в короткую строку» — то, что несёт.

- **HTTP-заголовок Server.** Короткая строка, которой веб-сервер представляется. Часто врёт или ничего не говорит (nginx сам по себе бесполезен), но редкое кастомное значение — `werkzeug/2.0.1 Python/3.9.6` на кустарной админ-панели — жёстко кластеризует серверы оператора.
- **HTML title / хеш meta.** `<title>` посадочной страницы или хеш блока `<meta>`. Там, где неправильно настроенные status-страницы утекают — сканер видит `Welcome to nginx!` рядом с забытым `[Redacted] Panel v1.03` на status-эндпоинте, который оператор собирался закрыть фаерволом, и title становится подписью.
- **Наборы X-заголовков.** Кастомные HTTP-заголовки с префиксом `X-`, которые нестандартный софт добавляет к своим ответам. Конкретная комбинация в конкретном порядке часто уникальна для одной сборки стека одного оператора.

FAVICON HASH FINGERPRINT



one file, one hash, many hosts → one operator

Один файл фавикона, хешированный `MurmurHash3`, становится одной короткой строкой; сканирующий индекс ищет каждый хост видимого интернета на точно эту строку и возвращает весь список собственности оператора — тот же трюк, что в главе 7, но на масштабе интернета.

Метод, шаг за шагом

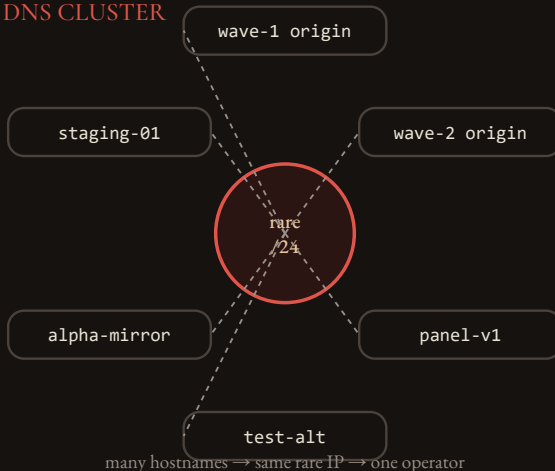
Шаг 1 — anchor домена или IP. Из глав 5 и 6 у тебя есть базовый домен, его внешне-сертифицированные имена хостов и исторические имена хостов, которые больше не резолвятся. Каждый anchor умножает рDNS-поверхность.

Шаг 2 — заberi рDNS-таймлайн. Для каждого имени хоста попроси рDNS-сервис каждую историческую A, AAAA, CNAME и NS, которую он видел. Отметь каждый переход — день, когда A-запись сменилась, день, когда переехали серверы имён, день, когда появилась CNAME. Каждый переход — датируемый момент.

Шаг 3 — обрати рDNS по каждому историческому IP. Возьми IP из шага 2 по одному и задай рDNS обратный вопрос: какие *другие* имена хостов указывали на этот IP в то же окно? На гигантском шаред-хосте получишь тысячи несвязанных арендаторов — шум. На маленьком, редком IP, куда во время аренды оператора указывала горстка имён хостов, со-арендаторы почти всегда — другая собственность того же оператора.

Шаг 4 — запроси сканирующие индексы по текущим и историческим IP. Забери запись сканирующего индекса на каждый: открытые порты, баннеры, TLS-сертификаты, JARM, HTTP-заголовки, HTML-title, фавиконки. Читай холодно. Отметь всё необычное — странную строку Server, не-дефолтный порт, отдающий HTTP, статус-страницу, которая не должна быть публичной, title, читающийся как приватная админ-панель.

PASSIVE DNS CLUSTER



Одно целевое имя хоста наверху; pDNS разворачивает исторические IP вниз по одной оси, а обратный pDNS по каждому редкому IP расфасовывает кластер со-арендованных имён хостов вбок. Запись сканирующего индекса на каждый IP свисает с него маленьким стеком отпечатков. Кластер — не один сигнал; это решётка.

Шаг 5 — отпечатай TLS-стек оператора. Возьми JARM сервера оператора и попроси сканирующий индекс каждый другой хост с тем же JARM. JARM, разделяемый двенадцатью миллионами хостов, значит «дефолтный nginx» — бесполезно. JARM, разделяемый 47 хостами, — кандидат-кластер, каждый хост — зацепка, подлежащая corroborации соседством pDNS и другими отпечатками.

Попробуй (2026). Возьми известный публичный сервис — большой новостной сайт — и прочитай его

JARM в сканирующем индексе. Посчитай, сколько других хостов его разделяют. Будет шесть-семь знаков: шумовой пол для этого JARM. Теперь то же для маленького self-hosted сервиса. Число будет намного меньше — редкость и делает JARM диагностическим. Конкретное имя сканирующего индекса в любом руководстве к моменту чтения могло умереть; упражнение (посчитать JARM, посчитать совпадения, почувствовать редкость) — нет.

Шаг 6 — хешируй фавикон и ищи в сканирующем индексе. Та же техника, что в главе 7, но вместо grep по нескольким кандидатам ты просишь индекс каждый хост с этим хешем. Редкий хеш, возвращающий три IP у трёх разных провайдеров, — кластер, который иначе не нашёл бы. Точный рецепт в Python REPL — предполагаемо гниёт, оговаривайся соответственно — `mmh3.hash(base64.encodebytes(open('favicon.ico','rb').read()))`; заметь, что `encodebytes` вставляет перевод строки каждые 76 символов и это намеренно, большинство сканирующих индексов этого ждут. В сегодняшнем запросе сканирующего индекса это выглядит как `http.favicon.hash:-1246753918` (синтаксис Shodan, знаковый 32-битный int). Разные индексы используют разные знаковые конвенции и разные ключи запроса; *форма* — «дай мне каждый хост, отдающий точно

этот фавикон» — то, что несёт.

Шаг 7 — кластеризуй результаты. Кандидат-родственный хост из шага 5 — один сигнал. Если тот же хост всплывает и в обратной pDNS-истории шага 3 на одном из редких IP оператора — это два сигнала, выстраивающихся вместе. Если его фавикон из шага 6 тоже совпадает — три. Лестница из главы 7 правит: независимые сигналы, соглашающиеся, зарабатывают *сильный*, когда их трудно объяснить любой соперничающей гипотезой. Согласия отпечатков почти всегда независимы от согласий pDNS — JARM измерил сканер, pDNS-запись залогировал резолвер — так что складываются чисто.

Шаг 8 — ранжируй честно. Кластеры отпечатков соблазнительны. Распространённый JARM совпадает с миллионами nginx-инсталляций и не доказывает ничего; дефолтный фавикон WordPress совпадает с миллионами блогов и не доказывает ничего. Редкий JARM, разделяемый 47 хостами, — золото; редкий фавикон, разделяемый тремя, близок к самоссылке. Прежде чем считать любое согласие отпечатков сигналом, спрашивай, сколько хостов во всём интернете его разделяют. Миллионы — сигнала нет вообще. Десятки — стоит того, что стоит глава работы.

Разобранный кейс, с тупиками

Команда threat-intelligence платёжной компании принесла две фишинг-волны из одного месяца. Волна один целилась в их розничных клиентов фальшивой страницей логина; волна два шла за клиентами бизнес-банкинга косметически другим вариантом набора. Разные домены, разные регистраторы, разные дизайны. Их вопрос был узкий: один оператор за обеими волнами или два? Кейс вымышленный, метод настоящий.

WHOIS тупик. Обе волны использовали домены, зарегистрированные через дисконт-регистраторов с приватностью с первого дня, разные регистраторы каждый раз. Исторический WHOIS вернул ничего старше текущей регистрации — оба домена свежие, созданы за недели до волны. Глава 5 не дала ничего.

Cloudflare тупик. Обе волны сидели за Cloudflare. Reverse-IP на edge Cloudflare возвращает сотни тысяч несвязанных арендаторов. Полностью фронтировано, пивота нет.

Certificate transparency тупик. Оба домена держали чистые сертификаты Let's Encrypt, выпущенные в момент, когда фишинг-сайт пошёл. Ни один сертификат не имел общего SAN с другим; ни общего wildcard, ни общего тенанта.

Mail-record тупик. У обоих TXT-записи для дженерик Google Workspace tenants и MX-записи на Google, с разными tenant-идентификаторами. Никаких SPF-квирков, связывающих их.

Четыре тупика. Примерно в этой точке новичок отчитывается недостаточным сигналом и останавливается. В этом случае здесь фактическая работа только началась.

Пивот. Я забрал pDNS-таймлайн для обоих имён хостов. Оба показали edge-IP Cloudflare с дня, когда имя хоста впервые разрешилось, и ничего больше — кроме того что для двухчасового окна в день, когда домен волны два вышел живым, до того как оператор закончил ставить Cloudflare перед ним, имя хоста ненадолго разрешилось *напрямую* в origin IP на маленьком европейском VPS-провайдере. И неделей раньше, на волне один, идентичная мисконфигурация утекла прямую резолюцию origin — на другой IP в том же /24 того же маленького провайдера.


```
pDNS timeline, both waves
-----
wave-1 paylink-secure-verify.top
      2026-05-14 09:12 A 203.0.113.44
                        (EU VPS, small)
      2026-05-14 10:47 A 104.21.x.x
                        (Cloudflare edge)
      2026-05-14 10:47 ... stays Cloudflare
wave-2 business-pay-portal.top
      2026-05-30 14:03 A 203.0.113.61
                        (EU VPS, same /24)
      2026-05-30 15:58 A 172.67.x.x
                        (Cloudflare edge)
-----
two brief origin-leaks, same /24,
weeks apart
```

Две мисконфигурации Cloudflare, недели порознь, обе утёкшие origin в соседние адреса у одного маленького провайдера.

Оба origin IP были соседними адресами в /24, принадлежащем маленькому европейскому реселлеру, у которого всего пара тысяч клиентов. Не совпадение; оператор забыл фронттировать свой настоящий хост на два часа в два разных дня.

Отпечатки на origin IP. Я запросил сканирующий индекс по обоим. Оба крутили один и тот же nginx на одном и том же не-стандартном порту, у обоих один JARM. Этот JARM был крайне редкий — индекс показывал его ровно на 47 других хостах во всём видимом интернете. Не миллионы. Сорок семь.


```
scan-index summary, JARM cluster
-----
JARM 2ad2ad0002ad2ad0002ad2ad2ad...
matches 49 hosts total (both origins
        plus 47 others)
common? no — near-zero baseline
common characteristics:
- nginx 1.21.4 on port 8443
- self-signed cert, CN=proxy
- HTTP header set:
    Server: nginx
    X-Frame-Options: DENY
    X-Panel-Build: 1.03
- favicon hash 1173925469
-----
X-Panel-Build is not a standard header
```

Кустарный конфиг reverse-проxy на редком порту, с кастомным заголовком и характерным фавиконом — отпечаток стека одного оператора.

Я прочитал запись сканирующего индекса на каждый из 47 хостов по одному. Два отдавали байт-идентичный фавикон, который отдавали фишинг-страницы волны один и волны два, хеш 1173925469. Один тихим воскресеньем отдавал дефолтную посадочную Welcome to nginx! — и рядом публично-достижимый status-эндпоинт, чей HTML-title читался [Redacted] Panel v1.03. Этот title совпал со строкой X-Panel-Build из JARM-кластера и совпал с приватной панелью фишинг-кита, рекламируемой на известном криминальном форуме ранее в том же году.

Складываем честно. Первое: pDNS origin-утечка на одном и том же редком /24 для обеих волн — умеренный сам по себе, потому что общий маленький VPS необычен, но не окончателен. Второе: JARM, разделяемый только 47 хостами, особенно с совпадающим заголовком X-Panel-Build — умеренный-к-сильному. Третье: хеш фавикона, разделяемый между двумя фишинг-страницами и двумя хостами JARM-кластера — независимый, сильный. Четвёртое: status-страница, чей title раскрыл точную версию панели и совпал с названным приватным фишинг-китом, — независимый, почти диагностический сам по себе. Четыре независимых сигнала, четыре разных метода сбора, все согласны. Я отчитал сильный на уровне кластера-оператора: один оператор за обеими волнами, крутит тот же приватный кит, на инфраструктуре, которую ненадолго не сумел спрятать, дважды.

Клиент скормил это в свой внутренний fraud-граф. Я отметил оговорку, которую всегда включаю: кластеры отпечатков на сетевом уровне идентифицируют *инструменты и инфраструктуру*, а не человека. Двое коллег, делящих кит и хостинг-привычку, выглядят на JARM-уровне так же, как один человек. Глава 9 закрывает этот разрыв.

Второй кейс: тот, который не закрывается

Другой кейс, та же неделя. Хорошо оперируемый противник, низкообъёмная collection-операция. Фронтирован большим CDN и остаётся фронтирован; никаких окон утечки origin в pDNS за год истории. TLS терминируется на CDN, так что JARM, который я видел, был CDN'овский, разделяемый миллионами хостов. Фавикон — простой дефолтный. Заголовки дженерик. Посадочные страницы не несли кастомных title.

Каждый отпечаток отсутствовал или был слишком распространён, чтобы что-то доказать. Обратный pDNS по историческим IP возвращал плотные кластеры несвязанных арендаторов на шаред-хостах. Этот оператор сделал всё правильно на сетевом уровне, и кластеризовать было нечего.

Честный отчёт, один абзац: *атрибуция невозможна из одних сетевых сигналов. Инфраструктурный опрес цели грамотен; ничто в pDNS и сканирующих индексах не поднимается над шумовым полом. Другой слой — контент-поведение, человеческое ремесло, паттерны времени публикуемого материала — следующее место для взгляда. Не каждый метод выплачивает. Сказать это честно — часть метода.*

Про покупку данных, которые не обязательно было покупать

Коммерческие рDNS и сканирующие сервисы легально купить, и для серьёзной инфраструктурной работы ты в итоге купишь как минимум один. Понимай, откуда пришли данные, до того как маршрутизируешь работу через них.

Пассивный DNS — живая проблема согласия. Данные агрегированы из потоков логов публичных резолверов — Google Public DNS, Cloudflare 1.1.1.1, университетских и корпоративных резолверов и длинного хвоста мелких коллекторов. Некоторые из этих резолверов публикуют простую opt-in privacy-политику: «ваши запросы могут разделяться с исследователями безопасности». Многие нет. Когда ты запрашиваешь рDNS-индекс на «каждый хост, куда когда-либо резолвился `example.com`», ты читаешь базу, построенную частью из DNS-запросов обычных пользователей — запросов, о которых они не знали, что их сохраняют, продают и делают поисковыми годами позже. Это некомфортная почва. Она не становится комфортнее от того, что имя домена в запросе публично; *сам факт запроса*, привязанный к резолверу и метке времени, — поведенческие данные о ком-то. Покупка не отмывает.

Данные сканирующего индекса менее спорны. Видимый интернет сканируется по праву видимости — ты читаешь то, чем собственный сервер цели решил ответить, — но условия

лицензий всё равно варьируются, и некоторые сканирующие индексы перераспределяют производные отпечатки хостов, о каталогизации которых оператор не догадался бы.

Если работаешь в регулируемой среде — EU-facing корпоративный DD, журналистика с юристом, работа по защите, любое состязательное дело, — прочитай заявление вендора об источниках данных полностью, спроси конкретно про согласие и правовое основание на стороне рDNS (не на стороне сканирующего индекса; это разные вопросы), получи ответ письменно и храни в кейс-файле рядом с запросами, которые ты выполнил. Спроси юриста своей организации, где линия в твоей юрисдикции, *до* того как маршрутизируешь клиентский заказ через платный рDNS API — не после. Сервис легально купить; защитимо ли использование в твоей юрисдикции и защитим ли источник перед судом — на тебе.

Безопасное упражнение

Возьми домен, которым лично владеешь, — хобби-сайт, запасной проект, старый блог. Забери свободную рDNS-историю по нему. Прочитай трейл каждого IP, куда он когда-либо резолвился, каждого сервера имён, который использовал, каждой миграции между хостами, о которой забыл. Если домен достаточно старый, трейл длиннее, чем помнишь. Большинство удивлены, насколько много собственной хостинговой биографии видно всякому, кто додумается посмотреть.

Итог

- Интернет держит два вида памяти: пассивный DNS, time-history DNS-резолуций, залогированных публичными резолверами, и сканирующие индексы, корпус отпечатков видимого интернета из регулярных сканов.
- рDNS даёт исторические резолуции, обратную историю по IP, окна миграций, обнаружение кластеров по редким IP и призрачные имена хостов, которые разрезолвились раз и не были продлены.
- рDNS молчит по приватно-рекурсивным установкам и DoH/DoT-стекам, которые никогда не касались логирующего резолвера; коммерческое покрытие глубже бесплатного.

- Отпечатки, которыми ты реально пользуешься: хеш favicona, JARM (и JA4S, где индекс поддерживает), HTTP-заголовок Server, хеш HTML-title или meta и редкие наборы X--заголовков. JA3 — более старый клиентский кузен, в основном для защитников.
- Кластеры отпечатков соблазнительны; распространённый JARM не доказывает ничего, редкий JARM — подпись. Сигнал — редкость, а не совпадение.
- Читай лицензирование и провенанс любых pDNS- или сканирующих данных, которые покупаешь, — правовое основание источника на тебе, не на вендоре.
- Атрибуция сетевого уровня идентифицирует кластеры инструментов оператора, а не людей; некоторые цели делают этот слой правильно и не дают тебе ничего.

Глава 9 — капстоун: один кейс, стягивающий каждый слой этой книги вместе, от кольца вокруг точки через людей, домены, сертификаты, содержимое, сложение сигналов и всё, что в этой главе, в один проход от стартового имени к защищённой находке.



ГЛАВА ДЕВЯТАЯ

Полноценная жёсткая цель

Один кейс, все техники, честные границы.

Всё в этом томе шло по одному инструменту за раз. Кеш. Удалённый аккаунт. Фотография. DNS-запись. Техники в чистом свете, одна за другой — так, как это должна подавать книга.

Настоящая работа по жёстким целям приходит не в таком порядке. Она приходит комом: шесть доменов и псевдоним, и редакция, которая спрашивает, безопасно ли называть человека по имени. Техники достаются из сумки в том порядке, в каком их требует кейс, а не по оглавлению.

Эта глава — один кейс, пройденный от начала и до конца. Я буду использовать каждый слой из глав с первой по восьмую и не буду останавливаться, чтобы переобучать. Если тебе надо освежить, что такое СТ-логи или пассивный DNS, ранние главы никуда не делись. Здесь ты увидишь *форму* расследования жёсткой цели, со всеми тупиками, и то, как оно зарабатывает себе место на лестнице.

Я покажу тебе то, что не сработало, так же аккуратно, как и то, что сработало. Чистая версия этого кейса уместилась бы на салфетке. Честная версия — вот почему у нас есть глава.

Бриф

Балтийская исследовательская редакция четыре месяца ходит вокруг одной истории. В преддверии местных избирательных циклов 2024 и 2025 годов в Латвии и Эстонии сеть небольших правдоподобно названных сайтов «общественных новостей» — сельских вестников, районных дневников, один из которых публикует только протоколы школьных советов — стабильно всплывает с конкретным набором нарративов в конкретном темпе. Каждый сайт подаёт себя как независимый. У каждого в подвале — почтовый ящик до востребования. Каждый написан на компетентно звучащем местном диалекте. Сеть в нескольких старых репортёрских блокнотах публично приписывается одному оператору, известному только под псевдонимом «Torrey».

Редактор редакции осторожна. Она не пустит материал, называющий Torrey, пока атрибуция не дойдёт как минимум до сильной ступени — три независимых, несхлопываемых сигнала, без самоссылки, — и она хочет, чтобы тупики были перечислены рядом с находками, тем же кеглем, чтобы её юрист мог прочитать всё целиком.

Наш бриф от неё, в одном письме: *Torrey — это один человек, одна команда или мираж, и если человек, то кто?*

Письменный отчёт по атрибуции в конце, честно ранжированный, со всем, чего мы не делали, тоже записанным.

Это весь запрос. Мы не должны интервьюировать, связываться или провоцировать цель. Мы не должны логиниться куда-либо от чьего-либо имени. Мы здесь, чтобы аккуратно читать открытую сеть и в конце сказать одну жёсткую правдивую вещь.

Рамки, в одну строку

Только открытые источники. Никаких контактов с целью, никаких контактов ни с кем рядом с целью, никакого зондирования любого хоста дальше чтения записей, которые интернет и так открывает любому желающему. Каждый экран, на который мы смотрим, мы архивируем; каждое утверждение, которое мы делаем, ложится на лестницу с доказательством рядом.

Якорь

Редакция передаёт нам шесть доменов. Это публичные входные точки сети — сайты, с которыми Torgue публично связывался в более ранних блокнотах, и ни один из них не оспаривается. Отсюда мы начинаем и, что касается рамок, отсюда нам разрешено начинать.

- kalnina-vesti.lv — деревня Калныня, «общественные новости»
- riga-vidzemes-nedela.lv — еженедельник внутреннего пригорода Риги
- daugavgriva-hronika.lv — хроника портового района
- tallinn-mustamae-teataja.ee — репортёр района Мустамяэ
- tartu-annelinn-uudised.ee — новости квартала Аннелинн
- parnu-raekula-teataja.ee — еженедельник района Пярну. (В отображаемой форме — эстонские ä/ü; в каждом DNS-или СТ-запросе домен резолвится как xn--prnu-raekla-teataja-gwb62c.ee — форма ACE/punycode. В книге для читаемости используется отображаемая форма; в реальном запросе — ACE-форма.)

Две категории: четыре латвийских, два эстонских. Все шесть зарегистрированы между 2019 и 2022 годами, согласно поверхностному WHOIS-ответу, который может вытащить

кто угодно. Каждый публикует по буднему графику. У каждого — шапка без имени редактора. Каждый в своём подвале говорит, что он *независимый, поддерживается сообществом и внепартийный*.

Мы записываем эти шесть имён в кейс-заметку с тремя колонками — *утверждение, доказательство, ступень* — и ничего не заходит в отчёт, пока не заработает ступень.

Слой 1 — Поверхность не говорит ничего

Первый проход — это тот проход, который компетентный читатель сделал бы за вечер. И первый проход не говорит почти ничего.

Живой WHOIS по всем шести возвращает ту же форму: регистрант скрыт, админ скрыт, тех скрыт, приватность-прокси стоит впереди. Две .lv-записи идут через один латвийский приватность-прокси; две другие — через другой. Две .ee-записи идут через эстонский сервис. Разные прокси, никакой общей строки регистранта, никакого общего адреса.


```
whois — kalnina-vesti.lv (live)
-----
registrant: [privacy-proxy]
admin:      [privacy-proxy]
tech:       [privacy-proxy]
created:    2020-04-14
updated:    2023-11-02
name-server: ns1.cloudflare.com
name-server: ns2.cloudflare.com
-----
```

живой публичный WHOIS, скрыт в источнике

Контент аккуратный. Он не является очевидно партийным и не является очевидно скоординированным. Двухмесячные первые полосы читаются как малогородская журналистика — дорожные работы, школьные праздники, мягкая передовица о муниципальной прозрачности. Нарративы, за которые беспокоится редакция, там есть, но посеяны легко — абзацем на третьей статье, раз в пару недель.

В каждом подвале указана одна и та же форма контакта: почтовый ящик, hello@ на собственном домене сайта, тэнант Google Workspace за почтовым сервером. Почтовые ящики — разные адреса в разных городах. Ничто не рифмуется.

Каждый сайт сидит за Cloudflare. Каждый сертификат — Let's Encrypt, ротация 90 дней, wildcard там, где есть.

Никакие два не делят IP на фронте. Никакие два не делят почтовый сервер. DNS на первый взгляд выглядит так, будто шесть несвязанных людей сделали шесть несвязанных сайтов.

Такое настроение. Цель прочитала книжку вроде этой. Ничто на поверхности ни в чём не признаётся. А значит, поверхность — не то место, где стоит проводить день.

Слой 2 — Инфраструктурные отпечатки

Главы седьмая и восьмая — это про то, как забраться за отполированную поверхность. Мы начинаем тянуть.

Первое, что стоит проверить, — это сама *страница*. Фронт Cloudflare не может скрыть то, что *отдаёт* origin — фавикон, аналитические теги, маркеры фреймворков, форму HTML. Мы забираем шесть первых полос и хешируем каждый фавикон.

```
favicon hash — all six network domains
-----
kalnina-vesti.lv           -1246753918
riga-vidzemes-nedela.lv    -1246753918
daugavgriva-hronika.lv     -1246753918
tallinn-mustamae-tea.ee     -1246753918
tartu-annelinn-uud.ee       -1246753918
parnu-raekula-tea.ee        -1246753918
-----
```

tmh3 от favicon.ico, побайтово идентичны

Шесть независимых общественных сайтов не отдают случайно один и тот же фавикон байт в байт. Это один сигнал. Этого мало — шаблонная контора могла раздать один и тот же ассет шести клиентам, — но это твёрдое начало.

Смотрим исходник. Все шесть несут один и тот же GA4 measurement ID: **G-9K2D4X7QH1**. GA4-ID привязаны к арендатору; они принадлежат одной Google Analytics-собственности, контролируемой одним Google-аккаунтом. Шесть «независимых» сайтов, отчитывающихся в одну аналитическую панель, — второй сигнал, и от этого уже труднее отмахнуться. Шаблонная контора делится CSS. Она не делится аналитическим арендатором клиента.

Один из шести — **kalnina-vesti.lv** — несёт файл **humans.txt** в корне, который, похоже, оставили по неосторожности. Файл пустой, кроме одной строки-комментария: **# built by МО, 2020**. Два инициала. Мы их отмечаем и идём дальше — сами по себе инициалы пока ничего не зарабатывают, но скоро они будут иметь значение.

Теперь заходим за Cloudflare. Пассивный DNS по шести доменам показывает ожидаемую историю A-записей Cloudflare для большинства недель. Но на одних выходных в ноябре 2023 года двое из шести — **daugavgriva-hronika.lv** и **rārnū-raekūla-teataja.ee** — на короткое время резолвились в не-Cloudflare-адрес, небольшой европейский VPS-провайдер, автономная система в диапазоне AS200000, прежде чем в понедельник переключиться обратно. Кто-то ротировал сертификат или перезапустил прокси, и на сорок восемь часов origin остался открытым.

Мы вытаскиваем записи скан-индекса по этому IP origin за те выходные. Оба домена обслуживались с одного и того же хоста, на одном и том же порту, с одним и тем же TLS-стеком. Отпечаток JARM совпадает до байта.

```
scan-index — weekend of 2023-11-04
-----
host    [origin IP redacted]
443/tcp
  jarm   2ad2ad0002ad2ad00042d42d0000..
  cert   CN=daugavgriva-hronika.lv
  cert   CN=xn--prnu-raekla-teataja-gwb62c.ee
  server nginx/1.24.0
-----
```

сторонний интернет-скан-индекс, исторический

Два из шести сайтов сети, физически колоцированные, на одном небольшом VPS. В сумме с фавиконом и тенантом GA4 у нас есть три по-настоящему независимых сигнала, указывающих на одного оператора за сетью. Атрибуция *кластера оператора* теперь стоит на сильной. Torrey — не мираж. Torrey — это одна рука. Чья именно, мы пока не знаем.

Слой 3 — Удалённая комната

Следующий рывок приходит из того, что Torrey сделал за годы до того, как Torrey появился.

GA4-ID, который мы подняли, — G-9K2D4X7QH1 — жёсткий идентификатор. Мы ищем его по публичному коду и корпусам страниц, и он всплывает на седьмом сайте:

baltika-kaleidoscope.eu. Блог о еде и путешествиях. Ничего явно политического. Другая тема, другой визуальный шаблон, другой язык подвала.

Текущая версия блога — без авторской подписи. Но Wayback (глава первая) захватил страницу About одиннадцать раз между 2019 и 2024 годами. Шесть из этих захватов — всё до июня 2022 — содержат подпись: Микелис Озолиньш, житель Юрмалы, контакт mik.ozolins@yandex.ru. Захват в июне 2022 — первый, где подпись и email стёрты.

```
web.archive.org - /about (2021-08-12)
-----
"About the author"
"Mikelis Ozoliņš - Jurmala-based writer
on food, travel and coastal culture.
Reach me: mik.ozolins@yandex.ru"
-----
```

архивированная страница, захвачена 2021-08-12

Кто-то стёр подпись в середине 2022 года — это примерно тогда, когда сеть Torrey начала публиковаться в темпе, и примерно тогда, когда компетентный оператор снимал бы старые артефакты идентичности с поверхностной сети.

С кешем одним можно спорить — Wayback-захват это один источник. Поэтому мы ищем цитирования в экосистеме (снова глава первая). Небольшой латвийский агрегатор местных новостей в обзорной статье 2020 года о ресторанах

Курземского региона цитирует целый абзац из поста на baltika-kaleidoscope.eu с атрибуцией: *«как пишет Микелис Озолиньш в своём дневнике лета, [цитируемый абзац]»*.

Подпись и город. Независимый сайт. Не зеркало.

Это уже территория второй главы — восстановление удалённой идентичности из кольца вокруг неё.

FOAF-проход по пре-2022-About-странице поднимает ещё два подтверждения: пост «друга блога» от эстонского пишущего о еде в 2021 году, обращающийся к «Микелису» по имени и благодарящий его за рекомендацию юрмальского ресторана, и ветку комментариев на конкурирующем латвийском блоге, где «Микелис О.» появляется в подписи под комментарием, отправленным с того же yandex.ru-адреса, видного на странице About.

Итак, человек существует: Микелис Озолиньш, Юрмала, фуд-блогер, активен в 2019–2022, затем стёрт. И GA4-тенант этого человека, до сих пор живой и не переименованный, теперь измеряет сеть Torrey. Это не доказательство — это очень сильный пивот. Общий аналитический тенант между стёртым личным блогом и сетью анонимных политических сайтов — это голос двух источников за одного оператора позади обоих.

Слой 4 — Фотография

Теперь идём туда, где живут третья и четвёртая главы.

Один из постов Микелиса 2021 года на baltika-kaleidoscope.eu — чисто захваченный в трёх Wayback-снимках — несёт фотографию без подписи и без видимых EXIF. Композиция странная: полоса тротуара, край низкого белого здания в углу кадра, кусок бледного зимнего неба и один пластиковый шезлонг на явно гостиничном балконе. Снимок читается как пост «я где-то», а не как еда-фото — поэтому его стоит хронологизировать: он *датирует* модель перемещений Микелиса.

Сначала геолокация. Видно в кадре:

- Фрагмент вывески через улицу, кириллицей, видны только три буквы: ...рор...
- Другая вывеска, дальше, в латинском гостинично-брендовом шрифте, частично: ...ISON
- Специфический сварной узор балконного ограждения — узкие вертикали через каждые ~90 мм, нетипичный шаг для европейских гостиничных построек
- Угол солнца и тень балкона сверху ставят фасад здания примерно на юго-юго-восток

Кириллица на уличных указателях плюс фрагмент бренда Radisson плюс архитектура балкона — достаточно небольшое пересечение, чтобы стоило свериться со шорт-листом. Латиноалфавитные гостиничные бренды с объектами в странах кириллицы: Беларусь, Россия, части

Центральной Азии. Зимний свет, пальмово-соседствующие насаждения, видные вдоль тротуара, и специфический сварной узор балкона сужают дальше. Street View вдоль Курортного проспекта в Сочи показывает гостиницу с ровно таким узором балкона и с линией видимости на указатель, которая разрешает фрагмент ...рор... в уличный указатель Курортный через дорогу.

Мы не утверждаем больше, чем видим. Геолокация: почти наверняка конкретная гостиница на Курортном проспекте, Сочи. Уверенность: сильная, с остатком, что вторая гостиница бренда Radisson где-то ещё на черноморском побережье могла бы нести похожую спецификацию балкона. Остаток назван, а не отброшен.

Теперь дата. Дисциплина четвёртой главы. Угол солнца на этом юго-юго-восточном фасаде, при широте Сочи, укладывается в утро поздней зимы — примерно с конца января до конца февраля. Видно на крыше через дорогу — тонкий лист инея, доживший в тени, что в Сочи ставит нас в холодную половину этого окна. И на автобусной остановке через улицу, на краю кадра, фрагмент афиши концерта разборчив настолько, чтобы прочитать «Зимний джаз» и двузначное число. Этот фестиваль, по публичным архивам событий, шёл в конкретные даты в феврале 2021 года.

Итак: Микелис, в феврале 2021, был в Сочи. Это само по себе не находка по атрибуции. Это *паттерн-факт* —

юрмальский фуд-блогер съездил на российский черноморский курорт в межсезонье, — и редакция позже им воспользуется. Для нашей главы это хронологизированный якорь: удалённая идентичность имела физическое, датируемое присутствие.

Слой 5 — Исторический WHOIS

Теперь глава пятая — и голос, который связывает две стороны кейса вместе.

Живой WHOIS на baltika-kaleidoscope.eu скрыт. Исторический WHOIS по тому же домену, из до-GDPR архива с датой 2017 год, возвращает чистый email регистранта: ozolins.m@inbox.lv. Другой email, не тот mik.ozolins@yandex.ru, видимый на странице About, — но тот же человек, на латвийском почтовом провайдере, в правдоподобной форме «фамилия первой».

Одна эта запись работу в одиночку не делает. Работу делает то, что всплывает, когда мы вытягиваем исторический WHOIS по доменам *сетти Torrey* — конкретно по тем двум, которые на короткое время слили origin в Слое 2, daugavgriva-hronika.lv и parnu-raekula-teataja.ee. Оба были изначально зарегистрированы в 2017, за три года до того, как несли хотя бы одну статью, под тем же ozolins.m@inbox.lv. Обе записи были снова закрыты за приватность-прокси в 2018, когда реестры .lv и .ee начали

читать GDPR-подобные запросы на скрытие.

```
historical whois (pre-GDPR archive)
-----
domain    daugavgriva-hronika.lv
created   2017-05-22
registrant-email  ozolins.m@inbox.lv
registrant-name    M. Ozolins
registrant-city    Jurmala
-----
```

архивный снимок реестра, 2017

Та же форма записи появляется для pärnu-raeküla-teataja.ee, датированной тремя месяцами позже. Два из шести доменов сети Torrey, в их пре-скрытой форме, зарегистрированы на личный email Микелиса Озолиньша, с юрмальского адреса, за три года до того, как сеть начала публиковаться.

Это не один голос. Это две независимые записи регистрации доменов, в двух разных национальных реестрах, согласующиеся друг с другом и с пре-скрытой записью самого фуд-блога. Пивот очень жёсткий. Он сам по себе не доказывает, что Микелис управляет сетью *сейчас*, — домен может тихо сменить владельца, и WHOIS 2017 года не является утверждением о 2024. Но в сочетании с совпадением GA4-тенанта и отпечатком кластера оператора это существенная третья верёвка.

Слой 6 — СТ и забытый staging

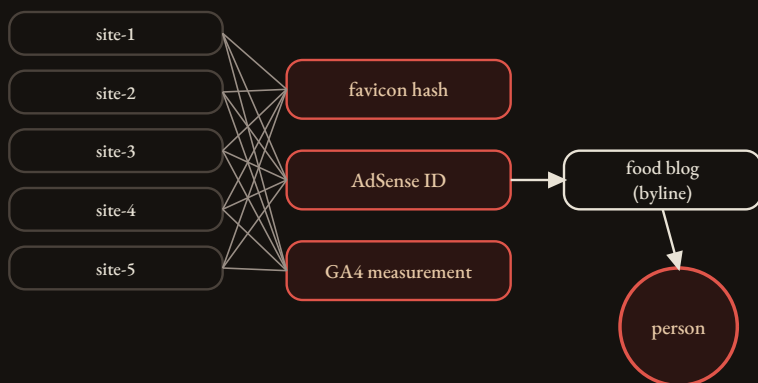
Глава шестая. Прозрачность сертификатов помнит то, что оператор забыл спрятать.

Мы вытягиваем СТ по шести живым доменам Torrey. Ничего экзотического — сертификаты Let's Encrypt на apex и www, ротация 90 дней, никаких wildcard, сливающих поддомены. Чисто.

Вытягиваем СТ по baltika-kaleidoscope.eu. И вот тут начинают говорить *привычки* оператора. В августе 2020 СТ фиксирует выдачу предсертификата для dev.baltika-kaleidoscope.eu — поддомен разработки, предположительно давно снятый. Паттерн стандартный: префикс dev.. Интереснее *суффиксный* паттерн на втором предсертификате две недели спустя: dev-uat.baltika-kaleidoscope.eu. Суффикс -uat — это личная конвенция. Не неправильно, не редко в абстрактном смысле, но привычка *конкретного* человека.

Проверяем СТ-историю доменов сети на тот же отпечаток. И на одном из них — tartu-annelinn-uudised.ee — СТ-запись от января 2022 показывает предсертификат для dev-uat.tartu-annelinn-uudised.ee. Тот же префикс. Тот же суффикс. Та же конвенция, на сайте, чей поверхностный WHOIS не называет никого.

INFRA → PERSON



operator fingerprints link the anonymous → the named

Шесть доменов сети Torrey сверху, baltika-kaleidoscope.eu справа сбоку, и четыре независимых моста, пересекающих между ними: общий GA4-тенант через все семь; два origin Torrey, колоцированные на одном VPS по JARM; два домена Torrey, делящие пре-2018 email регистранта с фуд-блогом; и привычка именования dev-iat., повторяющаяся между фуд-блогом и одним сайтом сети.

Отпечаток привычки оператора сам по себе мягкий. Он становится жёстким, когда сидит внутри кейса, где три других моста уже несут вес. Сам по себе он не двигает ничего; он двигает ступень лестницы на один аккуратный щелчок, когда всё остальное уже на месте.

Слой 7 — Кросс-платформенное замыкание

Нам не нужен второй том, чтобы сделать атрибуцию. У нас достаточно. Но редакция хочет знать, что человек за email — это человек на отмеченной фотографии, *лицо на имени*.

ozolins.m@inbox.lv — пивот в стиле второго тома. Реверс этого email по публичной сети, с помощью того же кросс-платформенного набора инструментов, которым пользуется любой в этом ремесле, возвращает три хита, переживших верификацию:

- Спящий Twitter/X-аккаунт, последняя активность 2019, с био со ссылкой на baltika-kaleidoscope.eu и отображаемым именем «М. Ozoliņš».
- Профиль на латвийском бизнес-каталоге — самопубликуемое объявление о фрилансерской копирайтинг-услуге, контакт ozolins.m@inbox.lv, город Юрмала, имя Микелис.
- Десятилетней давности личный блог на латвийской блог-платформе, активный 2010–2013, с несколькими автопортретами.

Блог с автопортретами — это то, что аккуратно выводит лицо на лестницу. На публичной Facebook-странице юрмальской торговой палаты фотография 2018 года с мероприятия малого бизнеса подписана тремя именами, одно из которых «Микелис Озолиньш». Самая сильная

связь между этой фотографией и личным email — это био в Twitter/X: спящий аккаунт, чьё био явно ссылается на baltika-kaleidoscope.eu и чьё отображаемое имя совпадает с «M. Ozoliņš». Это утверждение первой стороны от аккаунта под контролем самого Микелиса, привязывающее его имя к фуд-блогу. Это нога, на которой стоит визуальная атрибуция.

Видимая физическая метка на левой стороне шеи — небольшой пигментный невус, видимый на трёх автопортретах 2011 года на личном блоге и на фото палаты 2018 года — это вспомогательное подтверждение, а не независимая нога. Родинка — не диагностическая биометрия; при перекрёстном допросе компетентный оппонирующий эксперт разберёт её за десять минут. Она имеет значение только как проверка непротиворечивости поверх самоссылки в Twitter-био и паттерна общего имени и города. В отчёте мы называем её так, как она есть.

Индивидуальная атрибуция теперь стоит на трёх по-настоящему независимых ногах:

- Пре-2018 исторический WHOIS по двум доменам сети Torrey на личный email Микелиса, совпадающий с пре-скрытой записью самого фуд-блога.
- Общий GA4-тенант между сетью Torrey и фуд-блогом, с СТ-отпечатком привычки оператора, который переносится между ними.

- Публичная самоссылка Twitter/X-аккаунта между «M. Ozoliņš» и baltika-kaleidoscope.eu, подтверждённая (а не несущая) фотографией с мероприятия юрмальской торговой палаты и проверкой непротиворечивости по родинке.

Ступень по индивидуальной атрибуции: сильный. Не подтверждено — Микелис никогда публично не заявлял об управлении *самой сетью Torrey*, и редакции потребуется либо самоссылка, называющая свойства Torrey, либо документ первой стороны, чтобы сдвинуть эту последнюю ступень.

Тупики, которые обычно не показывают

Шесть ниток, которые никуда не пришли, перечислены по имени, чтобы отчёт был честным:

- Реверс-поиск изображения по фотографии из окна гостиницы. Вернул ноль визуально похожих изображений во всех инструментах реверс-поиска, которые я пробовал. Фотография была слишком идиосинкратичной, чтобы быть где-то перепощена, и слишком простой, чтобы быть стоковой обрезкой. Геолокацию пришлось делать руками — по фрагментам вывесок и архитектуре балкона, а не по совпадению.
- Четыре из шести origin Torrey никогда не сливались. Только два из шести доменов на короткое время сошли с Cloudflare в ноябре 2023. Остальные четыре оставались

непрозрачными всё это время. Мы можем показать на кластер, но мы не можем увидеть машину, на которой на самом деле живут четыре из шести.

- **Адреса почтовых ящиков.** Все шесть подвальных почтовых ящиков при ближайшем рассмотрении разрешаются в единый общий сервис пересылки почты, который позиционирует себя для малого бизнеса. Им пользуются сотни клиентов. Адреса не являются доказательством ничего об операторе; они являются доказательством того, что оператор нанял почтово-пересылочную компанию.
- **Отчёты DMARC на baltika-kaleidoscope.eu.** Публичный DNS показывает DMARC-запись с указателем `rua=mailto:`, но пункт назначения — приватно-пересланный ящик на сервисе, специализирующемся на DMARC-агрегации. След умирает у пересылщика. Ни регистранта, ни метаданных снаружи не видно.
- **Ширина JARM-кластера.** JARM-отпечаток, который мы подняли на `origin-VPS` в Слое 2, на момент скана имеет примерно 6 400 совпадающих хостов в интернет-широком скан-корпусе. Это широкий кластер. Он стал полезным только после фильтрации по автономной системе и стране хостинга — тот же JARM в той же AS в той же небольшой европейской юрисдикции сузил шорт-лист до двух хостов. Без этого фильтра сам по

себе отпечаток не сказал бы ничего.

- Риск однофамильца по палате торговли. «Микелис Озолиньш» — не самое редкое имя в Латвии.

Фотография палаты 2018 года легко могла быть другим Микелисом Озолиньшем — то же имя, тот же город, несвязанная жизнь. Что закрыло остаток по индивидуальной атрибуции — это собственное био Twitter/X-аккаунта, ссылающееся на baltika-kaleidoscope.eu, — самоссылка первой стороны, — с родинкой как вспомогательной визуальной проверкой непротиворечивости. Без самоссылки в Twitter визуал остался бы на умеренном, и кейс поехал бы на одну ступень ниже; родинка сама по себе — подтверждение, а не атрибуция.

Тупики — это инвентарь. Кейс без них декорирован, а не расследован.

Что говорит отчёт на самом деле

Письменный отчёт по атрибуции, на одной странице, доставленный редактору редакции и её юристу:

«Наиболее сильные независимые доказательства указывают на Микелиса Озолиньша, жителя Юрмалы (Латвия), как на оператора сети Torrey из шести сайтов общественных новостей в Латвии и Эстонии. Степень атрибуции: сильный. Текущий контроль Микелиса не подтверждён. Записи WHOIS 2017 года устанавливают его как

регистранта двух доменов сети по состоянию на 2017; живые регистрации скрыты, и домен может тихо сменить владельца. Его авторство связанного фуд-блога *baltika-kaleidoscope.eu* — это самоссылка первой стороны (био Twitter/X); его регистрация доменов Torrey — это исторический факт, а не утверждение о текущем контроле в настоящем времени.

Независимые сигналы: (i) пре-2018 исторический WHOIS по двум из шести доменов Torrey на *ozolins.m@inbox.lv*, который также является пре-2018 регистрантом *baltika-kaleidoscope.eu* и появляется в независимых публичных каталогах под полным именем Микелиса; (ii) общий GA4 measurement ID G-9K2D4X7QH1 по всем шести сайтам сети Torrey и фуд-блогу — измеряется как один Google-аккаунт, до сих пор живой и не переименованный со старта блога в 2019 году, а не просто переиспользованный сниппет; (iii) общий хеш фавикона -1246753918 (Shodan-конвенция знакового 32-битного) и совпадающий отпечаток JARM origin по двум origin Torrey, которые на короткое время сошли с Cloudflare в ноябре 2023, оба колоцированные на одном VPS; (iv) СТ-отпечаток привычки оператора — конвенция именования поддомена *dev-uat.*, — общий между фуд-блогом и одним сайтом сети.

Не подтверждено: (а) что Микелис сохраняет оперативный контроль над сетью в настоящем времени — не наблюдалось

ни утверждения первой стороны, ни самоссылки, называющей свойства Torrey, ни документа на этот счёт; (б) что сеть Torrey — сольная операция, а не небольшая команда, использующая Google-аккаунт и хостинговые привычки Микелиса. Чтобы сдвинуть находку с сильного на подтверждено, потребовалась бы публичная самоссылка, документ первой стороны, называющий Микелиса текущим оператором, или положительное официальное подтверждение от самого Микелиса — ничего из этого мы не искали. Чтобы ослабить находку до умеренного, потребовались бы правдоподобные доказательства передачи домена между 2017 и сегодняшним днём для двух зарегистрированных доменов Torrey или доказательства того, что общий GA4-тенант администрируется кем-то, кроме Микелиса».

Линия, которую мы не перешли

Мы не зондировали ни один хост. Каждая выборка была чтением публичной страницы или публичной записи. Мы не пытались достучаться до админ-панели, страницы входа или какого-либо не-связанного эндпоинта ни на одном из семи доменов.

Мы не логинились ни на одну платформу иначе, чем читатель, смотрящий на открытый контент. Мы не создавали аккаунтов, чтобы увидеть приватные профили, и мы не вступали ни в одну закрытую группу.

Мы не связывались с Микелисом. Мы не связывались ни с одним другом, коллегой или членом семьи Микелиса. Мы не использовали его сопосетителей мероприятия торговой палаты 2018 года как способ триангулировать его текущее местонахождение.

Мы не публиковали и не включали в отчёт частный домашний адрес, хотя геолокация отдельной фотографии из блога 2019 года сузила бы его до одной улицы в Юрмале. Адрес не был запросом; идентичность — была.

Профессионал — это тот, кто знает, когда остановиться.

Резюме

- Используй каждый слой, который нужен кейсу, и не более того; техники — для вопросов, а не для показухи.
- Независимые сигналы должны быть *на самом деле* независимыми — три факта, приходящие через один аккаунт, — это один источник, а не три голоса.
- Исторические записи (WHOIS до 2018, Wayback-захваты, СТ-логи, история pDNS) — это то, что позволяет тебе видеть, что оператор стёр.
- Cloudflare прячет origin ровно до тех пор, пока origin ни разу не забудет спрятаться.
- Отпечатки привычек оператора — конвенции поддоменов, аналитические ID, хеши фавиконов — сами

по себе не двигают ничего и значат много, когда три других моста уже несут вес.

- Тупики — это инвентарь. Перечисляй их по имени в отчёте; не прячь.
- Хронолокация часто и есть находка, а не украшение — паттерн *когда* может значить для истории больше, чем *где*.
- Заканчивай каждый кейс письменным отчётом, который может прочитать юрист клиента, с утверждениями, доказательствами, ступенью и *не-сделано* в одном документе.
- Ступень должна соответствовать доказательствам. Сильный — это не подтверждено, а подтверждено требует самоссылки первой стороны, которую никакое наслоение не заменит.

Цикл, в последний раз

Даже в таком масштабе форма работы всё ещё была той формой, которой она всегда бывает. Сеть анонимных фронтов обнажила отпечаток (фавикон, GA4, JARM). Каждый отпечаток пивотил на новую поверхность (стёртый блог, слитый origin, СТ-предсертификат). Каждый пивот кормил лестницу атрибуции на одну ступень. Ничего не пропущено, ничего не перепрыгнуто.

ЦИКЛ



одна зацепка, ходи по кругу, пока не укажет на человека

След — пивот — атрибуция — тот же цикл, что и первый кейс в первом томе, на большем радиусе и против цели, которая действительно пыталась спрятаться.

Переверни страницу. Четвёртый том — о том, как превратить это умение в ремесло.

Что ты можешь сделать сейчас

— и что будет дальше.

Остановись на секунду и посмотри, как далеко ты зашёл.

В Томе 1 ты научился тянуть одну нить. В Томе 2 — сплести нити с многих платформ в одного уверенного человека. В Томе 3 ты научился читать те места, где никто не собирался оставлять нить: удалённый аккаунт, фото без подписи, лог сертификата, неправильно сконфигурированный origin. Ты понял, что «пропало» почти всегда означает «сместилось», и что мир хранит записи, о которых оператор не думал, когда эту запись создавал.

В этой книге у тебя изменилось и кое-что ещё. Ты перестал нуждаться в том, чтобы объект сотрудничал. В Томах 1 и 2 большая часть работы — читать то, что человек сам выложил в открытую. Здесь большая часть работы — читать то, что человек *пытался спрятать*, и делать это, не трогая ни одного замка, без логина, без обхода, пользуясь лишь публичными записями, прочитанными внимательно. Это гораздо более холодное ощущение. Посиди с ним. Именно об этом говорят профессионалы, когда говорят, что работа

не всегда весёлая. Именно это отделяет профессионала от энтузиаста.

Держись за привычки, а не за инструменты

Платформы будут меняться. Cloudflare будет меняться. Поставщики исторического WHOIS будут сливаться или умирать. Появятся новые индексы сканов. Ничего из этого не важно. *Форма* работы не меняется: назови законный вопрос, закрепи, что у тебя есть, пройди записи, которые мир уже сделал публичными, честно посчитай независимые сигналы, взвесь каждую находку на лестнице и возьми только то, что нужно вопросу. Освой это — и любой новый инструмент станет ещё одной дверью в тот же метод.

Где продолжать точить нож

- Работай сам с собой в стиле *hard-target*. Удали старый блог. Потом попробуй восстановить его снаружи. Потом закрой каждую дыру, которую нашёл. Лучшее упражнение в этом томе.
- СТФ и верификационные челленджи. Хорошие теперь включают раунды по хронологии, геолокации и инфраструктурным пивотам. Это самый безопасный способ ускорить глаз.
- Поисковые события по пропавшим людям (например, Trace Labs) — осмысленно, аккуратно, рядом с людьми, которые этим занимаются годами, внутри жёсткого

правила «никакого контакта».

- **Читай защитников.** Обратная сторона того, что ты только что выучил, — это asset-management и работа с поверхностью атаки. Их разборы собственных утечек читаются как твои кейс-ноуты наоборот — и учат, какие утечки важны, а какие нет.

Мост к Тому Четвёртому

Эта книга была о зарытых местах. Том 4 — The Professional — о том, как превратить навык в ремесло, за которое платят и которому доверяют. Отчёты уровня решений.

Chain-of-custody. Отбор заказов. Counter-OSINT — как объект защищается ровно от того, что ты только что выучил. Автоматизация, на которую действительно можно опереться. И честная этика работающего следователя, а не хоббиста.

Пока что ты умеешь прочитать место, которое читать не хочет, и честно сказать, что ты о нём можешь и не можешь утверждать. Это много. Веди заметки, держи дисциплину. Увидимся в Томе 4.

— Yehor

Приложение А — Рабочий инструментарий (2026)

Форма инструментов, которые всё ещё работают, и как о них думать.

Это приложение называет *формы* инструментов, а не рекомендации. Любой конкретный сервис из списка к моменту, когда ты это читаешь, может исчезнуть, стать платным или испортиться. Важна форма — знание того, *какого рода инструмент* ты берёшь, подсказывает, что искать, когда текущий умрёт.

Архивы и кэши

- Общие веб-архивы. Wayback Machine (web.archive.org) — рабочая лошадка: читает полный таймлайн захватов, поддерживает поиск по URL-шаблону (web.archive.org/web/*/example.com/). Сосед: archive.today / archive.ph (одноразовые снимки, тяжелее цензурировать, полезно, когда Wayback ретроактивно заблокировали). Национальные веб-архивы — UK Web Archive, португальский Arquivo.pt, Library of Congress — часто сохраняют локальный контент, который глобальные архивы упустили.
- Остатки кэша поисковиков. Оператор cache: у Google фактически мёртв с 2024 года. Кэш Bing ещё еле дышит.

Не строй метод ни на том, ни на другом.

- **Комьюнити-снэпшот-кольца.** Небольшие архивы, которые ведут исследователи или активисты, иногда сохраняют целые субкультуры (чан-борды, мёртвые форумы). Форма: ищи домен + «archive» или «mirror» + узкое нишевое ключевое слово.

Обратный поиск изображений и фото-геолокация

- **Обратный поиск изображений.** Google Images, Yandex, Bing Visual Search, TinEye. Yandex часто сильнейший на фото-места. Скармливай *целевые кропы* (вывеска, характерный угол) — полный кадр обычно возвращает шум.
- **Поиск по лицу.** Сервисы типа PimEyes существуют, но они коммерческие, юридически чувствительные (GDPR, ВІРА) и вне рамок большинства персональной работы. Используй только внутри авторизованного заказа с задокументированным правовым основанием.
- **Калькуляторы солнца и тени.** Веб-приложения типа SunCalc (вычисляют азимут солнца на дату и координаты). Крайне полезно для хронолокации.
- **Исторические архивы погоды.** OpenWeather, Meteostat и государственные метеослужбы публикуют почасовые архивы погоды, которые можно запросить по кандидатной дате и точке.

- Историческая спутниковая съёмка. Sentinel Hub, тайм-слайдер Google Earth, публичные брифинги Planet. Смотри, когда стройплощадка появилась между пролётами.
- Прогулки по street view. Google Street View, Yandex Panoramas, Baidu Map, Mapillary, KartaView. Бери то, у чего есть покрытие региона — Mapillary заливают комьюнити, и часто это единственный источник в слабо покрытых районах.

Домены, DNS и WHOIS

- Живой WHOIS. Вывод whois регистратора плюс who.is и фронты формы whoiscologne.io. Читай каждое поле, особенно серверы имён.
- Исторический WHOIS. WhoisXMLAPI, DomainTools, SecurityTrails и подобные. Коммерческие, платные; бесплатные тиры жёстко режут. Это тот единственный рычаг, который вероятнее всего вернёт тебе email регистранта до 2018 года — стоит своих денег, если кейс настоящий.
- DNS. dig, nslookup или веб-фронты вроде mxtoolbox.com. Читай A, AAAA, MX, NS, TXT, CNAME — каждый тип записи говорит своё.
- Пассивный DNS. SecurityTrails, RiskIQ / Microsoft Defender Threat Intelligence, VirusTotal (бесплатный тир на удивление рабочий), Farsight DNSDB (энтерпрайз,

золотой стандарт).

Прозрачность сертификатов

- Интерфейсы поиска по СТ. crt.sh (Sectigo, бесплатный, рабочая лошадка), поиск сертификатов Censys, СТ-поиск Google. Читай каждый SAN в каждом серте; обращай внимание на прекертификаты.
- Мониторы СТ. Подписываешься на домен и получаешь уведомление на каждый новый сертификат. Сервисы формы certstream делают это в реальном времени.

Индексы сканирования

- Shodan — классика. Каждый открытый порт видимого интернета, с запросами и фильтрами по отпечаткам.
- Censys — чище данные по сертам и TLS, сильная поддержка JARM.
- ZoomEye — китайский индекс сканов, часто покрывает то, что западные пропустили.
- BinaryEdge и Onyphe — дополнительные корпуса сканов, стоит знать.
- FOFA — китайский, поиск по хешу фавикона среди сильнейших.

Отпечатки инфраструктуры

- **Хеш фавикона** — MurmurHash3 сырых байт фавикона, закодированный в base64 (с переводами строки каждые 76 символов — это специально и обязательно), — формат, который принимают большинство сканирующих индексов. В Python REPL: `import mmh3, base64; mmh3.hash(base64.encodebytes(open('favicon.ico','rb').read()))`. В Shodan сегодня: `http.favicon.hash:-1246753918` (знаковый 32-битный int; другие индексы используют другие соглашения по знаку и другие ключи запроса — несущая — форма).
- **JARM** — 62-символьный серверный отпечаток TLS-стека. Open-source-инструмент от Salesforce; сканирующие индексы отдадут JARM нативно. До сих пор рабочая лошадка по огромному бэк-каталогу уже отснятых хостов.
- **JA4S** — наследник мира JARM образца 2023 года, серверный и напрямую релевантный OSINT. Предпочитай его JARM на свежесконфигурированных стеках, где индекс его поддерживает; на остальном — JARM. JA4 (клиентский) и JA3 (более старый клиентский) существуют и в основном используются защитниками для идентификации семейств вредоносного ПО.
- **Отпечатки HTTP-заголовков** — Wappalyzer, BuiltWith, Whatweb. Определяют фреймворки, CDN,

CMS, аналитические стеки.

Поиск по аналитическим ID

- Поиск Google Analytics ID — SpyOnWeb, DNSlytics, сервисы формы Analyzer. Скормишь UA- или G- ID — получишь другие сайты, которые его несут. Работает и для AdSense pub-, ID Facebook Pixel, счётчиков Yandex.Metrika.

Заметка о цене

Половина форм выше имеет бесплатные парадные двери, половина — за платным сервисом. Не выкладывай личные деньги за коммерческого поставщика ради обычного любопытства. Если кейс настоящий — платящий клиент, законный журналистский общественный интерес, задокументированный вопрос защиты — цена становится строкой в смете. Иначе оставайся в бесплатном тире и принимай его пределы.

Приложение В — Шаблоны

Копируй, вставляй, используй. Написано для реальных дел.

Это рабочие болванки. Заполняй, вычёркивай ненужное, оставляй нужное.

В.1 Скоуп в одну строку

До первого пивота напиши это. Если не можешь — у тебя есть любопытство, а не дело.

```
I am looking into [subject] for [client / editor / self] to  
answer  
[specific legitimate question] on the basis of [lawful basis  
: contract,  
public interest, safeguarding, own footprint]. In scope: [wh  
at].  
Out of scope: [what]. Stop conditions: [what would end this]  
.
```

scope: one line

В.2 Карточка отчёта по геолокации

Photo: [URL / hash / where it came from, and when I got it]
Capture-time claim (if any): [what the source said]
Provenance chain: [how I got the file – screenshot? reupload
? original?]

Excludes (naked-eye pass, no tools):

- [element] → excludes [region / hemisphere / country]
- ...

Concentrates (highest-signal elements only):

- [element] → concentrates on [region]
- [element] → concentrates on [region]

Targeted reverse-image / street-view / satellite work:

- [what I looked at, what returned]

Confirmed location: [address or coordinate range]

Independent axes confirming: [1, 2, 3]

Rung: weak / moderate / strong / confirmed

Uncertainty note: [what I could not confirm]

geolocation card

В.3 Карточка отчёта по хронолокации

Photo / video: [reference]

Fast-clock signals (astronomical):

- Sun direction: [reading]
- Shadow-to-object length ratio: [reading]
- Moon phase (if visible): [reading]

Slow-clock signals (seasonal / weather):

- Foliage: [state]
- Snow / frost / rain traces: [state]
- Weather archive for candidate date at candidate location: [match / conflict]
- Manmade calendar signals: [poster, TV screen, wall calendar]
- Fashion / tech dating cues: [phone, car, streetwear]

Date bracket: [narrowest defensible range]

Rung: weak / moderate / strong / confirmed

Uncertainty note: [what I could not narrow]

chronolocation card

В.4 Таблица следа WHOIS и DNS

Каждая строка — это утверждение, которое кому-то другому придётся перепроверять через год, когда живая запись уже изменится. Сначала сохраняй, потом цитируй.

Domain: [name]
Examiner: [your name]
Examined on: [YYYY-MM-DD, timezone]
Tool versions: [whois client X.Y, dig X.Y, passive-DNS provider + query date]

Live WHOIS

- Registrar: [name]
- Created: [YYYY-MM-DD]
- Updated: [YYYY-MM-DD]
- Expiry: [YYYY-MM-DD]
- Status flags: [list]
- Nameservers: [list]
- Registrant: [redacted / name]
- Source classification: primary (registry) / secondary (aggregator) / broker
- Preservation: [Wayback URL | Perma.cc ID | archive.today ID] captured [YYYY-MM-DD HH:MM]
- Downloaded artifact SHA-256: [hash], stored at [case-file path]

Historical WHOIS

- Earliest record: [date] – [registrant email / name if any]
Source: [provider + product], classification: [primary / secondary / broker]
Preservation: [snapshot ID + timestamp], SHA-256: [hash]
- Transition 1: [date] – [what changed]
Source, classification, preservation, hash: [as above]
- Transition 2: [date] – [what changed]
Source, classification, preservation, hash: [as above]

DNS today

- A / AAAA: [IP list] – resolver [name], captured [YYYY-MM-DD HH:MM]
- MX: [mail hosts]
- NS: [nameservers]
- TXT: [records, especially verification tokens]
- CNAME: [aliases]
- Preservation: [dig +short output stored at path], SHA-256: [hash]

Passive DNS

- IP history for [domain]: [chronology]
- Reverse-history for [current IP]: [related hostnames if any]
- Provider: [name], query date: [YYYY-MM-DD], classification : broker
(pDNS is always a broker view; cite the provider, not "the internet")
- Preservation: exported JSON at [path], SHA-256: [hash]

Notable signals: [what stands out]

Not preserved / could not preserve: [what, and why]

whois trail

В.5 Карта инфраструктурных пивотов

Target site(s): [list]

Fingerprints observed:

- Favicon hash: [value] → matched on [N] other hosts (source: [scanner + date])
- GA4 / UA / AdSense ID: [value] → matched on [sites] (source, date)
- JARM: [value] → matched on [N] hosts (source, date; note cluster width)
- HTTP Server / X- headers: [notable strings]
- Historical WHOIS emails: [leaked addresses]
- humans.txt / security.txt: [content]

Independent votes for one operator:

1. [signal] on [sites] – why independent of votes 2 and 3
2. [signal] on [sites] – why independent of votes 1 and 3
3. [signal] on [sites] – why independent of votes 1 and 2

Attribution:

- Operator-cluster rung: [weak / moderate / strong / confirmed]
- Person rung: [weak / moderate / strong / confirmed]
- Residual namesake / agency ambiguity: [what would move this]

infra pivot

В.6 Отчёт об атрибуции по «жёсткой» цели

Финальный письменный продукт. Короче — лучше, чем длиннее: клиент должен уметь прочитать за пять минут и действовать. У каждого утверждения есть источник, его классификация и способ сохранения. Отчёт обязан заставлять тебя называть то, что ты *не* подтвердил; отчёт, где только находки, — это маркетинговый документ, а не доказательства.

Subject: [name / handle / cluster]
Prepared by: [examiner name and role]
Prepared on: [YYYY-MM-DD]
Prepared for: [client / editor / internal file]
Report version: [v1.0 – increment on any material change; keep a changelog line]
Changelog: [v1.0 initial; v1.1 corrected X per Y on YYYY-MM-DD]

Classification and handling

- Distribution: [Confidential – client only | Restricted – named recipients | Internal]
- Handling: [encrypt at rest, no forwarding without written approval, retention window N months]
- Do not quote in external publication without written approval from [name]

Lawful basis for this work

- [Contract with named client dated YYYY-MM-DD | Legitimate interest of the publisher in matter of public concern | Safeguarding | Regulated DD under [regime]]. All processing of personal data is limited to what is necessary for the stated question.
- Jurisdictions in scope: [list]
- Data-subject rights (where the subject is in the EU/UK): the subject may request access, rectification, or erasure of personal data held by [controller name] at [contact]. Requests to be handled per [controller]'s privacy notice dated [date].

Question answered

- [One plain sentence. The question the client asked, not the question that was easiest to answer.]

Attribution – shippable hedged sentence

- Write the finding as a single sentence a lawyer will pass.
Model:

"The strongest independent evidence points at [X] as the operator of

[Y] as of [date range]. Current control by [X] is not confirmed. No

first-party statement or self-link has been observed."

- Rung: [weak / moderate / strong / confirmed]

- What "confirmed" would require (and why we are not there):
[specific evidence – a first-party document, a self-link, an on-record statement – that would move the finding one rung]

Independent signals supporting the attribution

For each: what it is, why it is independent of the others, the source and its classification, and how it is preserved.

1. [signal]

- Source: [name], classification: primary / secondary / broker

- Preservation: [Wayback | Perma.cc | archive.today] ID [X], captured [ts]

- Artifact SHA-256: [hash], stored at [path]

- Independence: [why this is not the same fact as signals 2 and 3]

2. [signal] – as above

3. [signal] – as above

What we did not confirm (mandatory)

- [Specific fact 1 the reader might assume is confirmed and is not.]

- [Specific fact 2. Current control. Present-tense operation . Intent. Funding.

Any adjacent person. Any allegation the evidence does not carry.]

- Namesake / agency residual: [what alternative explanation survives, and what would rule it out]

Out of scope / not attempted

- [List. This is not weakness, it is discipline. Contacts not made, hosts not probed, private data not sought, adjacent persons not investigated.]

Method summary

- [Three-line paragraph. No tool-name catalogue; the client does not need it. Name the categories of source used (registry records, certificate transparency, archived captures, public directories) so a reviewer can reason about coverage.]

Data provenance (per cited fact)

- Every claim in this report is listed in the case file with:
 - : source URL,
 - source classification (primary / secondary / broker), capture timestamp,
 - preservation snapshot ID, and SHA-256 of any downloaded artifact.
- Case file: [path or secure link], SHA-256 of the case-file manifest: [hash]

Examiner sign-off

- I confirm the findings above reflect the evidence in the case file as of the date of this report, that no material contradictory evidence has been omitted, and that I have named the limits of the work honestly.
- Signed: [examiner name], [date]
- Reviewed by: [second examiner or supervising analyst], [date]

attribution report

В.7 Язык, который примет юрист

Атрибуционные фразы — это то место, где грамотную работу чаще всего переписывает редактор или прилетает письмо от юристов. Схема почти всегда одна: находка была защитимой, а фраза — нет. Держи под рукой пары «отклонённая форма — принятая форма».

Уверенность атрибуции - Отклонено: *X operates the network.* - Принято: *The strongest independent evidence points at X as the operator of the network. Current control by X is not confirmed.*

Оператор против регистранта - Отклонено: *X owns the domains.* - Принято: *X was the registrant of two of the six domains in pre-2018 WHOIS records. Present-day registration is behind a privacy proxy; current ownership is not confirmed from public records.*

«Подтверждено» против «сильно» - Отклонено: *We confirmed that X runs the site.* - Принято: *The finding sits at the "strong" rung on our internal ladder — three independent, non-collapsible public signals. It is not "confirmed"; a first-party self-link or on-record statement would be required for that.*

Личность против структуры - Отклонено: *X is behind the campaign.* - Принято: *The operator-cluster evidence points at a single hand behind the network. The evidence does not distinguish between X acting alone and X acting on behalf of an organisation; the residual is named and not resolved.*

Утверждения в настоящем времени из исторических записей

- Отклонено: *X controls the infrastructure.* - Принято: *X was named in registry records dated [YYYY]. A domain can change hands without a public record; we make no claim about control after [YYYY] beyond what the signals in section [N] carry.*

Оговорка «мы не подтвердили X» - Отклонено (пропуск):

[в отчёте только находки, никакого негативного утверждения]. - Принято: *We have not confirmed, and this report does not assert: (i) that X currently operates the network; (ii) any funding relationship; (iii) any intent behind the network's editorial choices; (iv) the involvement of any person named adjacent to X in the source material.*

Смежные лица - Отклонено: *X's associate Y is also involved.* -

Принято: *Y appears in one 2018 photograph with X. The photograph places them in the same room on one date. It carries no attribution weight for the network and Y is out of scope for this report.*

Правило поверх всего этого: пиши такую фразу, которую готов прочитать вслух на допросе. Если хоть одно слово в ней уходит дальше того, что лежит в деле, — вычёркивай это слово.

Приложение С — Красные линии

Одна карточка. Перечитывать каждый год.

Ничто в этой книге не требует от тебя пересекать красную линию. Если техника соблазняет тебя её пересечь — ты выбрал не ту технику. Почти всегда есть способ ответить на законный вопрос без этого сокращения.

Линии здесь не исчерпывающие. Это те, к которым читатель Тома 3 подойдёт вплотную с наибольшей вероятностью.

Доступ

- Никаких логинов туда, куда ты не имеешь права. Читать публичный снапшот — нормально. Угадывать пароль, реиграть старую куку или использовать украденную учётку, чтобы зайти в живой аккаунт — это несанкционированный доступ в большинстве юрисдикций (CFAA в США, Computer Misuse Act в Великобритании, статья 32 GDPR как нарушение в других местах).
- Никакого обхода пейволлов, robots-файлов или лимитов запросов силой. robots.txt в большинстве юрисдикций не *юридический* барьер, но злоупотребление лимитами или обход явного контроля доступа сервиса —

быстрый путь к гражданской ответственности, а иногда и к уголовной. Если оператор явно попросил автоматические читалки не соваться — не суйся.

- Никакого прощупывания хостов, которые ты вычислил. Найти админ-поддомен в СТ — работа с публичными записями. Дёрнуть логин-страницу этого поддомена — уже запрос. Попробовать на нём учётки — несанкционированный доступ. Перечисляй; не трогай.

Происхождение данных

- Понимай, что покупаешь. Коммерческий рDNS, исторический WHOIS и данные сканирующих индексов — всё это где-то собрано агрегацией логов. Какие-то поставщики получили согласие операторов резолверов, какие-то нет. Если работаешь в регулируемой среде — спрашивай.
- Не используй данные утечек, чтобы залогиниться. Пароль из утечки доказывает, что аккаунт существовал. Использовать этот пароль, чтобы зайти в живой аккаунт — почти везде преступление. См. Том 2, Глава 5.
- Ссылайся на каждый источник в каждом отчёте. Каждое утверждение — URL и время захвата. Если источник платный или под NDA — называй поставщика по имени, а не внутренний идентификатор.

Люди

- Человек — не мишень. Том 3 очень легко даёт соскользнуть с *оператора* на *его семью, соседей, арендодателя, ребёнка на заднем плане геолоцированного фото*. Не соскальзывай. Собери то, что отвечает на вопрос, и остановись.
- Никогда не геолоцируй частный дом, чтобы это опубликовать. Даже если это неоспоримо. Даже в расследовании по утечке. Общественный интерес почти никогда не требует точных координат.
- Никогда не хронолоцируй перемещения человека, чтобы это опубликовать. Узор частной жизни — не публичная запись. Сообщи находку клиенту, если этого требует кейс; не публикуй её.
- Исключение: домашнее насилие / stalking / высокий риск. Если тебя попросили найти человека, который специально ушёл из старой жизни, — откажись. Точка. Внутри служб защиты есть профессионалы, которые делают это правильно. Ты не один из них, начитавшись книги.

Этика раскрытия

- **Общественный интерес** — не то же самое, что общественное любопытство. Тест общественного интереса в редакции спрашивает: пропорционален ли вред объекту вреду обществу, если это останется скрытым? Тест любопытства спрашивает: могу ли я это узнать? Первый оправдывает публикацию; второй — никогда.
- **Минимальное раскрытие.** Публикуй только то, что отвечает на вопрос. Если ты нашёл свадебное фото, чтобы подтвердить место жительства, — называй место жительства, а не свадьбу.
- **Ты не последняя проверка.** Если твой отчёт уходит клиенту, который может по нему действовать — журналисту-расследователю, корпоративному DD, офицеру защиты — ожидай, что он добавит свои проверки. Это не недоверие; это процесс.

Линия, которую ты ставишь сам себе

Над каждым правилом: тот, кто знает, когда остановиться, а не тот, кто нашёл больше всех. Если ты не можешь одним простым предложением сказать, зачем ты тянешь эту нить, — перестань её тянуть. Читай каждую карточку в этом приложении в начале каждого кейса. Это минута. Это спасает карьеры.

Приложение D — Забери своё обратно

Всё, что ты только что научился читать, — закрой против самого себя.

Каждая глава этой книги учила тебя читать след. Это приложение — закрывающее упражнение: прочитай *свой собственный* след и закрой, где можешь. Половина этого — мышечная память, стоит один раз сделать; вторая половина — привычка обслуживания.

Делай это дважды в год. Как только становится неуютно — новая работа, публичное появление, переезд в новый город, вопрос личной безопасности — сделай это в ту же неделю.

Архивы (Гл. 1)

- Поищи в Wayback Machine каждый домен, которым ты когда-либо владел. Прочитай таймлайн. Если что-то стыдное — запроси удаление из Wayback (они принимают часть запросов). Если что-то хуже — понимай: запрос-и-забыл недостаточно, сторонние зеркала могут всё ещё это нести.
- Поищи в кавычках редкие фразы, которые ты когда-то писал. Посмотри, что сохранили третьи стороны. Всё, что тебя удивляет, — сигнал для следующей секции.

Удалённые профили (Гл. 2)

- Составь список каждого аккаунта, который ты когда-либо создавал. Старый MySpace, ICQ, Xanga, LiveJournal, мёртвые форумы, вики того игрового клана из 2011. Поищи каждый по нику и по email.
- Прогони через обратный поиск изображений аватарку, которую ты использовал в каждом. Одинаковая аватарка между двумя аккаунтами, которые ты считал разделёнными, — это сокращение, которое ты оставил кому угодно.
- Прочитай осадок графа друзей. На платформах, которые до сих пор показывают общих друзей, посмотри, что незнакомец мог бы вывести о твоей сети.
- Opt-out у брокеров данных. People-search-сайты держат снапшоты годами. У каждого сайта в США есть страница отписки — большинство враждебные, все в итоге работают. Есть консолидированные сервисы, которые делают это за тебя; не рекомендация, просто заметка.

Фотографии (Гл. 3 и 4)

- Убирай EXIF со всего, что публикуешь. Большинство соцплатформ сейчас его срезают, но блоги и облачные шары часто нет.
- Читай свои же опубликованные фото глазами геолокатора. Номер дома в углу. Отражение в зеркале.

Характерное дерево. Убирай их или обрезай.

- Сделай то же самое для хронологии. Паттерн «всегда по вторникам постим из того же кафе» помещает тебя в привычку. Если привычка важна для твоей безопасности — сломай её.
- Особая забота о детях. Фото школьного значка, маршрут в школу, форма в семейном кадре — любое из этого — хронология утра вторника ребёнка. Не публикуй.

Домены (Гл. 5)

- Прочитай свой живой WHOIS. По каждому домену, которым ты владеешь, посмотри, что публично. Если твой email регистранта датирован до 2018 года — исторический WHOIS всё ещё его хранит, профессиональный противник найдёт его там.
- Прочитай свой DNS. MX-записи выдают твоего почтового провайдера; TXT-записи выдают твой tenant Google Workspace или Microsoft 365; SPF выдаёт каждого отправителя, которого ты разрешил. Ничего из этого не секрет; важно понимать, что оно выдаёт.
- Переведи личные домены на регистрацию с privacy, если ещё не. Утечка 2011 года случилась — но 2026 и вперёд может быть тихим.

Сертификаты (Гл. 6)

- Поищи в СТ свои же домены. Прочитай каждый SAN в каждом сертификате. Если там есть staging-окружение, о котором ты забыл, — этот хостнейм публичен навсегда. Если хост мёртв — сними его; если жив и по-настоящему внутренний — переведи на приватный CA (вне СТ).
- Осторожно с wildcard-сертами. Wildcard SAN защищает всё, но сам *факт*, что у тебя wildcard на домене, говорит профессионалу, что у тебя есть поддомены, которые стоят перечисления.

Отпечатки инфраструктуры (Гл. 7 и 8)

- Инвентаризируй свои операторские отпечатки. У всех твоих личных сайтов один и тот же фавикон? Один и тот же GA measurement ID? Один и тот же tag manager? Если да, а сайты связывать нельзя — развяжи их.
- Разнообрази стек между идентичностями, которые не должны соединяться. Два сайта, которые ты хотел держать раздельно, не должны делить одну и ту же платную тему WordPress, один и тот же файл аватарки, одни и те же имена CSS-классов.
- Проверь свой JARM. Если самохостишь — прогони JARM-инструмент по своему edge. Если твой отпечаток редкий — противник найдёт каждый другой хост, который ты крутишь с той же конфигурацией.

Привычки

- Пароль-менеджер, 2FA везде. Это привычка Тома 1; всё ещё крупнейшее одноразовое сокращение поверхности атаки. Не опция.
- Синхронизация контактов — выключить. Двусторонний РУМК свяжет твою исследовательскую идентичность с настоящей в первый же раз, когда оба приложения прочитают адресную книгу. См. Том 2.
- Компартиментализируй. Исследовательский браузер — не твой личный. Исследовательский телефон — не твой личный. Исследовательский ник — не тот, что ты когда-либо использовал раньше.
- Когда тебя уже ищут. Если ты знаешь или подозреваешь, что за тобой следят или тебя stalkают, — не запускай этот чек-лист на своих обычных аккаунтах: паттерн внезапного отвердевания сам по себе сигнал. Меняй всё разом, с чистого устройства, за одну сессию. Или обратись к профессионалу службы защиты; в этом нет стыда.

Линия

Ты не закроешь каждую дыру. И не нужно. Нужно ровно столько трения, чтобы случайный противник отвалился, и ровно столько дисциплины, чтобы серьёзному пришлось попотеть. Читай каждую главу этой книги как инструкцию по своей собственной защите. Потом закрой то, что можешь, живи с тем, что не можешь, и возвращайся к работе.

Глоссарий

Простые определения каждого термина, который эта книга использует больше одного раза. Заглядывай в любой момент.

- **AdSense ID / pub-id** — идентификатор издателя у Google для рекламной выручки, формата pub-1234567890123456. Когда один и тот же pub-id всплывает на двух разных сайтах, платят одному и тому же кошельку — поэтому это один из самых сильных сигналов атрибуции на лестнице.
- **Anchor / якорь** — та одна фиксированная известная вещь, с которой ты начинаешь расследование. Домен, фото, ник, номер телефона. Всё остальное в деле достигается прыжками от якоря.
- **Attribution / атрибуция** — третий ход в цикле. Превращение «это принадлежит какому-то человеку» в «это принадлежит *тому* человеку» — название оператора за следом.
- **Autonomous System (AS)** — кусок интернета под контролем маршрутизации одного оператора, идентифицируемый номером AS вроде AS13335. Полезен для группировки IP по тому, кто реально их держит, а не по тому, чьё имя в WHOIS.

- **Banner** — короткая строка, которую сервис издаёт в момент, когда ты открываешь к нему соединение. Номера версий, имена ПО, иногда хостнеймы. Бесплатная идентификация, логин не требуется.
- **Capture time** / время снимка — метка времени, когда был сделан снимок, а не время, когда ты на него смотришь. У каждой архивной страницы, каждого скана, каждого скриншота она есть. Цитируй, или доказательства тихо сгниют.
- **Certificate Transparency (CT)** / прозрачность сертификатов — публичная append-only система логов, где регистрируется каждый доверенный TLS-сертификат. Сделала перечисление поддоменов тривиальным и убила идею, что хостнейм может остаться секретом.
- **Chronolocation** / хронолокация — датирование изображения по тому, что в кадре. Угол солнца, листва, вывески магазинов, снег, дорожные работы, плакат с датой. Отвечает на «когда», а не «где».
- **clientTransferProhibited** — EPP-статус-код на домене, который блокирует его перенос к другому регистратору без разблокировки. Это анти-хайджек-замок, не более. Он не скрывает регистранта, и его наличие ничего не говорит о владельце.
- **CNAME** — DNS-запись, которая указывает один хостнейм на другой хостнейм, а не на IP.

`www.example.com` CNAME на `example.com` — классика.

Иди по цепочке — цель алиаса часто раскрывает арендатора хостинга.

- **Confidence ladder / лестница уверенности** — четыре ступени, на которых эта книга градуирует сигналы: слабый, умеренный, сильный, подтверждено. Слабый сигнал — намёк; подтверждённый — самоссылка или квитанция. Всё в отчёте должно быть промаркировано где-то на лестнице.

- **DKIM** — опубликованная в DNS система криптографических подписей, которая доказывает, что письмо было реально отправлено кем-то, авторизованным для этого домена. TXT-записи `s1._domainkey` — это DKIM.

- **DMARC** — политика в DNS-записи, которая говорит принимающим почтовым серверам, что делать, когда проверки SPF или DKIM провалились — доставить, поместить в карантин или отклонить. Публикуется в `_dmarc.example.com`.

- **DNS** — телефонная книга, которая превращает хостнеймы вроде `example.com` в IP-адреса. Почти каждая техника в Томе 3 либо запрашивает DNS, либо читает его историческую тень.

- **DoH / DoT** — DNS-over-HTTPS и DNS-over-TLS. Два способа шифрования DNS-запросов, чтобы наблюдатель

сети не видел, какие хостнеймы ты разрешил. Важно для исследовательской гигиены, не для того, что ты можешь запрашивать.

- **Dork** — поисковый запрос, построенный из операторов — `site:`, `inurl:`, `filetype:`, `intitle:`. Хорошо сформированный dork превращает поисковик в целевой индекс.
- **EXIF** — блок метаданных внутри фото-файла. Марка и модель камеры, объектив, выдержка, иногда GPS-координаты и серийник телефона. Стирай его со всего, что публикуешь; читай на всём, что получаешь.
- **Exposure / след** — первый ход в цикле: отпечаток субъекта, который уже лежит на виду. Ты не создаёшь следы, ты их замечаешь.
- **Favicon / фавикон** — маленькая иконка, которую браузер показывает во вкладке сайта. Обычно отдаётся с `/favicon.ico`. Переиспользуется на разных ресурсах субъекта гораздо чаще, чем он понимает.
- **Favicon hash / хеш фавикона** — MurmurHash3 сырых байтов файла фавикона, закодированный в base64. Индексы сканирования позволяют искать по этому хешу — один фавикон может опознать каждого хоста, отдающего тот же файл.
- **Fingerprint / отпечаток** — повторяемый идентификатор, полученный из конфигурации. Одна и та же настройка — один и тот же отпечаток, на разных IP и

хостнеймах. JARM, JA3, хеши фавиконов — все отпечатки.

- FOAF (friend-of-a-friend) — техника, которая идёт через сети других людей, чтобы добраться до субъекта. Субъект может закрыть свой профиль; публичный свадебный альбом его кузины — нет.
- GA4 (Google Analytics 4) — текущий аналитический маяк Google, идентифицируемый measurement ID формата G-XXXXXXX. Два сайта, несущих один и тот же measurement ID, разделяют владельца.
- GDPR — регламент ЕС о приватности, который в 2018 заставил регистраторов редактировать личные данные в WHOIS. Именно поэтому «почему WHOIS пустой» почти никогда не зловещий ответ.
- Geolocation / геолокация — определение, где был сделан снимок, по тому, что в нём видно. Горизонт, холмы, дорожная утилита, язык на вывесках. Отвечает на «где»; хронология отвечает на «когда».
- Historical WHOIS / исторический WHOIS — снапшоты WHOIS-записей до текущей — часто до GDPR-редакции. Домен, анонимный сегодня, мог нести полное имя и email в 2015.
- Нор / pivot / пивот — второй ход в цикле: превращение одного следа в следующий. От домена к его сертификату к другому домену. От ника к email к второму нику. Каждое

дело — цепь пивотов.

- **HTTP header / HTTP-заголовок** — метаданные, отправляемые с HTTP-запросом или ответом — Server, Set-Cookie, X-Powered-By и десятки других. Читай их; они утечивают стек, арендатора и иногда внутренние хостнеймы.
- **ICANN** — некоммерческая организация, которая управляет политикой доменных имён на вершине дерева. Задаёт правила, которым должны следовать регистраторы и реестры.
- **Independence (of signals) / независимость сигналов** — два сигнала считаются двумя голосами только если пришли из отдельных источников. Три страницы одного скрейпера, повторяющего одну утечку, — один сигнал, а не три.
- **JARM** — 62-символьный отпечаток того, как TLS-сервер отвечает на набор проб-хендшейков. Два сервера с одинаковым JARM почти наверняка запускают один и тот же стек, настроенный одинаково.
- **JA3 / JA4 / JA4S** — форматы отпечатков для *клиентской* стороны TLS-хендшейка (JA3, JA4) и *серверной* (JA4S). Используются для группировки трафика и инфраструктуры по стоящему за ними ПО.
- **Leak / breach / утечка / взлом** — дампы пользовательских данных, сделанный публичным без

согласия платформы. Исторически одно и то же слово используется для обоих; относись как к доказательству, цитируй источник и дату и никогда не перепубликуй сырые записи.

- **MurmurHash3** — быстрая некриптографическая хеш-функция. Используется индексами сканирования для отпечатков фавиконов; не используется ни для чего, чувствительного к безопасности.
- **MX record** — DNS-запись, которая называет почтовый сервер, ответственный за домен. Говорит, ведёт ли компания собственную почту, использует Google Workspace, Microsoft 365 или что-то более редкое.
- **Nameserver (NS) / сервер имён** — DNS-сервер, который реально держит записи домена. Два домена, разделяющие малоизвестный сервер имён, часто разделяют оператора.
- **Passive DNS (pDNS) / пассивный DNS** — архив исторических DNS-резолуций, собранный публичными резолверами за годы. Позволяет спросить «во что этот хостнейм разрешался в марте 2019» задолго после того, как запись изменилась.
- **Phenology / фенология** — сезонный цикл растений. Распускание почек, выход листа, цветение, сенесценция. На уличной фото состояние растительности сужает окно снимка до нескольких недель.

- **Precertificate** — версия TLS-сертификата, отправленная в СТ-логи до того, как подписан финальный лист. Именно она делает возможным поиск поддоменов через СТ практически в реальном времени.
- **Provenance / провенанс** — откуда пришло доказательство и как оно к тебе попало. Каждое заявление в отчёте должно нести свой провенанс; заявление без провенанса нельзя защитить.
- **Punycode / ACE form** — ASCII-кодировка, которую DNS использует для интернационализированных доменных имён, с префиксом xn--. xn--80akhbyknj4f — это испытание в проводной форме DNS. Следи за похожими на вид.
- **Ranking (on the ladder) / ранжирование** — действие присвоения слабый, умеренный, сильный или подтверждено сигналу до того, как ты его записываешь. Ранжируй по мере сбора; не откладывай.
- **Redaction (WHOIS) / редакция WHOIS** — пост-GDPR-практика скрывать имя, email и адрес регистранта за плейсхолдер-текстом или алиасом сервиса приватности. Стандарт, не подозрительно.
- **Registrar vs Registry / регистратор против реестра** — регистратор — вендор, у которого ты покупаешь домен (GoDaddy, Namecheap, Cloudflare). Реестр — авторитет, ведущий сам TLD (Verisign для .com, Nominet для .uk).

Разные роли, часто путают.

- **Research account** / исследовательский аккаунт — см. *sock account*.
- **Research browser** — см. *working browser vs research browser*.
- **Reverse-IP / reverse-DNS** — спрашивать «какие ещё хостнеймы разрешались в этот IP» (reverse-IP) или «какой хостнейм этот IP заявляет в записи PTR» (reverse-DNS). Два разных запроса, оба полезные, легко перепутать.
- **RFC 6962** — спецификация, определяющая логи Certificate Transparency. Цитируй, когда кто-то утверждает, что СТ опциональна; она нет.
- **robots.txt** — текстовый файл по /robots.txt, где сайт вежливо просит краулеры не индексировать определённые пути. Носит рекомендательный характер. Пути, которые он называет, часто самые интересные на сайте.
- **SAN (Subject Alternative Name)** — список хостнеймов, для которых валиден один TLS-сертификат. Сертификат с example.com, dev.example.com, staging.internal.example.com в SAN только что бесплатно сказал тебе три поддомена.
- **Scan index / индекс сканирования** — поисковый каталог каждого хоста, видимого в публичном интернете, ведомый такими сервисами, как Shodan, Censys или

FOFA. Ты запрашиваешь; сам не сканируешь.

- **SCT (Signed Certificate Timestamp)** — квитанция от СТ-лога, доказывающая, что сертификат был в него отправлен, встроенная в сам сертификат. Это то, что браузеры проверяют, чтобы обеспечить прозрачность.
- **Self-link / самоссылка** — заявление собственности от первого лица. Собственный сайт субъекта, ссылающийся на его ник. Самый сильный сигнал на лестнице для атрибуции.
- **Snapshot / снимок, снапшот** — сохранённая копия страницы в конкретный момент. Снапшоты Wayback Machine, снапшоты archive.today, твои собственные скриншоты. Всегда записывай время снимка рядом.
- **Sock account / исследовательский аккаунт** — чистая исследовательская личность, отдельная от настоящей у исследователя. Также называется research account. Используется для всего, что связано с логином или взаимодействием.
- **SPF** — DNS TXT-запись, которая перечисляет, каким почтовым серверам разрешено отправлять почту от имени домена. Раскрывает почтовую инфраструктуру и, иногда, сторонних арендаторов.
- **Subdomain / поддомен** — имя слева от базового домена. dev.example.com, mail.example.com. СТ-логи, DNS-брутфорс и пассивный DNS — способы их

перечислять.

- **TLS / SSL** — криптографический слой под HTTPS. TLS — текущее имя; SSL — более старое; люди используют их взаимозаменяемо. Каждый отпечатываемый хендшейк в этой книге живёт здесь.
- **TLD** — верхний домен — последний лейбл хостнейма. .com, .eu, .io, .рф.
- **TXT record** — свободная DNS-запись. Держит SPF, DKIM, DMARC и каждый верификационный токен SaaS, который домен когда-либо настраивал. Одна из самых утечивых записей в DNS.
- **UA-ID (legacy Google Analytics)** — более старый идентификатор Google Analytics, формы UA-XXXXX-Y. Устарел в 2023, но всё ещё виден в архивных страницах; всё ещё валиден для исторической атрибуции.
- **Verification token / верификационный токен** — случайная строка, которую сторонний сервис просит опубликовать в DNS для доказательства владения доменом. TXT-записи ими набиты. Каждый называет сервис, которым пользуется оператор.
- **Wayback Machine** — сервис истории веб-страниц у Internet Archive по адресу web.archive.org. Первая остановка по умолчанию для «как эта страница выглядела до этого».

- WHOIS — публичная запись о том, кто зарегистрировал домен, когда, через какого регистратора, до какого срока. После 2018 личные поля обычно отредактированы; операционные — нет.
- Wildcard cert — TLS-сертификат, чей SAN — *.example.com, валидный для каждого непосредственного поддомена. Удобен оператору и тихо враждебен к перечислению.
- Working browser vs research browser / рабочий против исследовательского браузера — твой ежедневный Chrome, залогиненный в твои настоящие аккаунты, — это рабочий браузер. Чистый профиль без cookies, без синхронизации, без расширений, которых ты сам не выбирал, — исследовательский. Никогда не путай их.

Если слово, которое эта книга использует больше двух раз, здесь не встречается — это баг, отметь. Глоссарий растёт с читателем.